ICT 6101: Introduction to Information Security

- Introduction to information security: security principles, access control mechanisms, authentication schemes;
- Information security concepts, classification, security threats such as phishing, spam, adware, ransomware, trojan, virus, etc;
- Operating system security: classic security models, common vulnerabilities, Linux, Windows, and cloud security;
- Cyber-attacks: examples, tools, and methodologies,
- Network security: firewall, intrusion detection system; intrusion prevention system, cyber defense techniques;
- Cyber forensics: tools, mechanisms, challenges;
- Cyber-ethics: cybercrimes, intellectual properties, privacy.

What is cybersecurity?

Cyber security is the practice **of defending computers, servers, mobile devices, electronic systems, networks**, and data from malicious attacks.

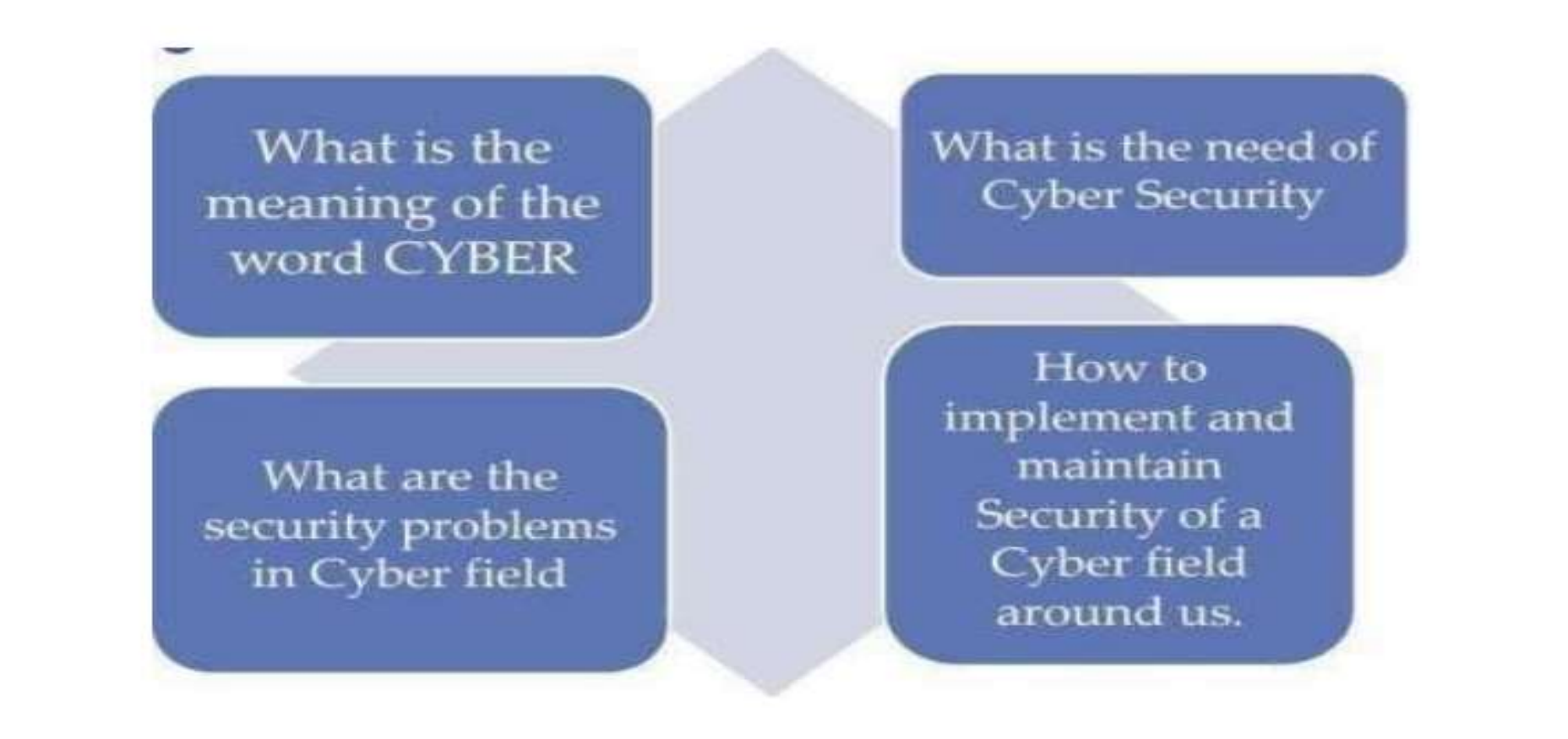
Or

Cyber security is **the application of technologies, processes, and controls to protect systems, networks, programs**, devices and data from cyber attacks.

Or

Cyber security refers **to every aspect of protecting an organization and its employees and assets against cyber threats**.

Understanding Cyber Security



Cyber and Cyberspace

- a combining form meaning “computer,” “computer network,” or “virtual reality,” - involving computers or computer networks (such as the Internet).

- Cyberspace can be defined as an intricate environment that involves interactions between people, software, and services. It is maintained by the worldwide distribution of information and communication technology devices and networks.

- the cyberspace today has become a common pool used by citizens, businesses, critical information infrastructure, military and governments in a fashion that makes it hard to induce clear boundaries among these different groups.

CIA triad

The three letters in " CIA triad " stand for Confidentiality, Integrity, and Availability. The CIA triad is a common model that forms the basis for the development of security systems. They are used for finding vulnerabilities and methods for creating solutions.



Confidentiality measures

Standard measures to establish confidentiality include:

- Data Encryption,
- Two-factor authentication,
- Biometric Verification,
- SecurityTokens



Integrity measures

Standard measures to guarantee Integrity include:

- Cryptography
- checksums Using file permissions
- Uninterrupted power supplies
- Data backups



Availability measures

Standard measures to guarantee Availability include:

- Backing up data to external drives,
- Implementing firewalls
- Having backup power supplies
- Data redundancy



Asset

- An asset is any data, device or other component of an organization's systems that is valuable – often because it contains sensitive data.
- For example:

- An employee's desktop computer, laptop or company phone would be considered an asset, as would applications on those devices.

- Likewise, critical infrastructure, such as servers and support systems, are assets.

- An organization's most common assets are information assets. These are things such as databases and physical files – i.e. the sensitive data that you store.

Threat/Cyber threat

- A threat is any incident that could negatively affect an asset – for example, if it's lost, knocked offline or accessed by an unauthorized party.

Or

- Cybersecurity threats are acts performed by individuals with harmful intent, whose goal is to steal data, cause damage to or disrupt computing systems.
- Threats can be categorized as circumstances that compromise the confidentiality, integrity or availability of an asset, and can either be intentional or accidental.
- Intentional threats include things such as criminal hacking or a malicious insider stealing information, whereas accidental threats generally involve employee error, a technical malfunction or an event that causes physical damage, such as a fire or natural disaster

Common Sources of Cyber Threats against organization

Here are several common sources of cyber threats against organizations:

- **Nation states**—hostile countries can launch cyber attacks against local companies and institutions, aiming to interfere with communications, cause disorder, and inflict damage.
- **Terrorist organizations**—terrorists conduct cyber attacks aimed at destroying or abusing critical infrastructure, threaten national security, disrupt economies, and cause bodily harm to citizens.
- **Criminal groups**—organized groups of hackers aim to break into computing systems for economic benefit. These groups use phishing, spam, spyware and malware for extortion, theft of private information, and online scams.
- **Hackers**—individual hackers target organizations using a variety of attack techniques. They are usually motivated by personal gain, revenge, financial gain, or political activity. Hackers often develop new threats, to advance their criminal ability and improve their personal standing in the hacker community.
- **Malicious insiders**—an employee who has legitimate access to company assets, and abuses their privileges to steal information or damage computing systems for economic or personal gain. Insiders may be employees, contractors, suppliers, or partners of the target organization. They can also be outsiders who have compromised a privileged account and are impersonating its owner.

Types of Cybersecurity Threats

- Malware Attacks
- Social Engineering Attacks
- Supply Chain Attacks
- Man-in-the-Middle Attack
- Denial-of-Service Attack
- Injection Attacks

Cyber attack

- An offensive action by a malicious actor that is intended to undermine the functions of networked computers and their related resources, including unauthorized access, unapproved changes, and malicious destruction.

- Examples of cyber attacks include Distributed Denial of Service (DDoS) and Man-in-the- Middle (MITM) attacks.

Threat, attack and risk differences

The terms cyber attack, cyber threat, and cyber risk are interrelated as follows:

- A **cyber attack** is an **offensive** action, whereas a **cyber threat i**s the **possibility** that a particular attack may occur, and the **cyber risk** associated with the subject threat **estimates the probability of potential losses** that may result.

- For example, a Distributed Denial of Service (**DDoS**) cyber attack by a **botnet** is a cyber threat for many enterprises with online retail websites, where the associated cyber risk is a function of **lost revenues due to website downtime** and the **probability that a DDoS cyber attack will occur**.

Cyber Security Solutions

Here are the main types of security solutions:

- **Application security**—used to test software application vulnerabilities during development and testing, and protect applications running in production, from threats like network attacks, exploits of software vulnerabilities, and web application attacks.
- **Network security—**monitors network traffic, identifies potentially malicious traffic, and enables organizations to block, filter or mitigate threats.
- **Cloud Security—**implements security controls in public, private and hybrid cloud environments, detecting and fixing false security configurations and vulnerabilities.
- **Endpoint security—**deployed on endpoint devices such as servers and employee workstations, which can prevent threats like malware, unauthorized access, and exploitation of operating system and browser vulnerabilities.
- **Internet of Things (IoT) security—**connected devices are often used to store sensitive data, but are usually not protected by design. IoT security solutions help gain visibility and improve security for IoT devices.
- **Threat intelligence**—combines multiple feeds containing data about attack signatures and threat actors, providing additional context for security events. Threat intelligence data can help security teams detect attacks, understand them, and design the most appropriate response.

What Are The Different Information Security Fields?

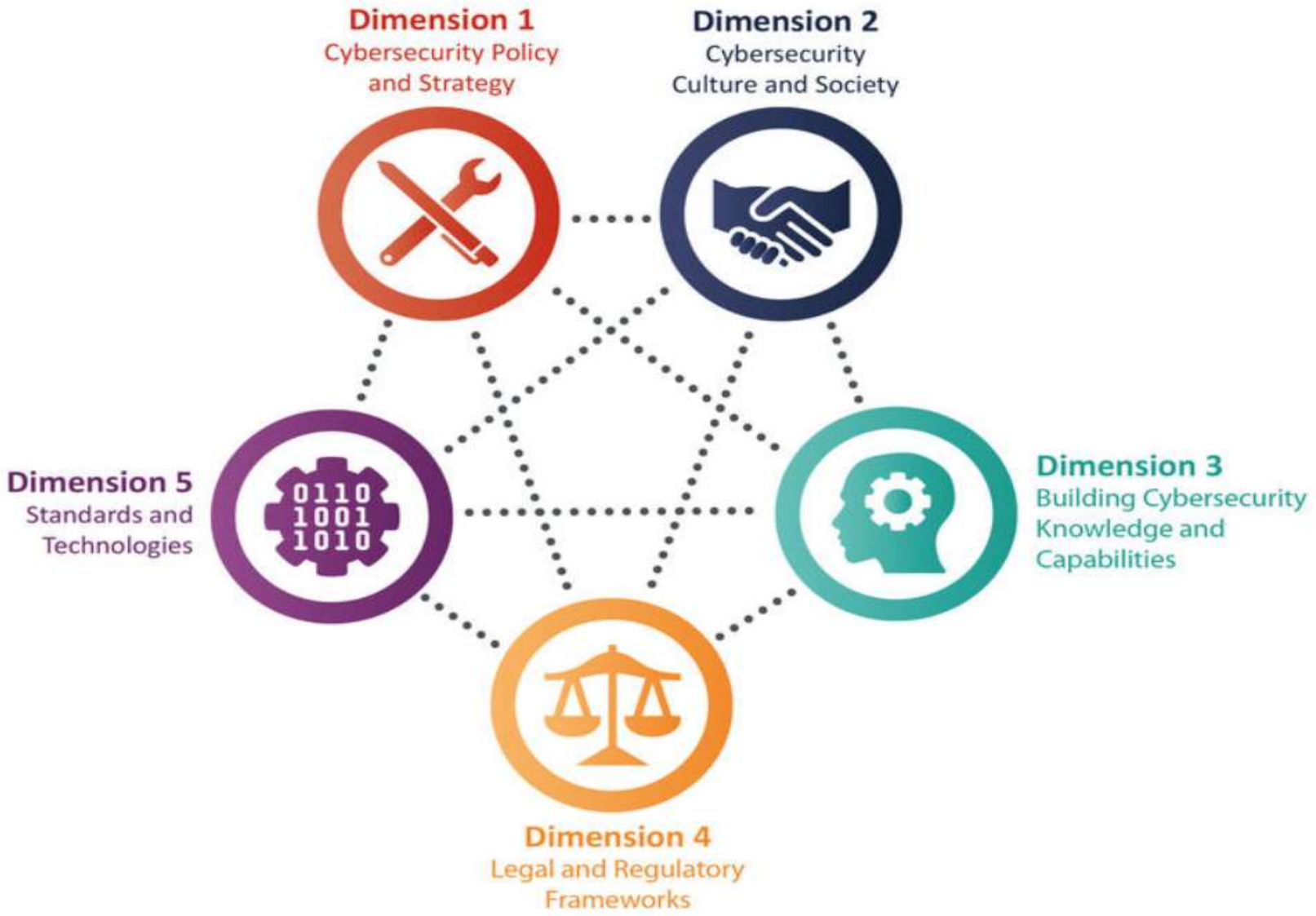
- Physical Cybersecurity **-** include biometric authentication, surveillance cameras, and access control systems to prevent unauthorized access.
- Information Security/endpoint security/application security
- IT Auditing & Consulting/Governance, risk, and compliance
- Ethical Hacking/Penetration Testing
- Intrusion detection
- Threat Intelligence
- Software Development
- Cloud security
- Digital Forensics and incident response
- Cryptography

Dimensions of cybersecurity

There are main 5 (five) dimension of cybersecurity:

- **Dimension 1**: **Cybersecurity policy and strategy** (effective policy and strategy)
- **Dimension 2**: **Cybersecurity culture and society** (effective trust, confidence and mindset)
- **Dimension 3**: **Building cybersecurity knowledge and capabilities** (effective security education, awareness & technical expertise)
- **Dimension 4: Legal and regulatory framework** (effective legal regime)
- **Dimension 5: Standard and Technologies** (effective implementation of cybersecurity standards, infrastructure, technology and good practices)

Dimensions of cybersecurity

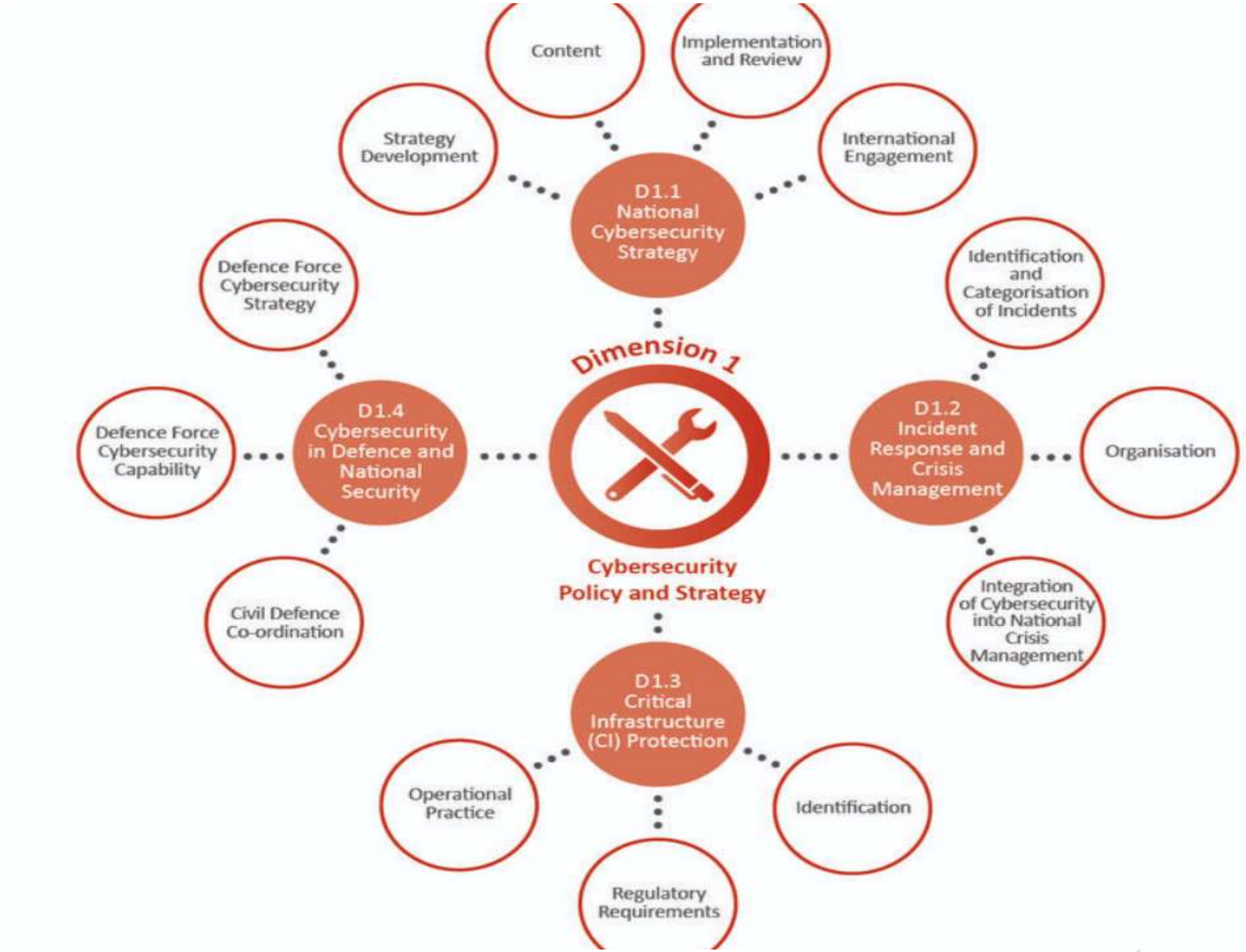


Cybersecurity Capacity Maturity Model (CMM) for Nations

The Cybersecurity Capacity Maturity Model (CMM) for Nations is a methodical framework designed to review a country's cybersecurity capacity. The CMM considers cybersecurity to comprise five *Dimensions* which, together, constitute the breadth of national capacity that a country requires to be effective in delivering cybersecurity:

- **Developing cybersecurity policy and strategy;**
- **Encouraging responsible cybersecurity culture within society;**
- **Building cybersecurity knowledge and capabilities;**
- **Creating effective legal and regulatory frameworks; and**
- **Controlling risks through standards and technologies.**

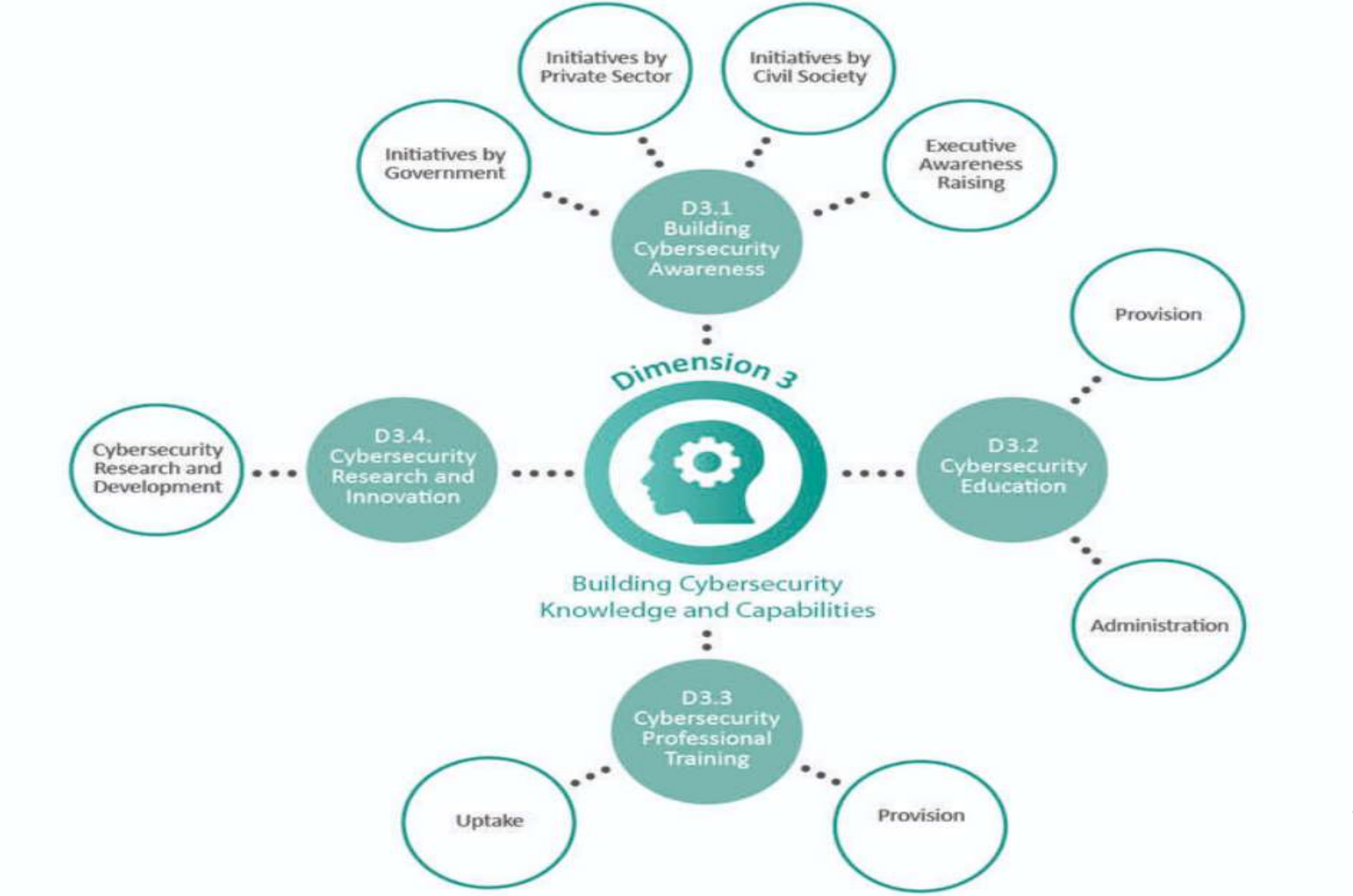
Cybersecurity: Dimension 1



Cybersecurity: Dimension 2



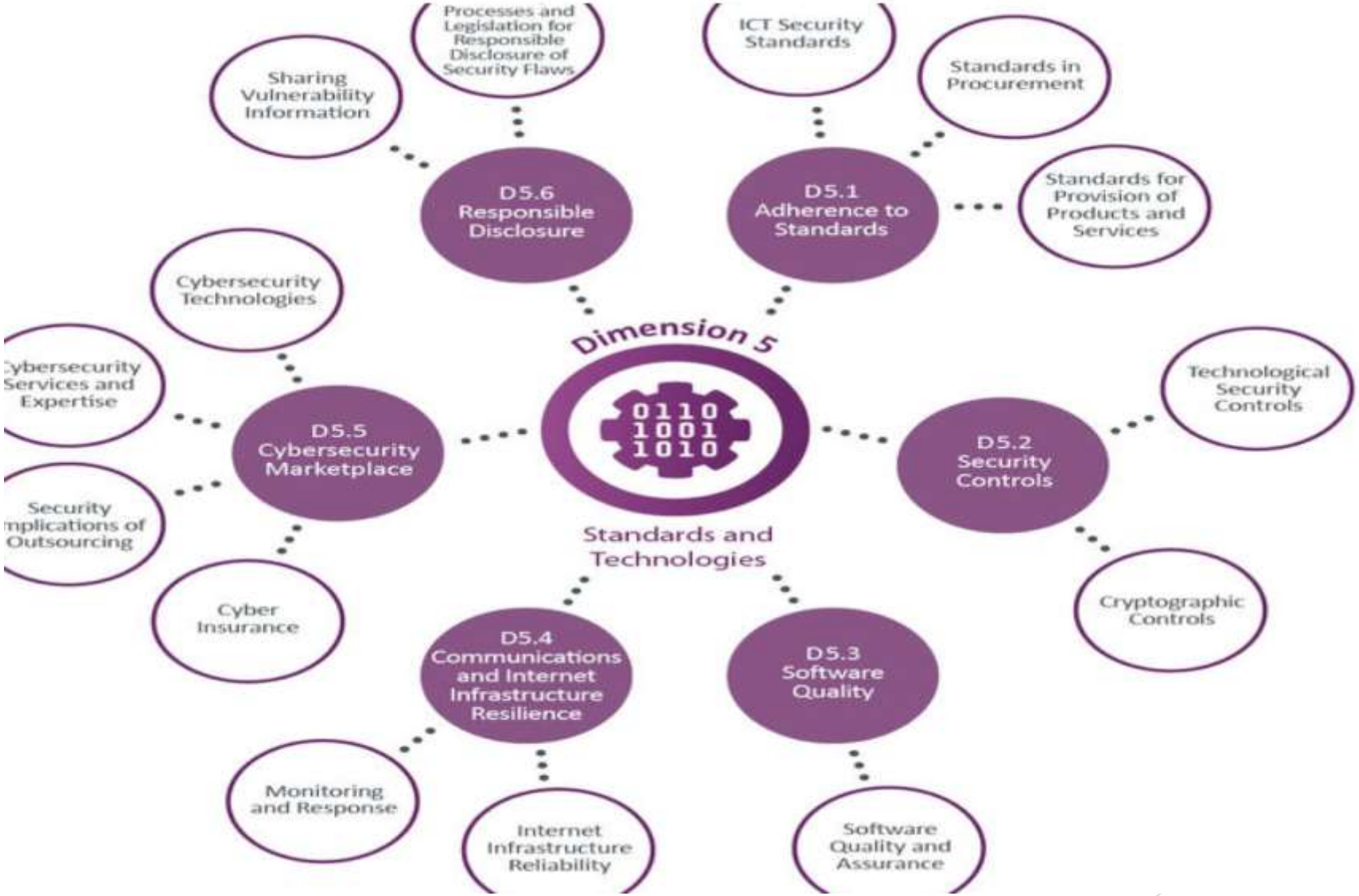
Cybersecurity: Dimension 3



Cybersecurity: Dimension 4



Cybersecurity: Dimension 5



ICT, it’s Indices, hardware and software

- What are ICT indices?
- Importance of ICT indices
- Various ICT indices: IDI, NRI, EGDI,GCI, NCSI

What are ICT Indices?

- To measure the strength of ICT development, deployment, usages - there are various standard indexes are used using various relevant parameters.

- Important ICT indices are composite measures developed by various organizations and compare a country's ICT development over time.

- These indices provide a standardized framework for assessing global digital divides by combining quantitative data on **ICT access, use, and skills, enabling governments and organizations to develop targeted policies for digital inclusion and economic growth.**

- These indices will help us to understand the current level of ICT development and deployment and finally, you may infer many points.

Purpose/Importance of ICT indices

1. **Monitoring Progress:**
   - Tracking changes in ICT development within and between countries.

2. **Identifying Gaps:**
   - Highlighting the extent of the digital divide.

3. **Informing Policy:**
   - Guiding the creation of policies and strategies to promote digital inclusion and leverage ICTs for economic and social development.

Various ICT indices

1. Networked Readiness Index (NRI)
2. ICT Development Index (IDI)
3. E-Government Development Index (EGDI)
4. Global Cybersecurity Index (GCI)
5. National Cyber Security Index (NCSI)

Networked Readiness Index (NRI)

- It is introduced by World Economic Forum (WEF). The WEF assesses the impact of ICT on the competitiveness of the nations of the world.
- The 3 components of NRI are:

  i) Environment for ICT (market, political and regulatory, infrastructural environment),
  ii) The Stakeholders (individuals, businesses and government) to use ICT, and
  iii) The usage of ICT.

  - In 2024, Bangladesh score is 43,56 (89th position out of 133 countries).

ICT Development Index (IDI)

- It is introduced by International Telecommunication Union (ITU). The IDI is a valuable tool for benchmarking the most important indicators for measuring information society or impact of ICT in the society.
- This index is dependent on eleven indicators, is grouped into 3-major categories:
  i) ICT readiness (Infrastructure, access) - reflecting the level of networked infrastructure and access to ICTs,
  ii) ICT Use (Intensity) - reflecting the level of use of ICTs in the society and
  iii) ICT capability (Skills) - reflecting the results/outcomes of more efficient and effective ICT use.
- **2025 IDI Score:** 64.9 (based on 2023 data), **Global Average:** 78, **Lower-Middle-Income Average:** 66

E-Government Development Index (EGDI)

- It is introduced by United Nations. The EGDI evaluates the impact of ICT on the political economy of a country.
- This index focuses on how the governments use ICT to deliver services to the people and opportunities for citizens to participate in decision making process.
- The EGDI consists of 3-components:
  i) Online service,
  ii) Technological infrastructure and
  iii) Human capital.
- In the **United Nations E-Government Development Index (EGDI) 2024**, Bangladesh ranked **100th out of 193 countries** with a score of 0.6570

Global Cybersecurity Index (GCI)

- It is introduced by International Telecommunication Union (ITU).
- The GCI results show overall improvement and strengthening of all 5 pillars of the cybersecurity agenda:

  i) Legal measures,
  ii) Technical measures,
  iii) Organizational measures,
  iv) Capacity development measures, and
  v) Cooperation measures.

- GCI 2024, Bangladesh ranked **53rd** out of 194 countries

National Cyber Security Index (NCSI)

- It is introduced by NCSI Project Team (e-Governance Academy Foundation), Estonia.
- The NCSI measures the preparedness of countries to prevent cyber threats and manage cyber incidents.
- The NCSI is also a database with publicly available evidence materials and a tool for national cyber security capacity building.
- The NCSI focuses on 4-measurable aspects of cyber security :
  - i) Legislation in force – Legal acts, regulations, orders, etc.,
  - ii) Established units – Existing organisations, departments, etc.,
  - iii) Cooperation formats – Committees, working groups, etc. and,
  - iv) Outcomes – Policies, exercises, technologies, websites, programs, etc.
- Bangladesh holds the 48th position in the National Cyber Security Index (NCSI) with a score of 66.67, according to 2021 data.

Secure Software design: Vulnerability, Threat and Risk

- Assets, key characteristics of assets & example of cyber assets
- Vulnerability, examples. types of vulnerability, CVE & CVSS
- Threat, examples, types of threats, common types of cyber threats
- Risk, types of risk, Example of cyber incidents, Risk management.
- Differences between vulnerability, Threat and risk

Assets

Assets

- An asset is a resource owned or controlled by a person or business that is expected to provide a future benefit or generate income.

or

- Assets are defined as anything of value that the business wants to protect. This can include people, information or data, intellectual property, and physical property.

- Protecting assets is crucial for financial security and peace of mind, shielding hard-earned wealth from potential risks like lawsuits, creditors, and unforeseen circumstances.

- Cyber assets encompass all digital and physical resources that an organization uses and that require cybersecurity protection.

Key Characteristics of an Asset

- **Ownership/Control:** An asset is something that a person or business owns or controls.

- **Future Benefit:** It is expected to provide future economic benefits, such as cash flow, reduced expenses, or increased sales.

- **Tangible or Intangible:** Assets can be physical, like buildings or machinery, or non-physical, like patents or trademarks.

Examples of Cyber Assets

- **Hardware:** Servers, computers, network devices, endpoint devices.
- **Software:** Operating systems, applications, software libraries, code repositories.
- **Data:** Databases, documents, user credentials, sensitive information.
- **Network:** Network infrastructure, cloud services, APIs.
- **Other:** Identities (users, accounts), devices, cloud configurations, and more.

Vulnerability, Threat and Risk

Despite having different meanings, the terms threat, vulnerability, and risk are often used together. Threats are possibility of something negative to happen, vulnerabilities are flaws that can be used against you, and risks are the possible outcomes of these exploits.

Vulnerability

- Vulnerability is a weakness or flaw in a system, application, or network that can be exploited by a threat.

or

- A vulnerability is a flaw in a system's design, security procedures, internal controls, etc., that can be exploited by cybercriminals.

or

- A vulnerability is a weakness, flaw, or other shortcoming in a system (infrastructure, database, or software), but it can also exist in a process, a set of controls, or simply just the way that something has been implemented or deployed.

- **Identifying vulnerabilities is similar to answering the question, "How could harm occur?"**

Vulnerability

- A vulnerability is a weakness or defect in design, implementation, integration, operation or utilization of asset.

- CISA (The Cybersecurity and Infrastructure Security Agency) defines a vulnerability -

"***as a set of conditions that may lead to an implicit or explicit failure of the confidentiality, integrity, or availability of an information system***."

Vulnerability: Examples

- **Example 1**

❖ A vulnerability is leaving your car unlocked in a public parking lot. Leaving the doors unlocked does not necessarily mean harm will occur, but it is an opening for someone to go through your car.

- **Example 2**

❖ include outdated software, unpatched software, weak passwords, misconfigured network settings, misconfigured firewalls and human errors like phishing attacks.

Types of Vulnerability

Vulnerabilities could be of many types, based on different criteria, some of them are:

- **Network -** Network vulnerability is caused when there are some flaws in the network's hardware or software.
- **Operating system -** When an operating system designer designs an operating system with a policy that grants every program/user to have full access to the computer, it allows viruses and malware to make changes on behalf of the administrator.
- **Process -** Specific process control can also cause vulnerabilities in the system.
- **Physical Vulnerabilities:** Unprotected hardware, stolen devices, or unauthorized access to servers.

Types of Vulnerability

- **Software failures:** During the development process, bugs may arise that are not identified and corrected, leading to security gaps. Inadequate designs and implementations can introduce flaws that adversaries exploit in attacks such as unauthorized access, privilege escalation, and lateral movement.
- **Hardware failures:** Vulnerabilities in physical components are usually difficult to remediate, requiring physical replacement. Design flaws in processors, firmware bugs, and insecure hardware configurations can create long-term security risks.
- **Human factors:** These can originate from insufficient training, unmapped faulty processes, and a lack of security awareness. Misconfigurations, excessive permissions, or unnecessary services provide entry points for attackers, increasing the risk of data breaches and system compromises.

Types of Vulnerability

- **Technical vulnerabilities** - like bugs in code or an error in some hardware or software. in 2022, according to Positive Technologies, 72% of vulnerabilities were related to flaws in web application code.

- **Human vulnerabilities** - such as employees falling for phishing, smishing (Smishing is a type of phishing attack conducted via text messages), Quishing or other common attacks. The goal of 85% of these attacks is data theft.

Why Software Vulnerabilities Matter?

- When a process reads input from attacker, the process may be exploited if it contains vulnerabilities.
- When an attacker successfully exploits a vulnerability, he can
  - **Crash programs: Compromises availability**
  - **Execute arbitrary code: Compromises integrity**
  - **Obtain sensitive information: Compromises confidentiality**

- Software vulnerability enables the attacker to run with privileges of other users, violating desired access control policy

Common vulnerability and exposure (CVE)

- Common Vulnerabilities and Exposures (CVE) are a set of security threats that are included in a reference system that outlines publicly known risks.
- The CVE threat list is maintained by the MITRE Corporation, a nonprofit organization that runs federal government-sponsored research and development centers.
- CVE is sponsored by the U.S. Department of Homeland Security's National Cyber Security Division (NCSD).
- CVE's main goal is to help organizations improve their security defenses. It does this by identifying and providing a catalog of software or **firmware** vulnerabilities and making it available as a free dictionary.

Vulnerabilities vs Exposures

- A vulnerability is a **flaw** in software code that cyber attackers can use to access a computer system and carry out unauthorized actions while posing as a legitimate user.

- Attackers may use vulnerabilities to execute code, gain access to system memory, install various forms of malware, and steal, delete, or alter sensitive data.

- **An exposure is different. It is a mistake in software code or configuration that gives an attacker access to a system or network. Data breaches, data leaks, and the sale of personally identifiable information (PII) on the dark web can all result from exposures.**

How to calculate vulnerability?

- Evaluate the effectiveness of security measures and controls in place.
- Then, assess the strength of the security systems, access controls, and training programs.
- Identify any vulnerabilities discovered through assessments or audits.
- **The CVSS (Common Vulnerability Scoring System) calculator assesses the severity of vulnerabilities by providing a numerical score based on various metrics. This score helps organizations prioritize vulnerabilities based on their potential impact and exploitability.**

Common Vulnerability Scoring System (CVSS)

- The Common Vulnerability Scoring System (CVSS) is a widely used framework for assessing the severity of software vulnerabilities.
- It provides a numerical score, ranging from 0 to 10, representing the potential impact of a vulnerability, helping organizations prioritize remediation efforts.
- Purpose:
  - **Severity Assessment:** CVSS helps determine how dangerous a vulnerability is.
  - **Prioritization:** It allows organizations to prioritize which vulnerabilities to address first, based on their severity.
  - **Communication:** CVSS provides a standardized way to communicate the severity of vulnerabilities, making it easier for different teams and organizations to understand and address them.

CVSS Relationship to CVE

- CVSS is used in conjunction with the Common Vulnerabilities and Exposures (CVE) glossary, which is a list of publicly known security vulnerabilities.

- CVE identifies and catalogs vulnerabilities, while CVSS provides a numerical score to indicate their severity.

- The National Vulnerability Database (NVD) provides CVSS scores for CVE records.

Qualitative Severity Ratings

CVSS v2.0 Ratings		CVSS v3.x Ratings		CVSS v4.0 Ratings	
Severity	**Severity Score Range**	**Severity**	**Severity Score Range**	**Severity**	**Severity Score Range**
		None*	0.0	None*	0.0
Low	0.0-3.9	Low	0.1-3.9	Low	0.1-3.9
Medium	4.0-6.9	Medium	4.0-6.9	Medium	4.0-6.9
High	7.0-10.0	High	7.0-8.9	High	7.0-8.9
		Critical	9.0-10.0	Critical	9.0-10.0

CVSS vs. CVE

- The main difference between CVSS and CVE lies in their roles. CVE (Common Vulnerability Enumeration) gives unique identifiers to specific security vulnerabilities, making them easier to track.

- CVSS (Common Vulnerability Scoring System) provides a score that shows how severe each CVE is. For example, the Heartbleed vulnerability (CVE-2014-0160) has a CVSS score 7.5, indicating high severity.

Threat, cyber Threat, Attack vector and attack surface

Threat

- A potential danger or adverse event that can exploit a vulnerability to cause harm like data loss or system failure.

or

- A cyber threat is a malicious act that seeks to steal or damage data or discompose the digital network or system.

or

- Anything that could exploit a vulnerability, which could affect the confidentiality, integrity or availability of your systems, data, people, and more.

or

- A threat is any potential danger or harmful event that can exploit a vulnerability and cause harm to a system, organization, or individual.

- **Identifying threats is akin to answering the question, “Who or what could cause harm?”**

Examples

- **House:**
  - ❖A house and its contents would correctly be characterized as assets. If the front door is left unlocked/broken locks, this would be characterized as vulnerabilities.
  - ❖ If a burglar was aware of the broken locks and intended to exploit them, then he or she would be a threat.

- **Car:**
  - ❖**A car, the owner of the car did not lock their door, so a carjacker could exploit the opportunity. This means the threat is human-made and deliberate.**

Types of Threat

Threats could be of 3-types, which are as follows:

- **Intentional -** Malware, phishing, and accessing someone's account illegally, etc. are examples of intentional threats.
- **Unintentional -** Unintentional threats are considered human errors, for example, forgetting to update the firewall or the anti-virus could make the system more vulnerable.
- **Natural -** Natural disasters can also damage the data, they are known as natural threats.
- Thus, threats can either be natural or human-made and accidental or deliberate.

Common Sources of Cyber Threats

Here are several common sources of cyber threats against organizations:

1. **Nation states**—hostile countries can launch cyber attacks against local companies and institutions, aiming to interfere with communications, cause disorder, and inflict damage.
2. **Terrorist organizations**—terrorists conduct cyber attacks aimed at destroying or abusing critical infrastructure, threaten national security, disrupt economies, and cause bodily harm to citizens.
3. **Criminal groups**—organized groups of hackers aim to break into computing systems for economic benefit. These groups use phishing, spam, spyware and malware for extortion, theft of private information, and online scams.
4. **Hackers**—individual hackers target organizations using a variety of attack techniques. They are usually motivated by personal gain, revenge, financial gain, or political activity.
5. **Malicious insiders**—an employee who has legitimate access to company assets, and abuses their privileges to steal information or damage computing systems for economic or personal gain. Insiders may be employees, contractors, suppliers, or partners of the target organization.

Common threat categories facing modern organizations

- **Adversarial threats**—including third-party vendors, insider threats, trusted insiders, established hacker collectives, privileged insiders, ad hoc groups, suppliers, corporate espionage, and nation-states. This category also includes malicious software (malware) created by any of these entities. Large organizations mitigate these threats by establishing a security operations center (SOC) with trained security staff and specialized tooling.
- **Natural disasters**—hurricanes, floods, earthquakes, fire, and lightning can cause as much damage as a malicious cyber attacker. A natural disaster can result in loss of data, disruption of services, and the destruction of an organization's physical or digital resources. The threat of natural disaster can be minimized by distributing an organization's operations over multiple physical sites or using distributed cloud resources.
- **System failure**—when a system fails, it may cause data loss and also lead to a disruption in business continuity. Make sure that your most critical systems are running on high-quality equipment, have redundancy in place to ensure high availability, are backed up, and your providers offer timely support.
- **Human error**—any user may accidentally download malware or get tricked by social engineering schemes like phishing campaigns. A storage misconfiguration may expose sensitive data. To prevent and mitigate these threats, you should establish an employee training program and enforce strong security controls. For example, use password managers and monitor critical systems for misconfigurations.

Some common cyber threats

- **Malware**
- **Phishing**
- **Denial-of-Service (DoS)/DDoS Attacks**
- **Ransomware**
- **Man-in-the-Middle (MitM) Attacks**
- **SQL Injection**
- **Insider Threats**
- **Zero-Day Exploits**
- **Data Breaches**
- **DNS spoofing**
- **Brute force attacks**
- **Trojan horses**

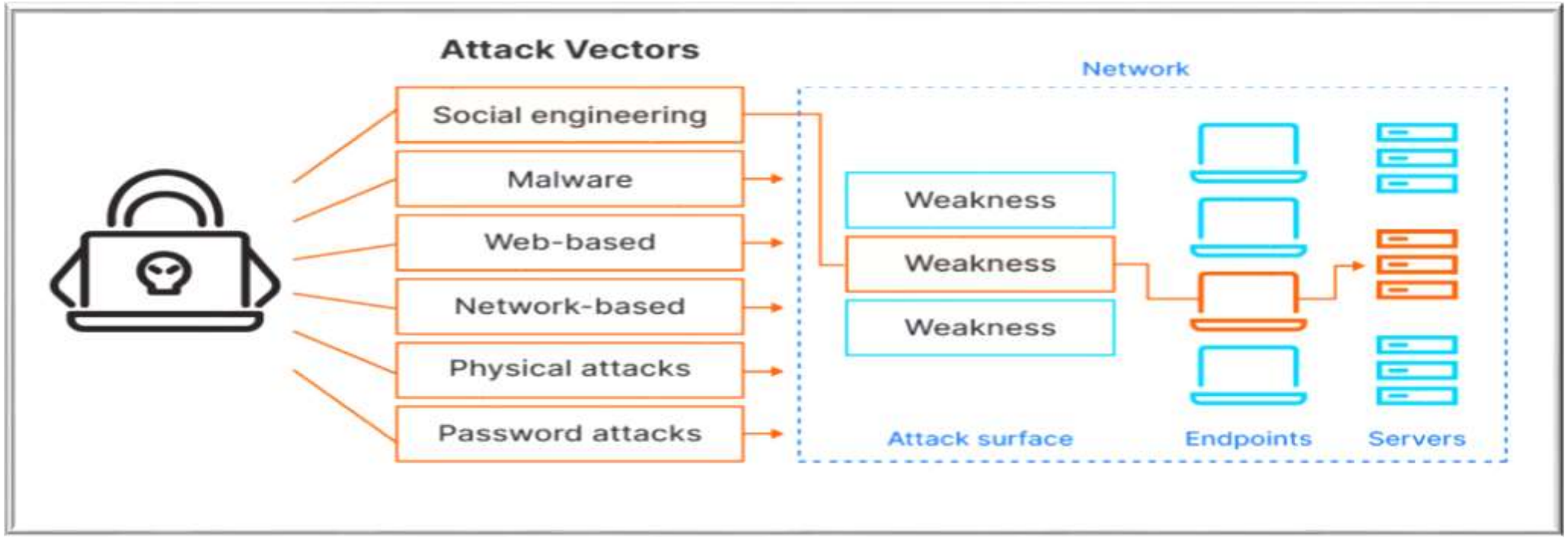
Attack vectors and attack surface

Attack Vectors are potential pathways into sensitive resources.

An Attack Surface is the sum of all attack vectors on a digital surface.

Attack vectors

- Attack vectors are the paths or methods that cybercriminals use to gain unauthorized access to a system, network, or application.
- Attack vectors allow hackers to gain unauthorized access to operating systems or application. For example, an attacker may exploit unpatched software to compromise a system or deploy malware to infect it.



Different types of attack vectors



Malware Attacks

Viruses
Worms
Trojans
Ransomware
Cryptojacking

Spyware
Adware
Fileless malware
Rootkits



Social Engineering

Baiting
Pretexting
Phishing
Vishing (voice phishing)

Smishing
Piggybacking
Tailgating



Man-in-the-Middle

Wi-Fi eavesdropping
Email hijacking

DNS spoofing
IP spoofing
HTTPS spoofing



Denial-of-Service

HTTP flood DDoS
SYN flood DDoS
UDP flood DDoS
ICMP flood
NTP amplification



Injection

SQL injection
Code injection
OS command injection
LDAP injection

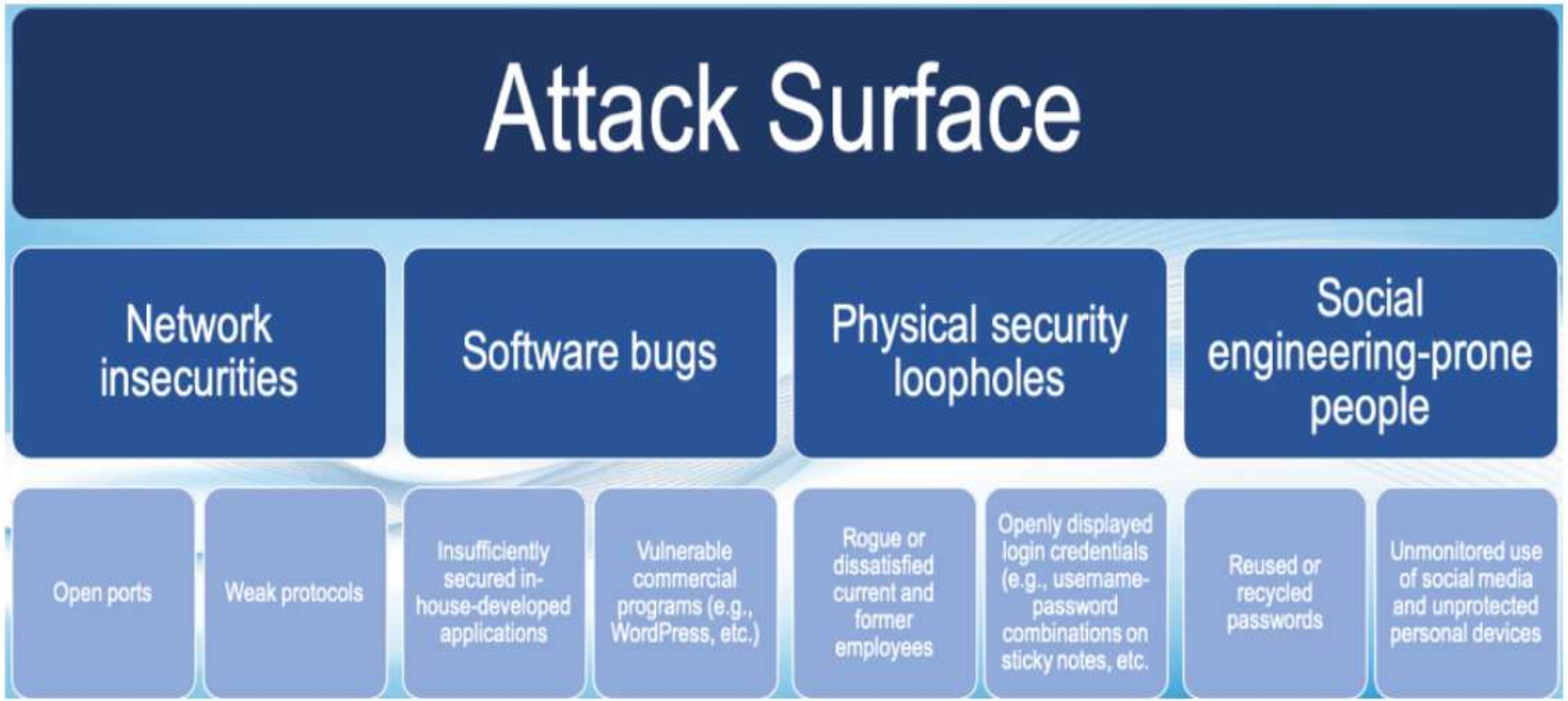
XML eXternal Entities (XXE)
Injection Cross-Site Scripting (XSS)

What is an Attack Surface?

- **Attack vectors:**
  - ✓These are the specific tools and methods attackers use to exploit vulnerabilities in a system.

- **Attack surface:**
  - ✓The attack surface is the aggregate of exploitable points in the network that could be attacked—that overall picture of **multiple cyber security attack vectors** that could be used to exploit a single system or network.
  - ✓ It includes any **hardware, software, interfaces, and human factors** that could be targeted.
  - ✓Examples include **open ports, web applications, network devices, user accounts, and even physical access points**.

Attack surface



Social engineering attack vectors

Cyber attack vectors can be classified based on attacker methodology and tools. Here are some Social engineering attack vectors exploit human behaviour.

- **Phishing**: These deceptive emails or messages steal information or gain access.
- **Pretexting:** Fabricated scenarios to steal information.
- **Baiting:** Enticing victims to click links to take other unsecured actions with offers or rewards.
- **Tailgating:** Following someone into a restricted area.

Risk and cyber security risk

Example of Risk: House

- A house and its contents would correctly be characterized as assets. If the front door is **left unlocked/broken locks**, this would be characterized as vulnerabilities.
- If a burglar was aware of the broken locks/ unlocks and intended to exploit them, then **he or she** would be a **threat**.

- **And the chance or likelihood of the burglar (he/she) entering in and stealing jewelry, electronics, or other possessions would be the risk. In this case, the difference between vulnerability and risk should be clear.**

Example of Risk: House

- Similarly, a car or truck would be an asset. If the window is left **rolled down** while the owner goes into the grocery store, that would be a vulnerability.

- A **passerby** in the parking lot that sees the **downed-window** and notices some coins/dollars in a cupholder would be a **threat**.

- **And the value of those coins/dollars would be the risk involved to the owner of the car if they were to be stolen.**

Asset, vulnerability, Threat and risk



Risk comes with this universal truth: you cannot eliminate or entirely protect against all threats, no matter how advanced your systems are.

Example of cyber incidents

Here are five notable incidents:

1. Data breaches due to insider threats

- Two former Tesla employees leaked sensitive data, including Social Security numbers and contact details, of more than 75,000 individuals to a foreign outlet. The breach was an inside job—no fancy hacks; just people with access.

2. Ransomware attacks exploiting software vulnerabilities

- In mid-2023, the Clop ransomware gang exploited a known vulnerability in Progress Software's MOVEit Transfer product. The fallout was massive: 2,700+ organizations affected and nearly 100 million individuals impacted.

Example of cyber incidents

3. Network misconfigurations exposing sensitive data

- Separate from the exploit above, a misconfiguration in MOVEit Transfer left doors wide open to unauthorized access. The breach wasn't a result of malware or credential theft—it was preventable mismanagement.

4. Supply chain attacks compromising third-party vendors

- A zero-day in Fortra's ***GoAnywhere*** software was exploited by the same ransomware group and exposed 130+ organizations. The issue? A weak link in the supply chain became everyone's problem.

5. Denial of Service (DoS) attacks disrupting operations

- A bad update from CrowdStrike disrupted Microsoft systems worldwide. It wasn't a deliberate attack, but the result was just as damaging—critical outages across industries.

Types of Risks (based on attackers position)

There are two types of cyber risks, which are as follows:

1. **External -** External cyber risks are those which come from outside an organization, such as cyberattacks, phishing, ransomware, DDoS attacks, etc.

2. **Internal -** Internal cyber risks come from insiders. These insiders could have malicious intent or are just not be properly trained.

Types of Cyber Security Risks

There are several types of cyber security risks that businesses and individuals should be aware of:

- **Data breach risk:** When sensitive data (like customer info or financial records) is exposed or stolen.
- **Operational risk:** When an attack disrupts business operations, such as shutting down systems or halting services.
- **Financial risk:** Losses due to fraud, ransom payments, or penalties from non-compliance.
- **Reputational risk:** Damage to your brand image or customer trust after a cyber incident.
- **Compliance risk:** Failing to meet industry standards or legal regulations related to data protection.
- **Insider risk:** Risks coming from within the organization, like employee misuse or accidental data leaks

Risks vary depending on various factors

Risks vary depending on various factors

Cyber security risks vary depending on:

- **How exposed your systems are?,**
- **How valuable your data is?,**
- **How strong your defences are?,**

- For example, if you store customer data on an **outdated system** without regular updates, and **hackers** are actively exploiting such weaknesses, your cyber **security risk** becomes significantly high.

Risk calculation

- Once we know an asset's vulnerabilities and threats, we can determine how much risk is posed to the asset owner. This measure is the combination of the **likelihood that a threat exploits a vulnerability** and the scale of harmful consequences.

Risk = (Probability that a threat occurs) * (Cost to the asset owner)

- Despite the quantitative-looking nature of risk calculation, many risk analyses use qualitative ratings.

- This is because it can be extremely difficult to determine accurate probabilities and realistic costs, especially for intangible assets like trade secrets.

Another way of describing risk

- **Risk = (Threat x Vulnerability)**
- **Risk = Likelihood x Consequence**
- **Risk = Likelihood of Occurrence x Potential Impact to Asset Owner**
- Risk can be quantified as the probability of a threat succeeding multiplied by the value of a potential loss. An unpatched software system that could lead to a complete loss of an entire corporate data set is a massive risk. **Conversely, a photocopier that still has the default password in place poses a small risk.**
- Risk fluctuates based on a wide range of factors. Sometimes, something in the business, like a specific investment or strategic initiative changes the company's risk profile. Sometimes external factors, like a new interest in an industry or sector brings greater risk to a business.

Another way of describing risk

- Risk is commonly quantified using the formula -

  Risk = Threat x Vulnerability x Impact

- This formula quantifies risk by combining the probability of a threat event, a vulnerability that can be exploited, and the potential impact of that exploitation.

  - **Probability** refers to the chance that an event will occur
  - **Impact** measures the severity of its consequences

- **Risk, therefore, represents the likelihood that a threat will exploit a vulnerability in an asset, resulting in a specific impact.**

Factors Contributing to Cybersecurity Risks

1. **Increasing Sophistication of Cyberattacks:**
   - Attackers are continuously developing new techniques and tools, making it more challenging to defend against cyber threats.
2. **Evolving Threat Landscape:**
   - New cyber threats emerge regularly, requiring organizations to stay vigilant and adapt their security measures.
3. **Lack of Cybersecurity Awareness:**
   - Insufficient training and education among employees can lead to human errors that compromise security.
4. **Complexity of IT Infrastructure:**
   - Modern IT systems are increasingly complex, with numerous devices, applications, and networks, making it difficult to manage security.

Threats with associated risks

Threat Type	Threat	Exploit/Vulnerability	Exposed Risk
Human factor internal threat	Intruder	No security guard or controlled entrance	Theft
Human factor external threat	Hacker	Misconfigured firewall	Stolen credit card information
Human factor internal threat	Current employee	Poor accountability; no audit policy	Loss of integrity; altered data
Natural	Fire	Insufficient fire control	Damage or loss of life
Natural	Hurricane	Insufficient preparation	Damage or loss of life
Malicious external threat	Virus	Out-of-date antivirus software	Virus infection and loss of productivity
Technical internal threat	Hard drive failure	No data backup	Data loss and unrecoverable downtime

Vulnerability vs threat vs risk

Vulnerability vs threat vs risk

- These 3 fundamental cybersecurity concepts are related but have distinct meanings.
- Security experts define these 3 concepts in a variety of ways, and the terms threat and risk are sometimes used interchangeably.
- Each term can be thought of in reference to an asset or "something that needs to be protected."
  - A vulnerability is **a flaw or weakness** in an asset's design, implementation, or operation and management that could be exploited by a threat.
  - A threat is a **potential** for an agent **to exploit a vulnerability**.
  - A risk is the **potential for loss** when the threat happens.

Vulnerability vs threat vs risk

These terms are frequently used together, but they do explain three separate components of cybersecurity.

In short, we can see them as a spectrum:

- First, a **vulnerability** exposes your organization to threats.
- A **threat** is a malicious or negative event that takes advantage of a vulnerability.
- Finally, the **risk** is the potential for loss and damage when the threat does occur.

Differences between vulnerability, threat and risk

Feature	Vulnerability	Threat	Risk
Definition	A weakness in a system, process, or human behavior that can be exploited by a threat	A potential danger that can exploit a vulnerability to breach security and cause harm	The potential for loss or damage that arises from a threat exploiting a vulnerability
Nature	Static (exists whether or not it's exploited)	Dynamic (can change or evolve)	Consequence of a threat exploiting a vulnerability
Examples	Unpatched software, weak passwords, lack of employee training, misconfigured firewall	Malware, phishing attacks, denial-of-service attacks, insider threats, natural disasters	Data breach, financial loss, reputational damage, business disruption, legal liabilities
Management	Patching, hardening systems, implementing controls, etc.	Threat intelligence, security awareness training, incident response planning	Risk assessment, risk mitigation strategies, acceptance, or transfer (e.g., insurance)
Measurability	Can be quantified (e.g., number of open ports)	Can be assessed (e.g., likelihood and impact)	Can be measured in terms of financial loss, downtime, etc.

Outline

- Causes of vulnerabilities
- Cybersecurity vulnerabilities
- Impact of vulnerabilities
- Vulnerability assessment process
- Methods of vulnerability detection
- Top vulnerability scanning tools
- CVE, CVSS, CNA and CVSS
- Vulnerability scanning and penetration testing
- Vulnerability management
- Vulnerability management components
- Software patch and types of software patching
- Why is patch management important?

Causes Vulnerabilities

Causes Vulnerabilities

There are many causes of vulnerabilities, including:

i) Complexity - Complex systems increase the probability of a flaw, misconfiguration, or unintended access.

ii) Familiarity - Common code, software, operating systems, and hardware increase the probability that an attacker can find or has information about known vulnerabilities.

iii) Connectivity - The more connected a device is, the higher the chance of a vulnerability.

iv) Poor Password Management - Weak passwords can be broken with brute force, and reusing passwords can result in one data breach becoming many.

v) Operating System Flaws - Like any software, operating systems can have flaws. Operating systems that are insecure by default allow any user to gain access and potentially inject viruses and malware.

Causes Vulnerabilities……

vi) Internet Usage - The Internet is full of spyware and adware that can be installed automatically on computers.

vii) Software Bugs - Programmers can accidentally or deliberately leave an exploitable bug in software. Sometimes end users fail to update their software, leaving them unpatched and vulnerable to exploitation.

viii) Unchecked User Input - If your website or software assumes all input is safe, it may execute unintended SQL commands.

ix) People - The biggest vulnerability in any organization is the human at the end of the system. Social engineering is the biggest threat to the majority of organizations. This category of cyber threats can be addressed with an in-house cyber threat awareness program.

Cybersecurity Vulnerabilities

Cybersecurity Vulnerabilities

i) Zero Day

Zero days are specific software security vulnerabilities known to the adversary but for which no fix is available, often because the bug has not been reported to the vendor of the vulnerable system.

ii) Remote Code Execution (RCE)

An RCE vulnerability allows an attacker to execute malicious code on the vulnerable system. This code execution can allow the attacker to steal sensitive data, deploy malware, or take other malicious actions on the system.

iii) Poor Data Sanitization

Many attacks — such as SQL injection and buffer overflows — involve an attacker submitting invalid data to an application. A failure to properly validate data before processing leaves these applications vulnerable to attack.

Cybersecurity Vulnerabilities….

iv) Unpatched Software

Software vulnerabilities are common, and they are corrected by applying patches or updates that fix the issue. A failure to properly patch out-of-date software leaves it vulnerable to exploitation.

v) Unauthorized Access

It is common for companies to assign employees and contractors more access and privileges than they need. These additional permissions create security risks if an employee abuses their access or their account is compromised by an attacker.

vi) Misconfiguration

Software commonly has various configuration settings that enable or disable different features, including security functionality. A failure to configure applications securely is a common problem, especially in cloud environments.

Cybersecurity Vulnerabilities….

vii) Credential Theft

Cybercriminals have different means of stealing user credentials, including phishing, malware, and credential stuffing attacks.

viii) Vulnerable APIs

Often, web security strategies focus on web applications, which are the more visible components of a corporate digital attack surface. However, APIs can be even more damaging if not properly secured against unauthorized access or exploitation.

ix) Malicious Insider

An employee or a vendor who might have access to your critical systems can decide to exploit their access to steal or destroy information or impair them. This is particularly important for privileged users and critical systems.

x) Missing/Poor Encryption

With attacks on Missing/Poor Encryption, an attacker can intercept communication between systems in your network and steal information.

Impact of Vulnerabilities

Impact of Vulnerabilities

The exploitation of these vulnerabilities can lead to various security breaches and attacks:

- **Data Breach**: Unauthorized access to confidential data.

- **System Compromise**: Complete takeover of the operating system, leading to loss of control over system functionalities.

- **Malware Spread**: Use of vulnerabilities to spread malware, ransomware, or other malicious software.

Vulnerability assessment process & detection

Vulnerability assessment process

1. Identify Vulnerabilities

Analyzing network scans, pen test results, firewall logs, and vulnerability scan results to find anomalies that suggest a cyber attack could take advantage of a vulnerability.

2. Verify Vulnerabilities

Decide whether the identified vulnerability could be exploited and classify the severity of the exploit to understand the level of risk.

3. Mitigate Vulnerabilities

Decide on countermeasures and how to measure their effectiveness if a patch is unavailable.

4. Remediate Vulnerabilities

Remediating vulnerabilities requires updating affected software or hardware where possible.

Mitigation includes reducing the impact of a threat when it cannot be eliminated. Remediation completely removes the threat when it's possible.

Methods of vulnerability detection

- **Vulnerability scanning**: It is the process of discovering, analyzing, and reporting on security flaws and vulnerabilities.

- **Penetration testing**: Penetration testing (or pen testing or ethical hacking) is a security exercise where a cyber-security expert attempts to find and exploit vulnerabilities in a computer system.

- **Google hacking**: Google hacking, sometimes, referred to as Google *dorking*, is an information gathering technique used by an attacker leveraging advanced Google searching techniques. Google hacking search queries can be used to identify security vulnerabilities in web applications.

Vulnerability Scanning

- **Vulnerability scanning** is the process of discovering, analyzing, and reporting on security flaws and vulnerabilities.

- **Vulnerability scans** are conducted via automated vulnerability scanning tools to identify potential risk exposures and attack vectors across an organization’s networks, hardware, software, and systems.

- **Vulnerability scanning** and assessment is an essential step in the vulnerability management lifecycle.

Credentialed Scans vs. Non-Credentialed Scans

Credentialed (**authenticated**) scans and non-Credentialed (**non-authenticated**) scans are the two main categories of vulnerability scanning.

- **Non-credentialed scans**, do not require credentials and do not get trusted access to the systems they are scanning. While they provide an outsider's eye view of an environment, they tend to miss most vulnerabilities within a target environment.

- **Credentialed scans** require logging in with a given set of credentials. These authenticated scans are conducted with a trusted user's eye view of the environment. Credentialed scans uncover many vulnerabilities that traditional (non-credentialed) scans might overlook.

Top vulnerability scanning tools

- **Tenable:** Best overall vulnerability scanner and enterprise vulscan option
- **Invicti:** Best for comprehensive website and application (webapp) scans
- **StackHawk:** Best entry-level webapp scanner for small DevOps teams
- **Nmap:** Best open-source tool for free IT infrastructure and port scanning
- **ConnectSecure:** Best basic infrastructure scanning for service providers
- **Vulnerability Manager Plus:** Best entry-level endpoint and server scanner
- **Wiz:** Best specialist tool for clouds, containers, and infrastructure as code

Penetration testing/ethical hacking

- Penetration testing, also known as pen testing or ethical hacking, is the practice of testing an information technology asset to find security vulnerabilities an attacker could exploit.
- Penetration testing can be automated with software or performed manually. Either way, the process is to gather information about the target, identify possible vulnerabilities and attempt to exploit them, and report on the findings.
- Penetration testing may also be used to test an **organization's security policy, adherence to compliance requirements, employee security awareness,** and an organization's ability to identify and respond to security incidents.
- VAPT- vulnerability assessment and penetration testing usually carried out regularly in important organization after a fixed interval of time.

Vulnerability Scanning vs Penetration Testing

Vulnerability scanning and penetration testing are both methods by which an organization's security team can find weaknesses in its cybersecurity. However, these two methods are very different.

- A ***vulnerability scan*** is an automated search for known vulnerabilities. A number of different vulnerability scanners exist, and they operate by searching for signatures of known vulnerabilities or common security errors (such as the use of weak passwords). These scans are typically designed to **find high-level weaknesses** within an organization's applications and IT infrastructure.

- A ***penetration test*** is an assessment of an organization's cybersecurity by a human operator or team or automated to some extend. This provides a more in-depth assessment because the penetration testers will actually exploit identified vulnerabilities, enabling them to gain additional access to the **target network and identify internal issues in the network**. Additionally, penetration testers can test potential attack vectors outside the scope of a vulnerability assessment, such as social engineering and phishing attacks.

Vulnerability assessment vs Penetration Testing

Feature	Vulnerability Assessment (VA)	Penetration Testing
Focus	Identifies potential vulnerabilities and prioritizes them based on severity.	Attempts to exploit vulnerabilities to understand their actual impact and potential for compromise.
Usage of Tools	Heavily relies on automated vulnerability scanners	Primarily uses skilled security experts. Tools may be used for initial discovery or specific tasks.
Performed By	Largely automated by vulnerability scanning tools.	Conducted by experts with deep knowledge of hacking techniques and system security.
Depth	Offers a broad overview of potential weaknesses.	Provides a deeper understanding of exploitable vulnerabilities.
Automation	Highly automated, allowing for frequent and quick scans.	Limited automation. Requires manual intervention to analyze results, exploit vulnerabilities, and assess impact.
Frequency	Can be performed very frequently (daily or weekly) depending on risk tolerance.	Typically performed monthly, quarterly, or annually, depending on security needs.
Compliance	Can be used for continuous compliance monitoring	Mandatory for compliance pentests such as GDPR, HIPAA, ISO, CERT-IN, and SOX
Certification	Does not directly lead to a penetration testing certification.	Can be used to prepare for and demonstrate skills required for penetration testing certifications.
Outcome	Provides a report listing vulnerabilities and their severity levels.	Provides a report detailing exploited vulnerabilities, the attacker's path to compromise, and potential remediation strategies.
Cost	Lower cost due to automation.	Higher cost due to skilled personnel required.

Penetration testing tools

- vPenTest
- Metasploit
- BreachLock Penetration Testing as a Service
- Edgescan
- NetSPI Penetration Testing Services
- Astra

CVE, CNA and CVSS

CVE: Common Vulnerabilities and Exposures

- CVE stands for Common Vulnerabilities and Exposures. CVE Program's primary purpose is to uniquely identify vulnerabilities and to associate specific versions of code bases to those vulnerabilities.

- An exposure is a mistake that gives an attacker access to a system or network. Exposures can lead to data breaches, data leaks.

- The goal of CVE is to make it easier to share information about known vulnerabilities so that cybersecurity strategies can be updated with the latest security flaws and security issue.

- A CVE score is often used for prioritizing the security of vulnerabilities.

- Founded in 1999, the CVE program is maintained by the MITRE corporation and sponsored by the U.S. Department of Homeland Security (DHS) and the Cybersecurity and Infrastructure Security Agency (CISA) as well as US-CERT.
- **MITRE** is a not-for-profit **corporation** committed to the public interest, operating federally funded R&D centers on behalf of U.S. government sponsors.

What are CNAs?

- CVE Numbering Authorities (CNAs) are organizations that identify and distribute CVE ID numbers to researchers and vendors for inclusion in public announcements of new vulnerabilities.

- CNAs include software vendors, open source projects, coordination centers, bug bounty service providers and research groups. **Bug bounty** programs offer monetary rewards to ethical hackers for successfully discovering and reporting a vulnerability or bug to the application's developer.

- CNAs are a federated systems that helps identify vulnerabilities and assigns them an ID without directly involving MITRE which is the primary CNA.

- There are currently 104 CNAs in 18 countries including many household names like Microsoft, Adobe, Apple, Cisco, Google, Hewlett Packard Enterprise, Huawei, IBM, Intel, Mozilla, Oracle, Red Hat, Siemens, Symantec, VMWare, Atlassian, Autodesk, Cloudflare, Elastic, GitHub, Kubernetes, Netflix and Salesforce etc.

How is a Vulnerability or Exposure Added to CVE?

- CVEs are added when a researcher finds a flaw or design oversight in software or firmware. The vendor does not have to see it as a vulnerability for it to be listed as a CVE- the researcher require to provide evidence of how it could be used as part of an exploit.

- Potential CVEs reported by established vendors or other trusted parties will generally be added to the CVE list quickly.

- CVE is a list of publicly disclosed vulnerabilities and exposures that is maintained by MITRE. NVD – The National Vulnerability Database (NVD) is a database, maintained by NIST, that is fully synchronized with the MITRE CVE list.
- A CVE entry describes a known vulnerability or exposure. Each CVE entry contains a standard identifier number with status indicator (*i.e.* "CVE-1999-0067", "CVE-2014-12345", "CVE-2016-7654321"), a brief description and references related vulnerability reports and advisories.

Vulnerability metric: Common Vulnerability Scoring System (CVSS)

- The Common Vulnerability Scoring System (CVSS) is a method used to supply a qualitative measure of severity. **CVSS is not a measure of risk.** CVSS v2.0 and CVSS v3.x consist of three metric groups: Base, Temporal, and Environmental.
- The Temporal score considers how those **characteristics may change over time**. The Environmental score evaluates how the **vulnerability could affect a specific environment.**

- CVSS is a set of open standards for assigning a number to a vulnerability to assess its severity. CVSS scores are used by the national vulnerability database (NVD), CERT, UpGuard and others to assess the impact of a vulnerability.

- A CVSS score ranges from 0.0 to 10.0. The higher the number the higher degree of security severity.

Common Vulnerability Scoring System (CVSS)

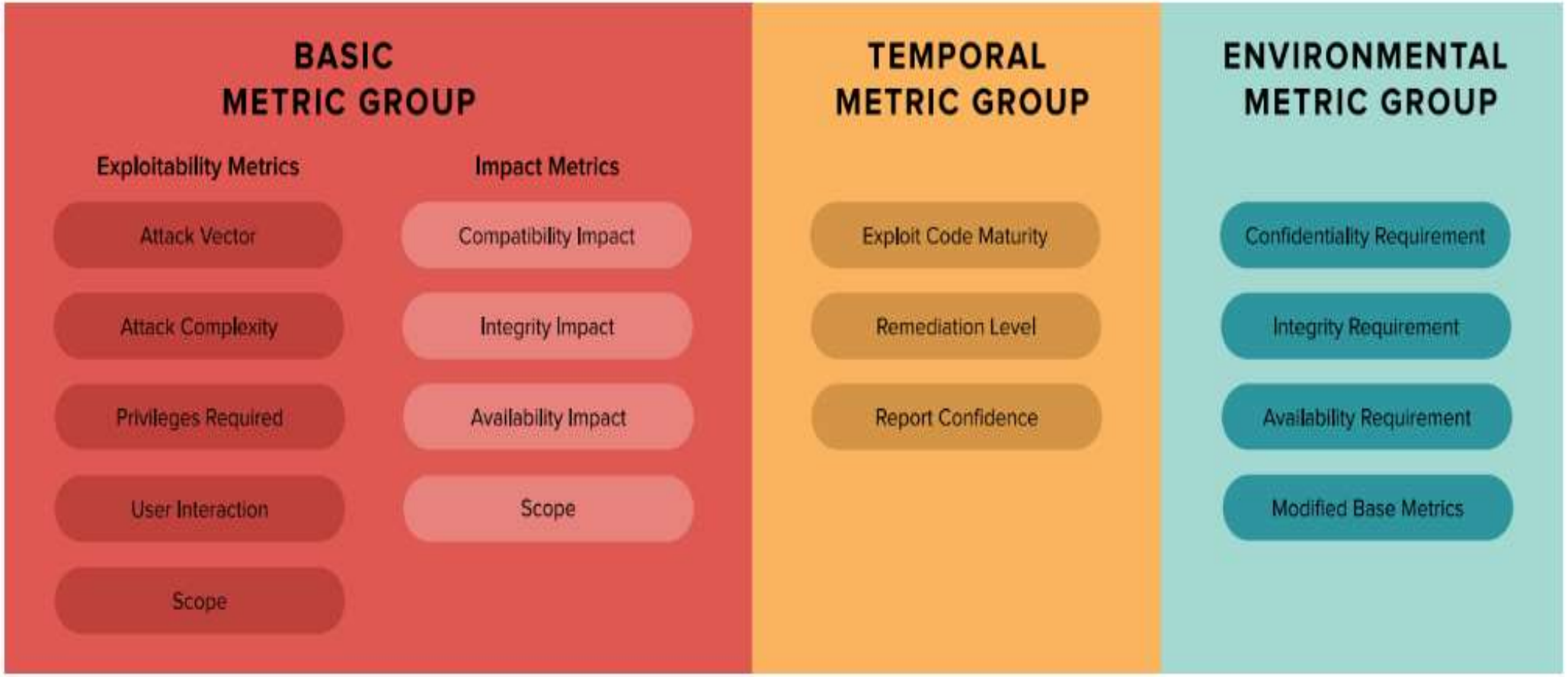
- CVSS is well suited as a standard measurement system for industries, organizations, and governments that need accurate and consistent vulnerability severity scores.

- Two common uses of CVSS are calculating the severity of vulnerabilities discovered on one's systems and as a factor in prioritization of vulnerability remediation activities.

- The National Vulnerability Database (NVD) provides CVSS enrichment for all published CVE records.
- The NVD supports Common Vulnerability Scoring System (CVSS) v2.0, v3.x and v4.0 standards.

CVSS score metric

A CVSS score is composed of three sets of metrics (**Base**, **Temporal**, **Environmental**), each of which have an underlying scoring component.



CVSS Base Metrics

The Base Metrics are the core components used to determine how severe a security vulnerability is.

They focus on the vulnerability's characteristics, regardless of whether it has been exploited or mitigated. These metrics include:

- Exploitability,
- Scope, and
- Impact.

Exploitability:

This metric assesses how easily a vulnerability is exploited. It is broken down into four sub-components:

- **Attack Vector**: Measures how an attack can be executed, with higher scores for remote attacks versus those requiring physical access.
- **Attack Complexity**: Evaluate the difficulty of executing the attack, with lower scores for easier vulnerabilities to exploit.
- **Privileges Required**: This indicator indicates the level of access needed to exploit the vulnerability, with higher scores for attacks requiring fewer privileges.
- **User Interaction**: Considers whether the attacker needs to involve a user in the exploit, with autonomous attacks scoring higher.

Scope

- This metric assesses whether the vulnerability can affect other components beyond the initial target.

- The score will be higher if the vulnerability can propagate, such as compromising an entire system through a single application flaw.

Impact

This metric evaluates the potential consequences of a successful exploit, focusing on three areas:

- **Confidentiality**: Measures the extent of data exposure.

- **Integrity**: Assesses the ability of the attacker to modify data.

- **Availability**: Evaluate the potential disruption to system access and functionality.

Limitations of Base metrics

- While CVSS-based Base Metrics provide a crucial starting point for understanding a vulnerability's severity, they have limitations.
- They do not account for Temporal Metrics, which change over time, or Environmental Metrics, which reflect an organization's specific context, such as existing security controls and asset criticality.
- Organizations must consider these additional factors to fully assess and prioritize vulnerabilities, which can significantly alter the perceived risk and required response.

CVSS Temporal Metrics

CVSS Temporal Metrics evaluate the changing nature of a vulnerability over time. These metrics assess a vulnerability's current exploitability and the availability of remediating controls, such as patches. Key sub=components of Temporal Metrics include:

- **Exploit Code Maturity**: A vulnerability is less threatening until a method to exploit it becomes available. As exploit code matures and becomes more widespread, its associated score increases, reflecting the heightened risk.
- **Remediation Level**: A vulnerability may not initially have a patch or workaround. As temporary fixes or official patches are released, the vulnerability score decreases, indicating reduced risk.
- **Report Confidence**: This measures how well a vulnerability is validated, ensuring it is both real and exploitable—higher confidence results in a higher score.

CVSS Environmental Metrics

CVSS Environmental Metrics allow organizations to adjust the Base CVSS score based on their specific Security Requirements and modifications of Base Metrics.

- **Security Requirements**: These metrics consider the criticality of the affected asset. Mission-critical systems, like a database containing all customer data, receive higher scores than less critical assets, such as a non-privileged user's workstation.
- **Modified Base Metrics**: Organizations can modify Base CVSS Metrics based on existing mitigations. For instance, "air gapping" a server—disconnecting it from external networks—lowers the Attack Vector score since remote exploitation is no longer possible.

By considering both Temporal and Environmental Metrics, organizations can achieve a more tailored and accurate assessment of a vulnerability's actual risk to their specific environment.

Qualitative Severity Ratings

CVSS v2.0 Ratings		CVSS v3.x Ratings		CVSS v4.0 Ratings	
Severity	**Severity Score Range**	**Severity**	**Severity Score Range**	**Severity**	**Severity Score Range**
		None*	0.0	None*	0.0
Low	0.0-3.9	Low	0.1-3.9	Low	0.1-3.9
Medium	4.0-6.9	Medium	4.0-6.9	Medium	4.0-6.9
High	7.0-10.0	High	7.0-8.9	High	7.0-8.9
		Critical	9.0-10.0	Critical	9.0-10.0

CVSS vs. CVE

- The main difference between CVSS and CVE lies in their roles. CVE (Common Vulnerability Enumeration) gives unique identifiers to specific security vulnerabilities, making them easier to track.

- CVSS (Common Vulnerability Scoring System) provides a score that shows how severe each CVE is. For example, the Heartbleed vulnerability (CVE-2014-0160) has a CVSS score 7.5, indicating high severity.

Is CVSS a risk score?

- CVSS is not a risk score; it measures the severity of vulnerabilities. While it provides a numerical score indicating the potential impact, it does not account for an exploit's specific context or likelihood.

- CVSS is not a threat model. It is a scoring system that quantifies the severity of vulnerabilities but does not comprehensively analyze threats or their interactions with vulnerabilities.

Vulnerability management & its components

Vulnerability management

- Vulnerability management is a continuous, proactive, and often automated process that keeps your computer systems, networks, and enterprise applications safe from cyber-attacks and data breaches.

- It requires more than scanning and patching.

- *It also requires a 360-degree view of an organization's* systems, processes, and people in order to make informed decisions about the best course of action for detecting and mitigating vulnerabilities.

Vulnerability management components

i) Asset discovery and inventory
IT is responsible for tracking and maintaining records of all devices, software, servers, and more across the company's digital environment, but this can be extremely complex since many organizations have thousands of assets across multiple locations.

ii) Vulnerability scanners
Vulnerability scanners usually work by conducting a series of tests against systems and networks, looking for common weaknesses or flaws. These tests can include attempting to exploit known vulnerabilities, guessing default passwords or user accounts, or simply trying to gain access to restricted areas.

iii) Patch management
Patch management software is a tool that helps organizations keep their computer systems up to date with the latest security patches

iv) Configuration Management
Security Configuration Management (SCM) software helps to ensure that devices are configured in a secure manner, that changes to device security settings are tracked and approved, and that systems are compliant with security policies.

Vulnerability management components

v) Security incident and event management(SIEM)
SIEM software consolidates an organization's security information and events in real time. SIEM solutions are designed to give organizations visibility into everything that's happening across their entire digital estate, including IT infrastructure.

vi) Penetration testing
Penetration testing software is designed to help IT professionals find and exploit vulnerabilities in computer systems. Typically, penetration testing software provides a graphical user interface (GUI) that makes it easy to launch attacks and see the results.

vii) Threat intelligence
Threat protection software provides organizations with the ability to track, monitor, analyze, and prioritize potential threats to better protect themselves. By collecting data from a variety of sources—such as exploit databases and security advisories—these solutions help companies identify trends and patterns that could indicate a future security breach or attack.

viii) Remediation vulnerabilities
Remediation involves prioritizing vulnerabilities, identifying appropriate next steps, and generating remediation tickets so that IT teams can execute on them. Finally, remediation tracking is an important tool for ensuring that the vulnerability or misconfiguration is properly addressed.

Software Patch, its updates and importance

Software patch

- A patch is a software update for an existing application or operating system to resolve bugs (errors) or vulnerabilities.
- A patch is also called a “fix” or “bugfix.”
- For business software or operating systems such as Windows, a special management program is typically used to install patches. Many applications and operating systems have fixed update and patch cycles.
- For example, **Microsoft usually releases patches for its products on the second Tuesday of each month, known as “Patch Tuesday.”** The reason for this is to make it easier for administrators to plan and install updates.
- However, critical security patches are also made available outside the regular update cycle.

Types of Software Patching

Patches can be broadly classified into the following three categories:

- **Security patches:** Security patch management, *i.e.* the process of deploying security patches to address security vulnerabilities in the software, drivers, and other related components helps secure it from being exploited by vulnerabilities and other threat actors.

- **Bug fix patches:** Bugs in software can range in severity from minor to critical. Bug fix patches ensure that the software is up to date with the latest, bug-free version.

- **Feature update patches:** Feature update patches introduce newer features and functions to software. In addition, they also enhance performance, making software faster and more efficient.

Why is patch management important?

Patch management is the process of identifying, testing, deploying, and installing software patches (or updates) to computers.

- **Preventing security breaches:** Software patch management is one of the most important IT tasks in any organization, as patches fix vulnerabilities in the software and applications, keeping cyber-attacks at bay.
- **Ensuring compliance:** With cyber-attacks on the rise, regulatory agencies have taken drastic measures to keep enterprises in line with compliance mandates.
- **Feature updates:** Besides providing security and bug fixes, patches also introduce new features and functions. This improves usability and enhances the end-user experience.
- **Downtime prevention:** Ransomware attacks and other cyber threats not only result in data breaches but can also cause system downtime, which in turn affects the productivity and revenue of any organization.

Conclusion

- With networks becoming more and more complex, it has become critical to actively manage cyber security vulnerabilities.

- Actively managing cyber security vulnerabilities, it is essential to have visibility of internal and third-party network ecosystems.

- IT personnel should learn cyber security to understand more about such vulnerabilities, their impact, and how to fix them.

Insider threat, backdoor, Logic bombs, Malware and it’s attack

- Insider threat
- Backdoor/trapdoor of a computer system
- Logic bombs
- Computer viruses, its kind and prevention
- Trojan horse & its types
- Computer worm
- Rootkits
- Bot, its types and botnets
- Privacy invasive software
- Bacteria/rabbit
- Countermeasures against the malware
- Economics of malware

Insider threat

What is an insider threat?

- An insider threat is a security risk that occurs when a current or former employee or business associate misuses their access to an organization's network.
- An insider threat can involve leaking data, sabotaging equipment, or stealing company property. Insider threats can be difficult to detect and combat.
- An insider threat is a security risk that comes from within your company. Employees, partners, vendors, interns, suppliers or contractors can potentially become an insider threat. These people can access your organization’s internal network and may accidentally leak or purposely steal sensitive information.

Types of insider threats

Types of insider threats

Here, 6 types of insider threats and the risky data movements are mentioned:

1. **Departing employees:** Employees leaving the company voluntarily or involuntarily are among the most common insider threats. They might take materials they're proud of to help land a new job or, more viciously, steal and expose sensitive data out of revenge.
2. **Malicious insiders:** These individuals are current employees. They might not be your company's biggest fans and usually act on their grievances by altering or deleting crucial data sets, disclosing secret information or engaging in other types of sabotage.
3. **Negligent workers:** Although insider threat management strategies often focus on malicious insiders, careless workers are more dangerous. These employees can unintentionally put organizations at risk by not applying proper security hygiene like strong passwords, multi-factor authentication, or allowing others to use their work device.

Types of insider threats

4. **Security evaders:** Modern companies have security policies for safeguarding their essential data. Some workers can find these protections inconvenient, leading them to create **workarounds** that increase the chances of a data breach.
5. **Inside agents:** These threats work on behalf of an external group, whether knowingly or unknowingly. Outsiders may compel them to give information through blackmail or bribery or deceive them into sharing their login credentials through social engineering.
6. **Third-party partners:** Not all insiders are on the payroll. Suppliers, contractors, vendors and other external parties with some level of inside access can be just as dangerous as employees with the same permissions.

Knowing how insider threats manifest can help you safeguard your company from them, protecting your organization's reputation, future success, customers and employees.

Defences against insider attacks

Defences against insider attacks

1. **Educate employees**

   Provide training and education on data handling policies to help employees understand their role in protecting company resources and the limits of their data access.

2. **Implement access controls**

   Use access controls and policies to limit who can access sensitive data and reduce the risk of unauthorized access.

3. **Apply the principle of least privilege**

   Only give users access to the specific data, resources, and applications they need to perform their job.

4. **Conduct risk assessments**

   Regularly assess your systems to ensure they are secure and up to date with the latest security measures.

Defences against insider attacks

5. Use threat modelling

Use threat modelling to identify and prevent cyber attacks, including those from insiders.

6. Monitor user behaviour

Use tools to monitor user behavior and detect anomalies.

7. Establish incident response procedures

Have procedures in place for responding to and reporting incidents.

8. Identify sensitive assets

Assess how accessible sensitive assets are to different insiders and identify potential threats.

Backdoor /trapdoor of a computer system

Backdoor/trapdoor of a computer system

- A backdoor/trapdoor is a method that allows unauthorized users to bypass security mechanisms and gain access to a system. Backdoors can be created for legitimate purposes, but they can also be used by attackers to gain access to a system.
- A backdoor **threat** is a cyber attack that gives hackers unauthorized access to a system, network, or application. Backdoors can be created by design flaws, coding errors, or malicious code.
- They can remain undetected for weeks, and even when vulnerabilities are identified, it can be difficult to determine where they end.
- Once an attacker has access to a system through a backdoor, they can potentially modify files, steal personal information, install unwanted software, and even take control of the entire computer or computer system.

Dangers of backdoor threats

- Stealing personal information
- Installing unwanted software
- Taking control of the entire computer
- Changing the infrastructure
- Making the system behave as the attacker wants
- Launching distributed denial of service (DDoS) attacks
- Infecting website visitors

Logic bombs

Logic bombs

- A logic bomb is a type of malicious code that is hidden in a computer system or application and executes when certain conditions are met. The code remains dormant until the trigger conditions are satisfied, and then it can cause a range of harmful outcomes.

- Logic bombs can be used for a variety of reasons, including revenge, profiteering, or just to cause havoc. For example, a disgruntled employee or spy might insert a logic bomb into a company system that deletes files when they are terminated.

- Some common triggers for logic bombs include: A specific date or time, Event-based triggers, User actions, and System conditions.

Range of destructive actions of logic bombs

- Deleting files
- Corrupting data
- Crashing systems
- Disrupting critical systems
- Data loss
- Financial losses
- Loss of productivity

Logic bombs are different from computer viruses and worms because they do not self-replicate or spread to other systems.

Malware

- Malware, or malicious software, is a type of software that is designed to disrupt a computer or network, steal data, or damage a computer system.

OR

- Malware refers to any **intrusive** software developed by cybercriminals (often called hackers) to steal data and damage or destroy computers and computer systems.

- The goal of malware is to cause harm, either for financial gain or sabotage.

- Examples of common malware include **viruses, worms, Trojan, rootkit spyware, adware, and ransomware.**

Computer viruses

Computer viruses

- A computer virus is a type of malicious software, or malware, that spreads between computers and causes damage to data and software.

- Computer viruses aim to disrupt systems, cause major operational issues, and result in data loss and leakage. A key thing to know about computer viruses is that they are designed to spread across programs and systems.

- Computer viruses typically **attach to an executable host file**, which results in their viral codes executing when a file is opened. The code then spreads from the document or software it is attached to **via networks, drives, file-sharing programs, or infected email attachments**.

How Do Computer Viruses Attack and Spread?

- In the early days of computers, viruses were spread between devices using floppy disks. Nowadays, viruses can still be spread via hard disks and Universal Serial Bus (USB) devices, but they are more likely to be passed between devices through the internet.

- Computer viruses can be spread via email, with some even capable of hijacking email software to spread themselves

- **A key feature of any computer virus is it requires a victim to execute its code or payload**, which means the host application should be running.

Phases of a computer virus

Phases of a computer virus

1. **Dormant phase**
   - The virus enters the computer or software but doesn't do anything.
2. **Propagation phase**
   - The virus multiplies and inserts copies of itself into other programs or areas on the disk.
3. **Triggering phase**
   - The virus changes from dormant to activated by **a specific user action or predefined date.**
4. **Execution/Action phase**
   - The virus releases its payload, which is the malicious code that harms the device.

Types of Computer Viruses

Types of Computer Viruses

1. Resident virus & non-resident virus

- A resident virus is a type of computer malware that embeds itself in the computer's memory (RAM), allowing it to remain active and infect other files even after the original infected program is closed.
- **A resident virus achieves this by infecting applications as they are opened by a user**. A non-resident virus is capable of infecting executable files when programs are not running.

2. Multipartite virus

- **It will typically remain in the computer's memory to infect the hard disk, then spread through and infect more drives by altering the content of applications.** This results in performance lag and application memory running low.

Types of Computer Viruses

3. Direct action

- **A direct action virus accesses a computer's main memory and infects all programs, files, and folders located in the autoexec.bat path, before deleting itself**. This virus typically alters the performance of a system but is capable of destroying all data on the computer's hard disk and any USB device attached to it.

4. Browser hijacker

- **A browser hijacker changes the settings of web browsers, such as replacing the homepage, editing the new tab page, and changing the default search engine without user permission.** Technically, it is not a virus because it cannot infect files but can be hugely damaging to computer users, who often will not be able to restore their homepage or search engine.

Types of Computer Viruses

5. Overwrite virus

- Overwrite viruses are extremely dangerous. **They can delete data and replace it with their own file content or code.** Once files get infected, they cannot be replaced, and the virus can affect Windows, DOS, Linux, and Apple systems. **The only way this virus can be removed is by deleting all of the files it has infected, which could be devastating.**

6. Web scripting virus

- **A web scripting virus attacks web browser security, enabling a hacker to inject web-pages with malicious code, or client-side scripting.** This allows cyber criminals to attack major websites, such as social networking sites, email providers, and any site that enables user input or reviews. Attackers can use the virus to send spam, commit fraudulent activity, and damage server files.

Types of Computer Viruses

7. File infector

- **It overwrites files when they are opened and can quickly spread across systems and networks. It largely affects files with .exe or .com extensions.** The best way to avoid file infector viruses is to only download official software and deploy an antivirus solution.

8. Network Virus

- Network viruses are extremely dangerous because they can completely cripple entire computer networks. They are often difficult to discover, as **the virus could be hidden within any computer on an infected network**. These viruses can easily replicate and spread by using the internet to transfer to devices connected to the network.

Types of Computer Viruses

9. Boot Sector Virus

- **A boot sector virus targets a computer's master boot record (MBR). The virus injects its code into a hard disk's partition table, then moves into the main memory when a computer restarts.**

- The presence of the virus is signified by boot-up problems, poor system performance, and the hard disk becoming unable to locate. Most modern computers come with boot sector safeguards that restrict the potential of this type of virus.

Encrypted viruses

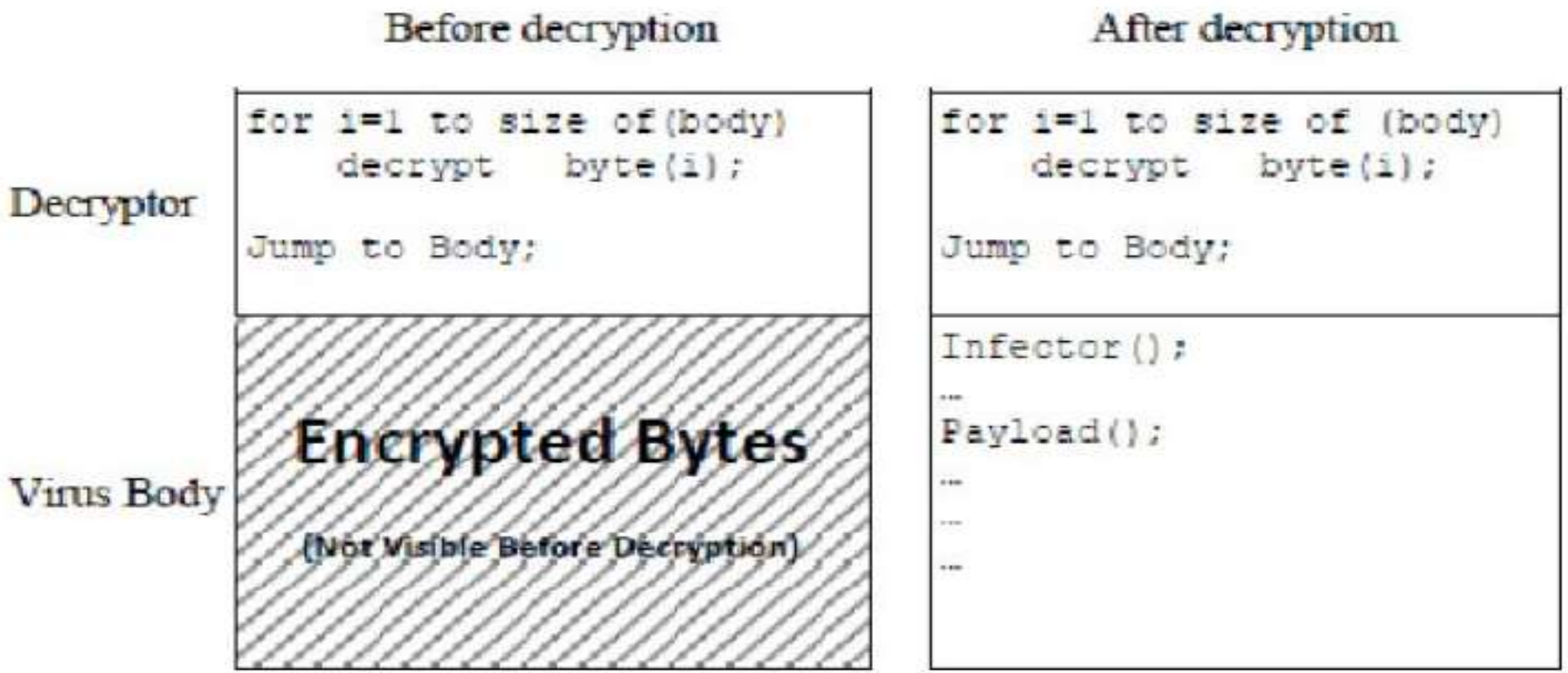
Encrypted viruses

- **An encrypted virus is a type of malware that uses encryption to conceal its code and avoid detection by security software.**

- This technique makes the virus appear as gibberish (*i.e.* unintelligible, meaningless), preventing traditional signature-based antivirus programs from recognizing and stopping it.

- The simplest form, where the malware consists of an encrypted virus body and a small, unencrypted "**decryptor**" program. The decryptor contains the key and routine to unscramble the main virus body

Encrypted viruses



Types of Encrypted viruses

(Polymorphic and metamorphic viruses)

Polymorphic and metamorphic viruses

Polymorphic (genetic variation) and metamorphic (change its code to avoid detection) viruses are both types of malware that can change their code to evade detection and remain on a system.

Polymorphic

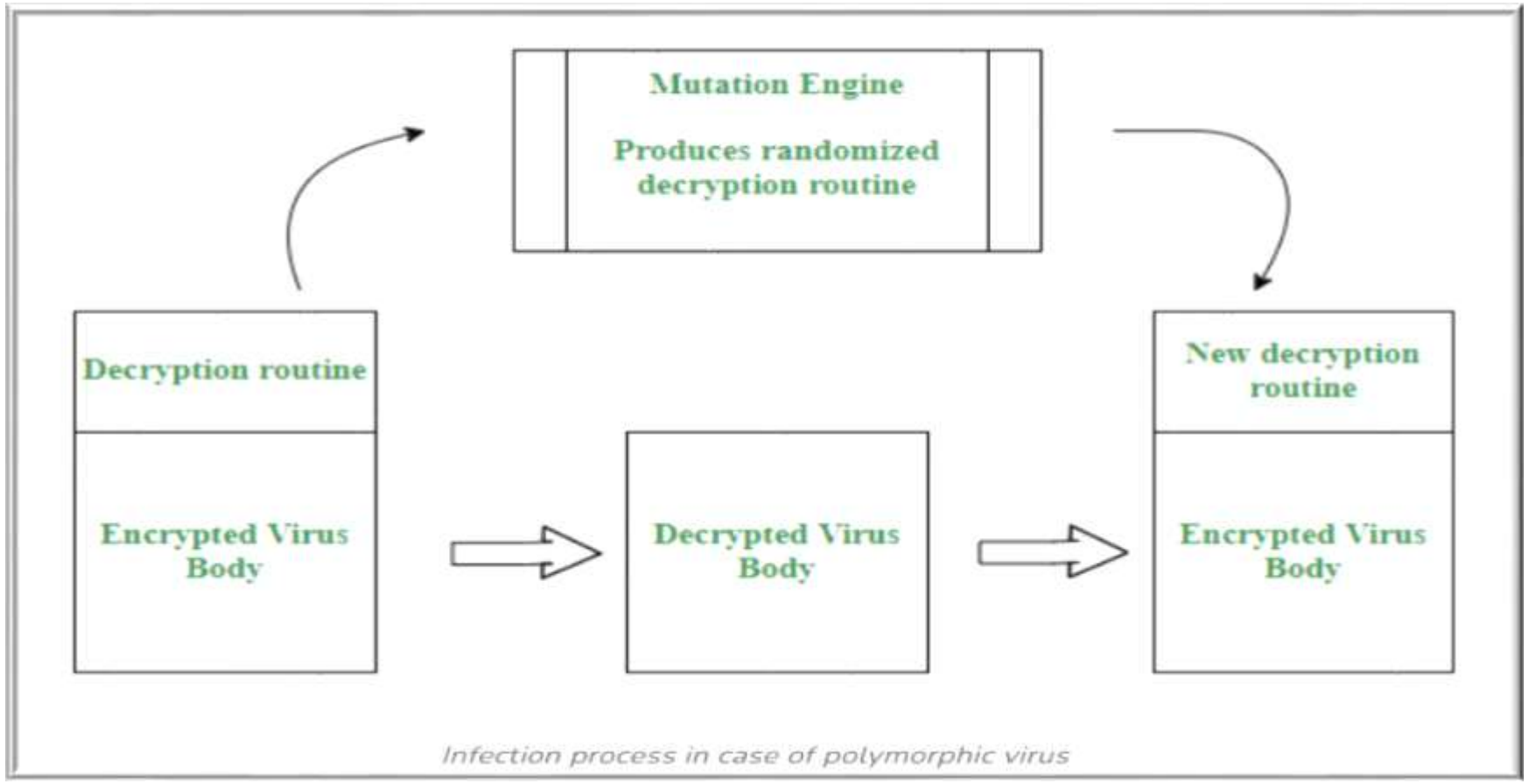
- **Uses a variable encryption key to change its code and make each iteration appear different.** This makes it difficult for traditional antivirus software to recognize and block the threat.

Metamorphic

- **Rewrites its code without an encryption key.** This makes it more complex and transformative than polymorphic malware, and it can be difficult for antivirus scanners to detect.

Polymorphic malware is more common than metamorphic malware. While both types of malware are a threat to systems, polymorphic malware is easier to identify than metamorphic malware because only part of its code is changed.

Working of Polymorphic Virus



In the case of the polymorphic virus, with each mutation, the basic function performed by the virus remains the same even though the signature or decryption routine changes

Detection of Polymorphic Virus

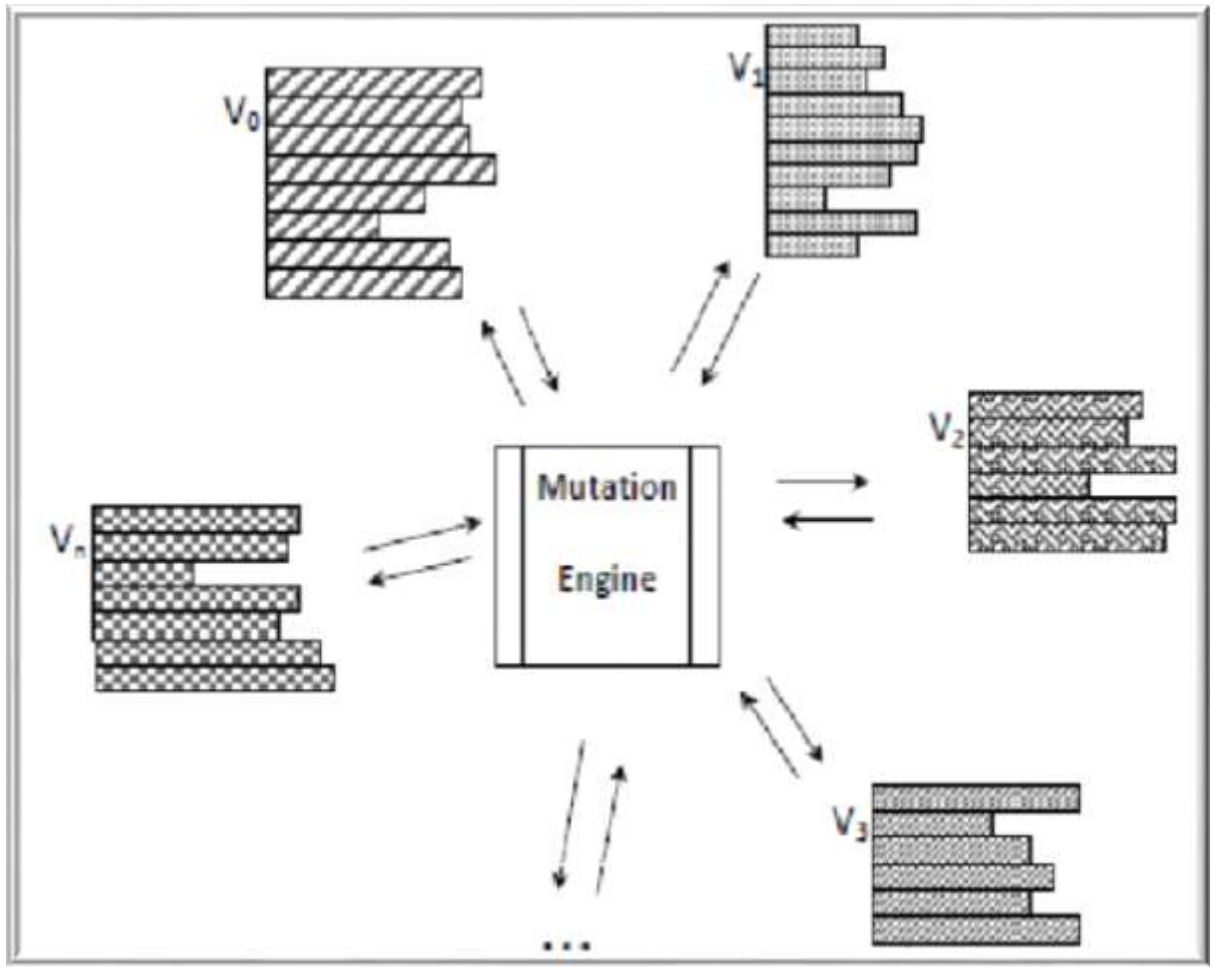
Polymorphic viruses can easily fool the conventional antivirus software using signature-based detection. However, these viruses can be detected by new security technologies which use machine learning and behaviour detection to identify any anomalous behaviour in the system.

- **Behaviour-based detection:** This technique analyses not only the code but also the behaviour of the virus. This helps in detecting viruses with similar behaviour.

- **Heuristic Scanning:** This technique looks for the components that different threats share instead of looking for an exact match to a threat. This helps in detecting new variation viruses.

Preventing/defenses Computer From Viruses

Metamorphic viruses



- Metamorphic malware have similar functionality, different structure and signature.

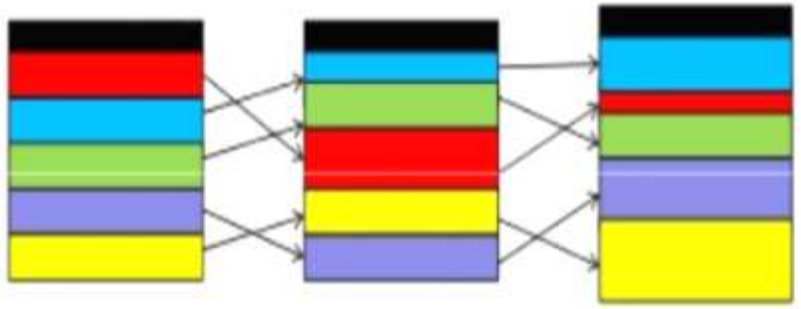


Diagram depicts metamorphic malware variants with reordered code

- Similar to genetic diversity in Biology.

To change code structure at each infection metamorphic malware employee the Mutation Engine (black-part) that use obfuscation techniques like: garbage code insertion, register/variable usage exchange, instruction replacement, instruction permutation, code transposition etc.

Differences between polymorphic and metamorphic viruses

Feature	Polymorphic Virus	Metamorphic Virus
Core Technique	Encrypts its body and uses a variable decryptor.	Rewrites its entire code, including the engine.
Signature	The encrypted body changes, but the decryptor routine often has a detectable signature (though it's hidden with junk code).	No part remains the same. There is no constant decryptor or body.
Analogy	A letter locked in a safe. The safe (encryption) and the lock (decryptor) change, but the letter inside (the malicious code) is the same.	The entire letter is rewritten in a different language and handwriting, but it says the same thing.
Complexity	Less complex.	Extremely complex to create.

Virus signature

Virus signature

- **A virus signature is a unique pattern of code or data that identifies a specific computer virus, similar to a fingerprint.**

- Antivirus software scans files, comparing them against a database of known signatures.

- If a match is found, the software can then take action to remove or isolate the threat.

Limitations of virus signatures

1. **Only detects known threats:**

- A traditional signature-based scanner can only identify malware for which a signature has already been created. This leaves a vulnerability period, known as a "zero-day," between a new malware's release and the antivirus database's update.

2. Vulnerable to polymorphic viruses:

- Sophisticated malware, known as polymorphic or metamorphic viruses, can alter its code with each new infection. This creates a new signature every time, making it difficult for traditional signature-based methods to keep up.

Preventing Computer From Viruses

Preventing Computer From Viruses

1. Use a trusted antivirus product

- Trusted computer antivirus products are crucial to **stop malware attacks** and prevent computers from being infected with viruses. These **antivirus concepts** will protect devices from being infected through regular scans and identifying and blocking malware.

2. Avoid clicking pop-up advertisements

- Unwanted pop-up advertisements are more than likely to be linked to computer viruses and malware. Never click on pop-up advertisements because this can lead to inadvertently downloading viruses onto a computer.

3. Scanning of email attachments

- A popular way to protect your device from computer viruses is to avoid suspicious email attachments, which are commonly used to spread malware. Computer antivirus solutions can be used to scan email attachments for potential viruses.

4. Scan the files that downloads using file-sharing programs

- File-sharing programs, particularly unofficial sites, are also popular resources for attackers to spread computer viruses. Avoid downloading applications, games, or software from unofficial sites, and always scan files that have been downloaded from any file-sharing program.



Trojan horse

Trojan horse

- **A Trojan Horse is a type of malware that downloads onto a computer disguised as a legitimate program.**

OR

- **A Trojan horse is a malicious program that appears to perform a desired function but actually has hidden programs that can steal information, create backdoors, or run scripts.**

- The delivery method typically sees an attacker use social engineering to hide malicious code within legitimate software to try and gain users' system access with their software.

- Trojans can be installed through a backdoor and are often confused with viruses. However, Trojans are usually stand-alone programs and don't inject themselves into other programs.

- Malicious code for a Trojan horse can be injected into benign applications, hidden in JavaScript pages, or masqueraded in email links.

Trojan Horse: malicious actions

Once installed, the Trojan Horse can perform a variety of malicious actions, including:

- Stealing sensitive data, such as passwords and financial information
- Corrupting or deleting files
- Taking control of the device for malicious purposes
- Installing other malware
- Disrupting the device's operation.

Types of Trojan horses

- **Backdoor Trojan**: Includes a backdoor that gives the attacker remote administrative control over the system
- **DDoS Trojan**: Starts Denial of Service (DoS) attacks by sending many requests to the target address
- **Trojan Downloader**: Downloads and installs files, often malicious programs
- **Info-stealer Trojan**: Also known as the information thief, this type of Trojan steals important data from susceptible systems
- **Banker Trojan**: Targets a user's financial account information and attempts to gain access to bank, investment, and credit card accounts
- **Zeus**: Also known as Zbot, this Trojan was designed to steal information such as credit card details and passwords from computers
- **CryptoLocker**: Encrypts files on your device and any connected media

Computer worms

Computer worms

- A computer worm is a type of malware that can replicate itself and spread to other computers without human interaction.
- Worms can exploit security vulnerabilities in a computer to gain access, and then use that computer as a host to infect other computers.
- A computer worm duplicates itself to spread to uninfected computers.
- As it spreads, a worm consumes bandwidth, overloading infected systems and making them unreliable or unavailable.
- Worms can also change and delete files or introduce other malware.

Attack by computer worm

Worms can:

- **Steal information**: Worms can exploit vulnerabilities in security software to steal sensitive information.
- **Install backdoors**: Worms can install backdoors that hackers can use to access a system.
- **Corrupt files**: Worms can corrupt files.
- **Crash systems**: Worms can crash systems through self-replication.
- **Download malicious applications**: Worms can download malicious applications.
- **Overload systems**: Worms can consume large amounts of memory and bandwidth, which can overload and malfunction systems, servers, and networks.

Worms can be difficult to eradicate because they spread quickly and automatically. Even if a worm doesn't have a malicious payload, it can still be a nuisance for IT managers.

Difference between virus and worm

- The main difference between viruses and worms is the method in which they reproduce and spread (how they spread and are activated).

- A virus is dependent upon a host file or boot sector, and the transfer of files between machines to spread, while a worm can run completely independently and spread of its own will through network connections.

- Worms can travel across networks and replicate themselves on a system, potentially consuming a lot of system memory or network bandwidth. Whereas the viruses need to be activated by a user's interaction with an infected file or program.

Computer Rootkits

Computer Rootkits

- A computer rootkit is a type of malware that gives cybercriminals unauthorized access to a computer or network. Rootkits are designed to be difficult to detect and can remain hidden for a long time.

- Rootkit is a type of malware program that enables cyber criminals to gain access to and infiltrate data from machines without being detected.

- It covers software toolboxes designed to infect computers, give the attacker remote control, and remain hidden for a long period of time.

A rootkit is a type of malware that provides a hacker with complete control over a computer, while a Trojan is a type of malware that gives an attacker limited access to a system.

Is A rootkit a Worm? Detection of rootkit!

- Rootkit and worms are two different type of malwares but we might see a blended malware.
- **For example, a worm might spread across network or devices and it contains payload for rootkit or it might contains dropper and it drop a Trojan or Virus which will execute a Rootkit.**
- **A dropper is a type of malicious software that installs other malware onto a device, allowing criminals to bypass security measures and deploy harmful programs. Droppers are typically used during the first stage of a malware attack.**
- A rootkit is a dangerous malware designed to gain **“illegal'' and persistent access to what is otherwise not allowed**. Typically, a rootkit also masks its existence or the existence of other malware.

- **Because the infected programs still run normally, rootkit detection is difficult for users – but antivirus programs can detect them since they both operate on the application layer.**

Features of dropper

1. **Disguising themselves**
   - Droppers can be disguised as harmless files, such as software installers, or as genuine apps with functionalities like calculators or QR code scanners.
2. **Exploiting vulnerabilities**
   - Droppers can exploit vulnerabilities in document formats like PDFs or Microsoft Office files.
3. **Installing payloads**
   - Droppers can install other malicious tools, called payloads, on the target device without the victim noticing.
4. **Neutralizing system defences**
   - Droppers can neutralize system defences before installing their payload.

Feature	Rootkit	Worm
Primary Purpose	To hide itself and other malware; to maintain persistent, undetected access to a system.	To self-replicate and spread to other computers, consuming resources and causing disruption.
Main Behavior	Stealth & Concealment. Modifies the OS core to hide files, processes, and network connections.	Propagation & Spread. Copies itself across networks, email, or vulnerabilities.
Method of Spread	Does not self-replicate. It is typically installed by another threat (e.g., a Trojan, worm, or hacker).	Self-replicating. It spreads automatically without user intervention, often by exploiting vulnerabilities.
User Interaction	Often requires a separate component to be installed. The user may not be directly involved in its installation.	Can spread with no user interaction, or may use social engineering (e.g., enticing email attachments).
Primary Target	The local system's integrity and security. It aims to control that specific machine.	Any and all vulnerable systems it can reach on a network. Its goal is widespread infection.
Key Danger	Stealthy Control. An attacker gains long-term, "root" (administrator) level access to your system.	Network Congestion & Resource Drain. Can overload networks and systems, causing slowdowns or crashes.
Visibility	Designed to be invisible to the user and standard antivirus software.	Its activity (network traffic, slow performance) is often more noticeable, even if the file is hidden.
Analogy	A sleeper agent who lives in your house, hiding in a secret room and monitoring your every move.	A contagious virus that spreads rapidly from person to person, causing a widespread epidemic.
Removal	Very difficult, as it subverts the tools used to detect it. Often requires specialized anti-rootkit software or an OS reinstall.	Can be removed by standard antivirus software, but its rapid spread makes containment a priority.

Bacteria/Rabbit

- Viruses that perform **no explicit malicious behaviour** are often called **bacteria** or **rabbits**. Unlike typical destructive malware (e.g., those that delete files, steal data, or encrypt systems), these viruses simply replicate themselves continuously.
- Even though they don't directly damage data or steal information, they can still cause **serious negative impacts** on a computer system and network.
- **Goal/Effect:** Consume system resources (CPU, memory, disk space) until the system slows down, crashes, or becomes unusable.
- **Spreading Method:** Usually confined to a single system (local replication).
- **Example:**
  - The **Rabbit Virus (1974)**
  - **Fork Bombs** in Unix/Linux.
- **Impact:** Resource exhaustion → Denial of Service (DoS).

Comparison of Rabbit/bacteria & worm

Feature	Bacteria/Rabbits	Traditional Viruses	Worms
Replication	Local, exponential self-replication	Attach to host files, replicate when executed	Network-based, self-propagating
Malicious Payload	None (just replication)	Often destructive (delete/steal data)	May carry destructive payload
Resource Consumption	Very high (crashes system)	Moderate (depends on payload)	High (spreads rapidly over networks)
Spreading Method	Within one machine	Via infected files/media	Across networks automatically
Impact Type	Denial of Service (DoS)	Data loss, corruption, theft	Network slowdown, mass infection, ransomware

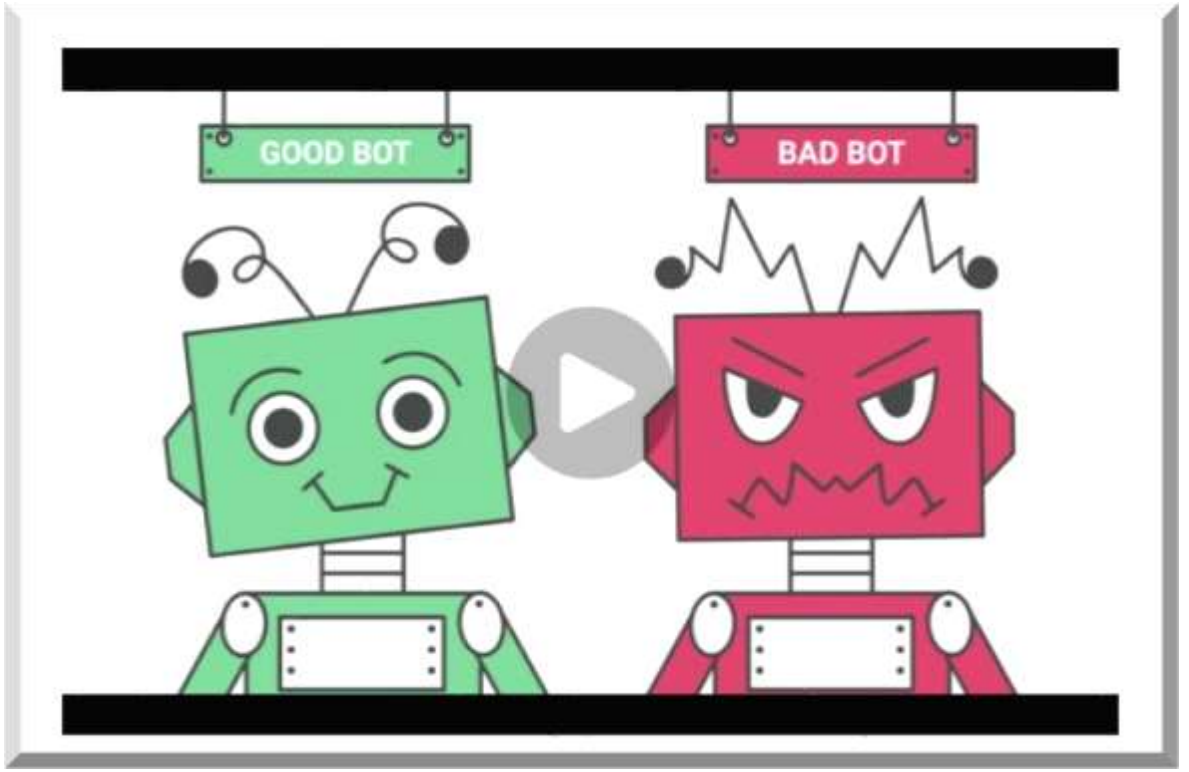
Key historical examples of malware

- **Bacteria/rabbits**: Harmless-looking but harmful due to **resource exhaustion**.
- **Viruses** : Destructive or manipulative, tied to host files.
- **Worms** : Fast-spreading across networks, often with dangerous payloads.
- **1974 – Rabbit Virus** → Endless replication, crashed systems (DoS).
- **1988 – Morris Worm** → First major Internet worm, overloaded thousands of systems.
- **2000 – ILOVEYOU Virus** → Email-based, overwrote files, spread globally.
- **2017 – WannaCry Worm** → Ransomware worm exploiting Windows SMB (server message block), caused worldwide disruption.

Bot and Botnets

Bot

- A bot is a software application that is programmed to do certain tasks.
- A bot is a software program that operates on the Internet and performs repetitive tasks.
- Although some bots are beneficial, malicious ones can severely damage a website or application.



Bot types (Good and bad bots)

1. **Chatbots**: Bots that simulate human conversation by responding to certain phrases with programmed responses. For example, **Apple's *Siri***, the virtual assistant pioneer, transforms the way users interact with their devices; **Alexa** from Amazon, **Google Assistant**.

2. **Web crawlers:** Bots that scan content on webpages all over the Internet. **Googlebots (Google search Engine crawler) - Googlebot Desktop and Googlebot Mobile**; **bingbo**t (Microsoft's search engine crawler for Bing), **Amazonbot** (the Amazon web crawler)

3. **Social bots**: Bots that operate on social media platforms. **Twitterbots** are already well-known examples. **Kismet** - a robot head that understands and exhibits emotion when interacting with humans.

4. **Malicious bots**: Bots that scrape content, spread spam content, or carry out credential stuffing attacks.

Malicious/bad bot activity

Any automated actions by a bot that violate a website owner's intentions, the site's Terms of Service. Malicious bot activity includes:

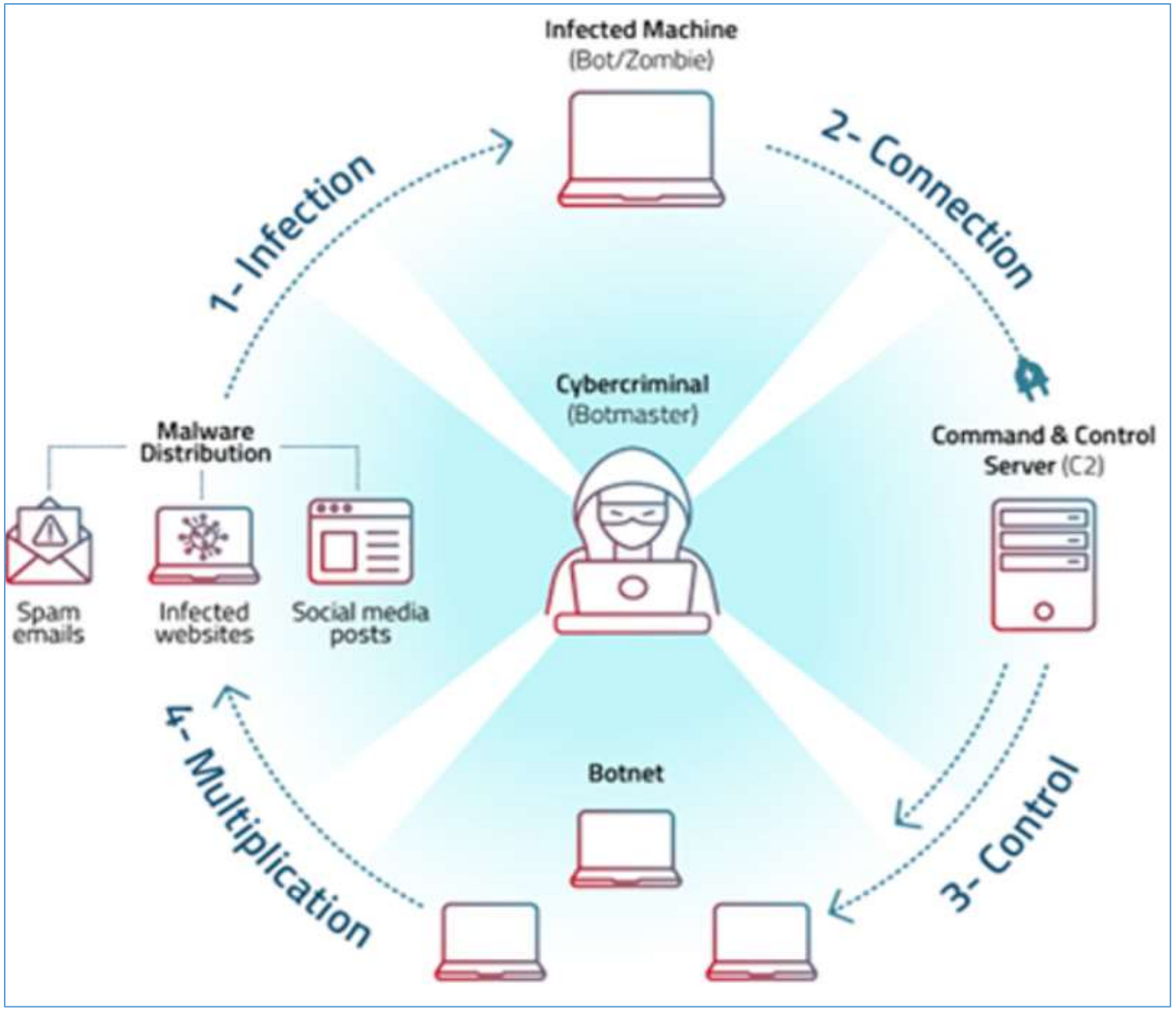
- Credential stuffing
- Web/content scraping
- DoS or DDoS attacks
- Brute force password cracking
- Inventory hoarding
- Spam content
- Email address harvesting
- Click fraud

Botnets

A botnet refers to a group of computers which have been infected by malware and have come under the control of a malicious actor called bot master.

or

A botnet is a network of internet-connected devices, like computers, smartphones, and IoT devices, that have been infected with malware and are controlled remotely by a cybercriminal called a "bot herder".



Privacy-invasive software

Privacy-invasive software: spyware and adware

Privacy-invasive software is a category of software that is built primarily to capture the target's private information. Basically, it ignores the privacy of the user and tracks the user activity. Some popular examples of privacy-invasive software are mentioned below:

1. Spyware

- It is a software that gathers the private information of an individual or an organization without their knowledge and pass this information to a third party. It is often used with a malicious intent. A few examples of **spyware are trojans, system monitors and tracking cookies.** These can collect any type of data from a system such as internet browsing habits of the users, bank account information, etc.

2. Adware

- Also known as advertising-supported software, this category is used for commercial intent**. It automatically displays unwanted** advertisements in order to generate revenue to its developer. The revenue is generated for two type of advertisements- one is for display and other is for pay-per-click.

Methods of Malware Attacks

Methods of Malware Attacks

The ways that malware can infiltrate and spread through networks continues to expand along with the threat vectors in the digital landscape, including the following:

- **Unsecure devices** that access the network such as personal mobile devices, PCs, and IoT devices open an attack vector for malware.
- **Unsecure networks** that are part of a supply chain or unsecure third-party partners' networks, can infect the networks of other suppliers or give malware access to the enterprise network.
- **Older devices** on the network with software that is not routinely updated can become compromised and spread malware.
- **Email attachments** containing malicious code can be opened and forwarded to other users, spreading the malware across the enterprise.

Methods of Malware Attacks

- **Phishing or spear phishing emails** trick the recipient into sharing passwords that give access to the corporate network where malware can spread.
- **Smishing texts**, similar to phishing emails but on mobile phones, trick distracted users into clicking on malware links and entering personal or business credentials that enable malware to spread on the network.
- **File servers**, such as those based on the common internet file system or network file system can spread malware as users download infected files.
- **File-sharing software** can allow malware to replicate itself onto removable media such as thumb drives and then on to computer systems and networks.
- **Peer to peer (P2P)** file sharing can introduce malware by sharing infected files as seemingly harmless as video, music, or images,
- **Remotely exploitable network vulnerabilities** can enable a hacker to access systems regardless of geographic location

Countermeasures against malware

Some countermeasures against malware

1. **Install antivirus software**: Install antivirus software on all devices connected to a network and update it regularly.
2. **Update software**: Keep your computer and software up to date with the latest versions.
3. **Use security tools**: Use a firewall, intrusion prevention system (IPS), and endpoint monitoring tools.
4. **Use email security**: Use email security filters to scan and remove malicious attachments and suspicious hyperlinks.
5. **Use web filters**: Use web filters to block access to websites that host malicious content.

Some countermeasures against malware

6. **Use multi-factor authentication (MFA)**: Use MFA to add an extra layer of security to your accounts.
7. **Back up your data**: Make multiple copies of your files using different backup solutions and storage locations.
8. **Use a non-administrator account**: Use a non-administrator account whenever possible. An **administrator account**, on the other hand, has full permissions to make system changes, including those that will affect other users.
9. **Develop security policies**: Develop security policies and implement security awareness training.
10. **Perform vulnerability assessments**: Perform routine vulnerability assessments

Economics of malware

Economics of malware

The economics of malware is driven by the desire of cybercriminals to make money, and the cost of cybercrime is expected to increase significantly in the coming years:

Malware costs

- The annual economic damage from malware worldwide is over $13 billion. Cybersecurity Ventures estimates that cybercrime costs will reach $10.5 trillion annually by 2025.

Ransomware

- Ransomware profits are expected to increase as criminals refine their techniques. For example, Check Point Research estimates that the Gandcrab ransomware attack generated $300–600,000 in ransom payments.

Malware distribution

- Malware can be installed when other programs are downloaded, including from third-party websites or peer-to-peer networks.

Every day, 560,000 new pieces of malware are detected. There are now over 1 billion malware programs in existence. Trojans account for 58% of all computer malware. Every minute, four companies fall victim to ransomware attacks.

Conclusion

- Malware stands as a persistent and evolving threat in the digital landscape, a shadowy counterpart to technological advancement.
- From simple viruses designed for mischief to sophisticated ransomware and state-sponsored attacks, its forms are as varied as its intentions are malicious.
- Combating this threat requires more than just robust antivirus software; it demands constant vigilance, proactive cybersecurity practices, and a collective responsibility from individuals, corporations, and governments alike.
- As our reliance on interconnected systems deepens, the battle against malware remains a critical and ongoing struggle to secure the integrity, privacy, and functionality of our digital world.



: An Overview

Outline

- Introduction and definition cloud computing
- Characteristics of Cloud Computing
- Service delivery models of cloud computing
- Deployment models of cloud computing
- Cloud Role and Boundaries
- Technologies in Cloud Computing
- Key drivers to adopt the cloud
- Edge and fog computing



Introduction

- In 1965, **Corbato** *et al*. provide a business model for on demand computing resources that is based on *pay-as you-go* manner - means customers get to choose whatever resources (like- CPUs, memory, bandwidth, platforms, etc) from the vendor.
- Cloud computing developed in 2005/2006 as a new distributed computing model with the aimed of attaining the computing as a utility like public user obtain services from traditional public utility services such as water, electricity, gas and telephone.



Introduction…

- Cloud computing is taking services and moving them outside an organization's firewall. Applications, storage and other services are accessed via the Web.

- The provision of dynamically scalable and often virtualized resources as a service over the Internet on a utility basis.
- Users need not have knowledge of, expertise in, or control over the technology infrastructure in the 'cloud' that supports them."



Cloud Definition

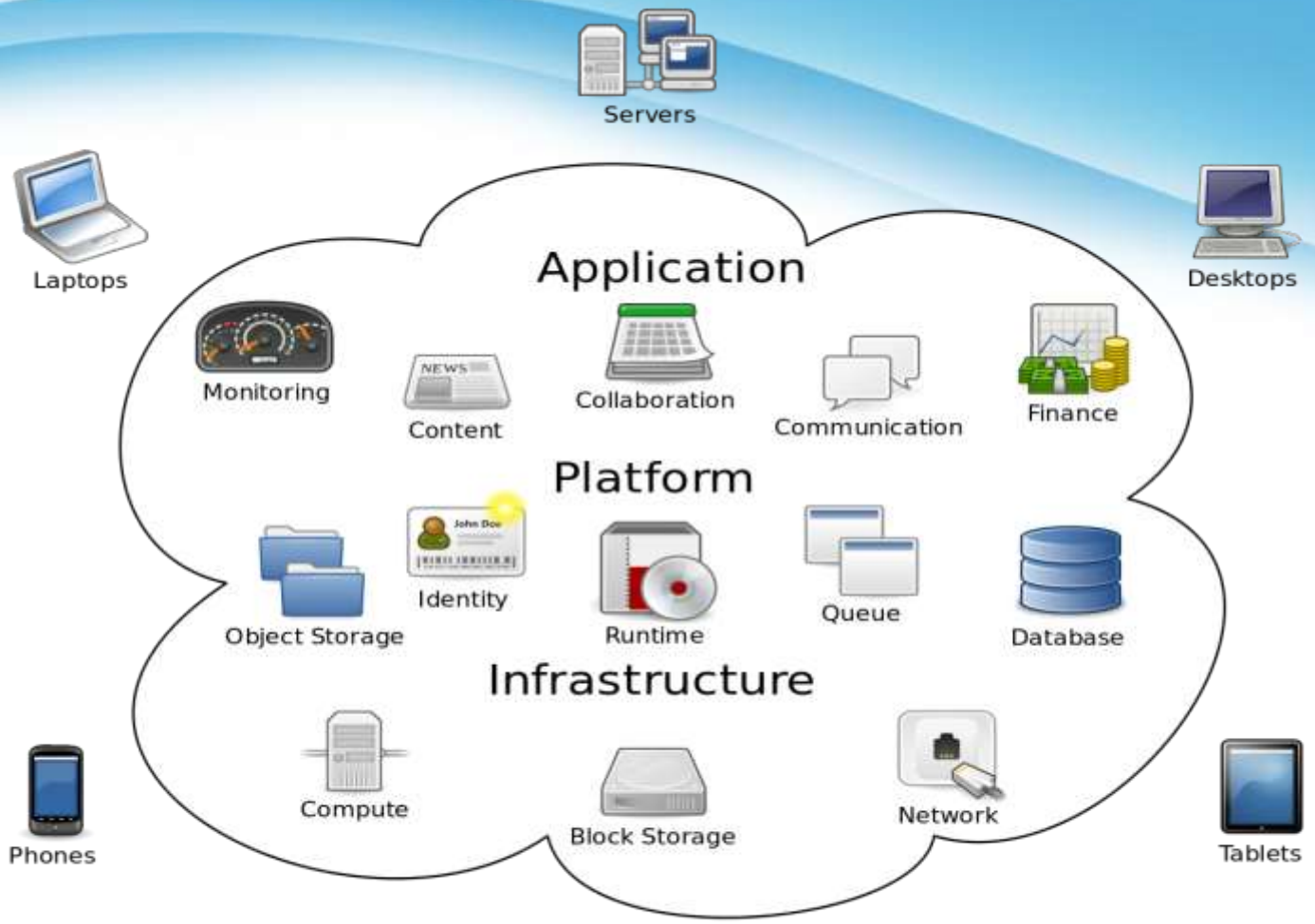
The **NIST** has a more comprehensive definition of cloud computing as-

"*A model for enabling convenient, on-demand network access to a shared pool of configurable computing resources (e.g.,* ***networks, servers, storage, applications, and services****) that can be rapidly provisioned and released with minimal management effort or service provider interaction*."

Cloud Definition

- Cloud computing is the delivery of computing services—including servers, storage, databases, networking, software, analytics, and intelligence— over the internet ("the cloud") to offer faster innovation, flexible resources, and economies of scale.
- By providing computing resources on demand, cloud computing avoids the need to install of physical servers, run own software, and manage the own databases.

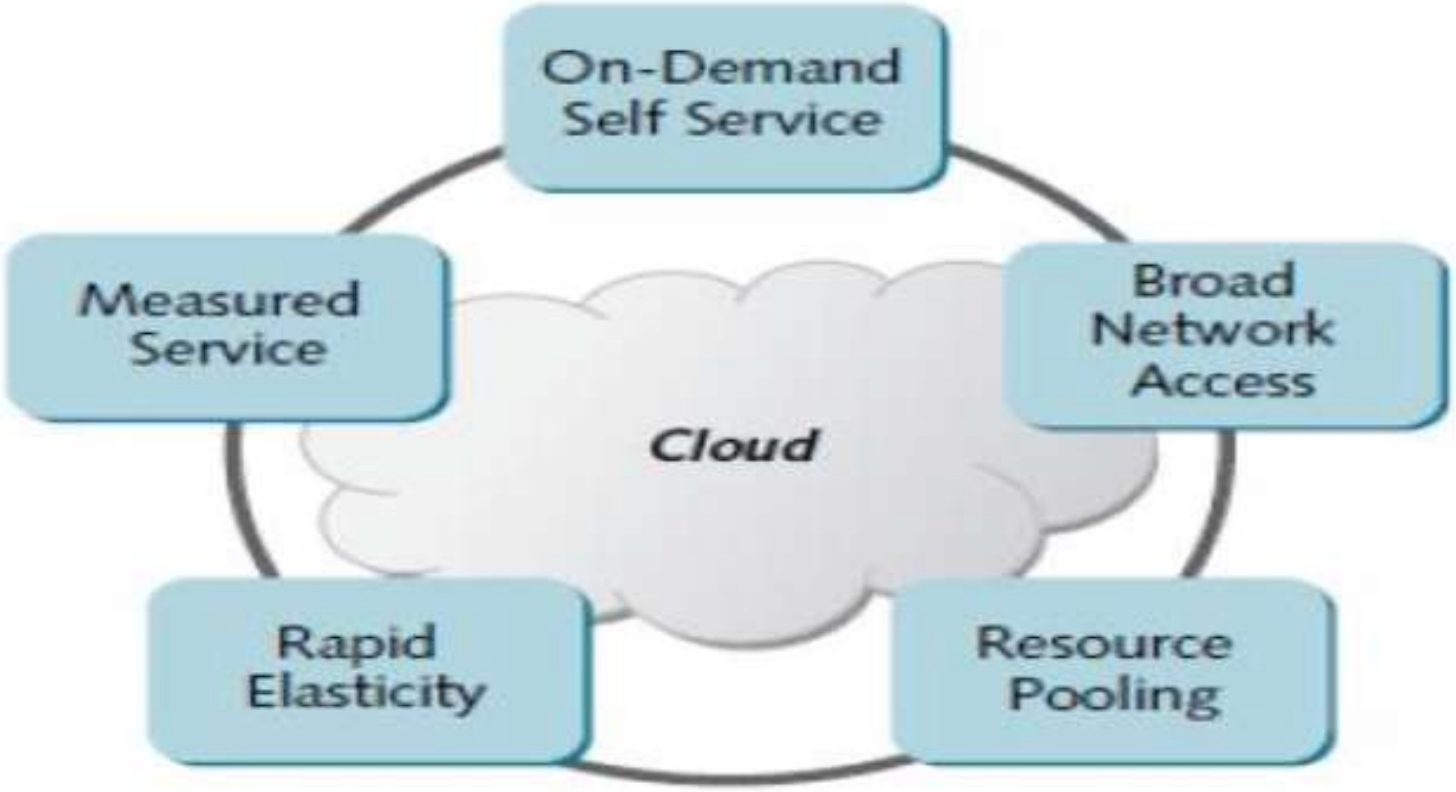
- By making the use of physical hardware more efficient and allowing one physical machine to serve many different needs and organizations, cloud computing reduces the cost of managing and accessing computing resources.



Cloud computing

Characteristics of cloud computing

Characteristics of cloud computing



On-demand self-service

- It enables consumers to directly request, manage and access the services through the web services and management interfaces without any human interaction.
- Computing resources are instantly available to users as per their requests.



Broad network access

- The data and services are presented in the cloud are accessible through using any standard device like mobile phones, PC, desktop, laptop.
- Cloud-based services are accessed from any location any time provided that there is adequate IP networking.



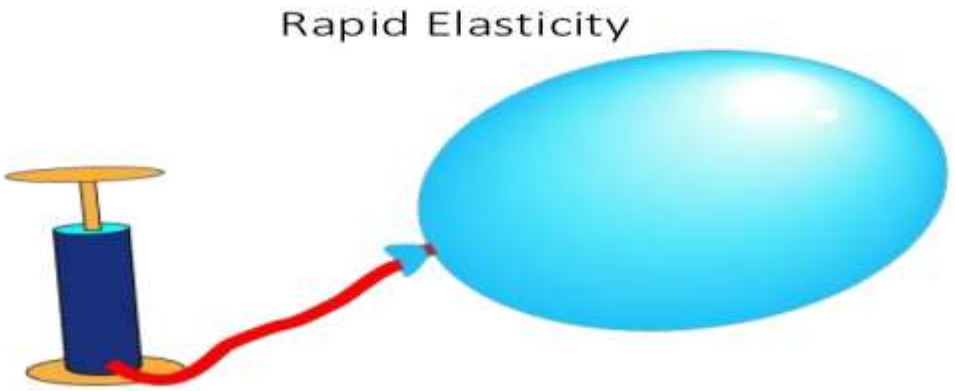
Resource pooling

- The cloud provider provides a large physical or virtual computing resources that are shared among multiple users.
- These resources are allocated dynamically in a multi-tenant environment.



Rapid elasticity

- Resources are scaled according to the consumer requirements. Customers have unlimited resources that can be purchased as needed in pay-per use manner.
- Elastically increases service capacity during busy periods, and reduces capacity during customers' off-peak periods.

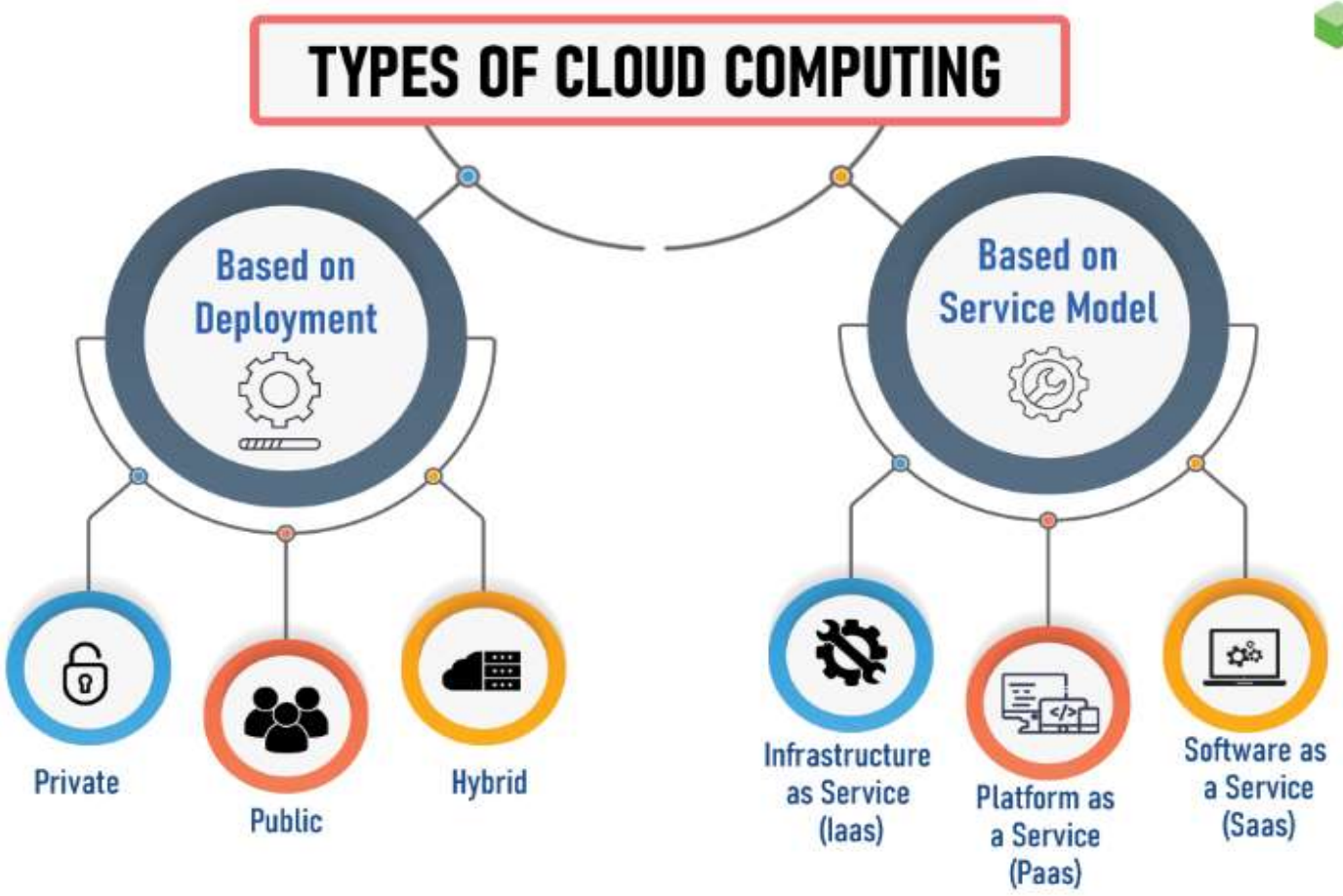


Measured Service

* You get what you pay for.
* The resources usage can be monitored, controlled, and reported.
* Allows for accountability for the provider and consumer.



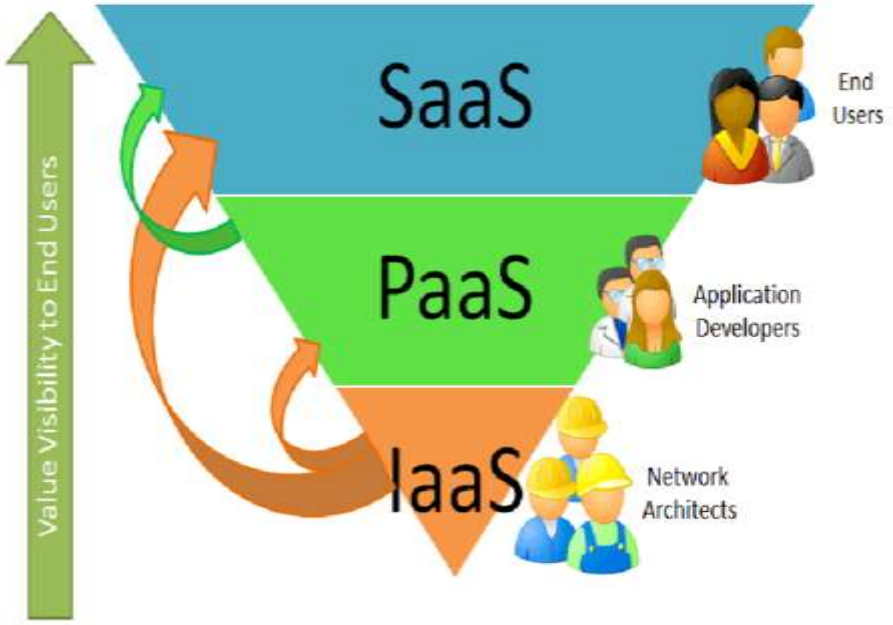
Classification/types of Cloud Computing


TYPES OF CLOUD COMPUTING
Based on Deployment
Based on Service Model
Private
Public
Hybrid
Infrastructure as Service (Iaas)
Platform as a Service (Paas)
Software as a Service (Saas)

Types/ classification based Service models

Service models of cloud computing

1. **Software as a service (SaaS)**
2. **Platform as a Service (PaaS):**
3. **Infrastructure as a service (IaaS)**



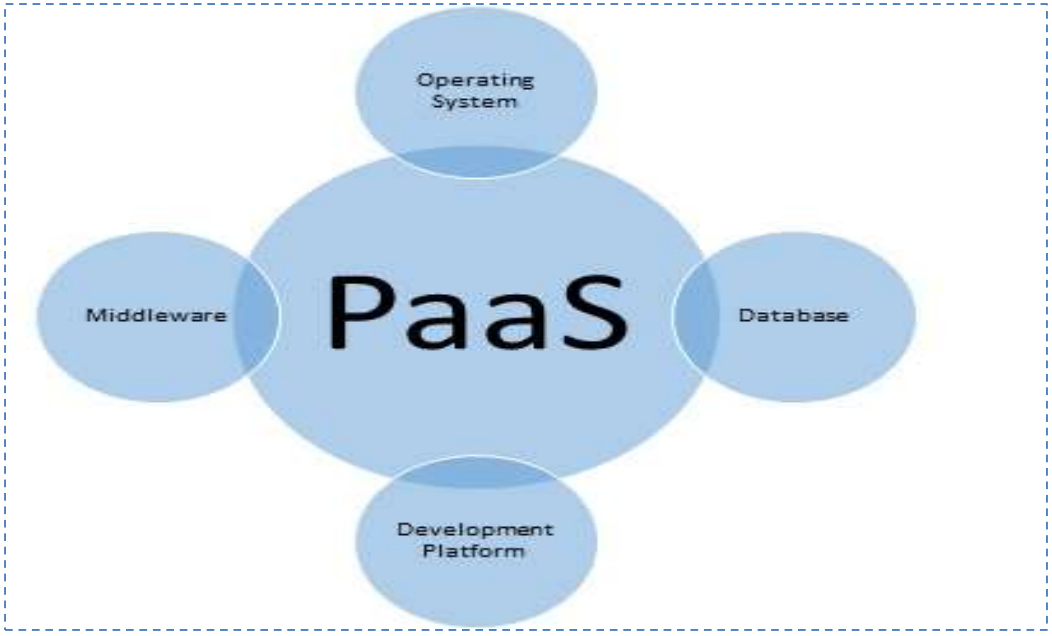
Software as a service

- Provides consumer the capability to use applications running on a cloud infrastructure mainly on the web browser to access software that offer as a service over the web.
- The consumers do not have control the underlying framework including system, servers, network, operating systems, storage.
- Example for SaaS are Dropbox, Google Apps and GoToMeeting etc.



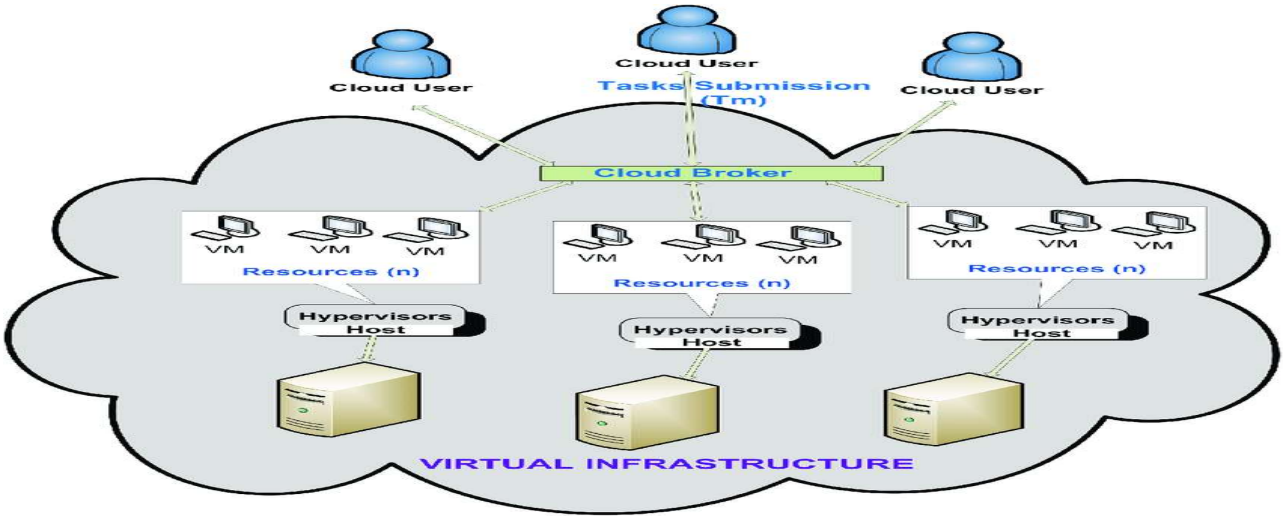
Service model: PaaS

- Provides the capability to deploy development environment onto the cloud infrastructure.
- Consumer creates/develops applications using set of programming languages and tools that are supported by the provider.
- Examples of PaaS are **Google App Engine** and **Microsoft Azure** Phantom



Service model: IaaS

- Provides the consumer with the capability to provision processing, storage, networks, and other fundamental computing resources and allow the consumer to deploy and run any software.
- The client has control over operating systems, storage, deployed applications and perhaps constrained control of select systems administration parts
- Examples of IaaS include *Amazon Web Services (AWS), Cisco Metapod, Microsoft Azure, Google Compute Engine (GCE*) etc.



Service model: at a glance

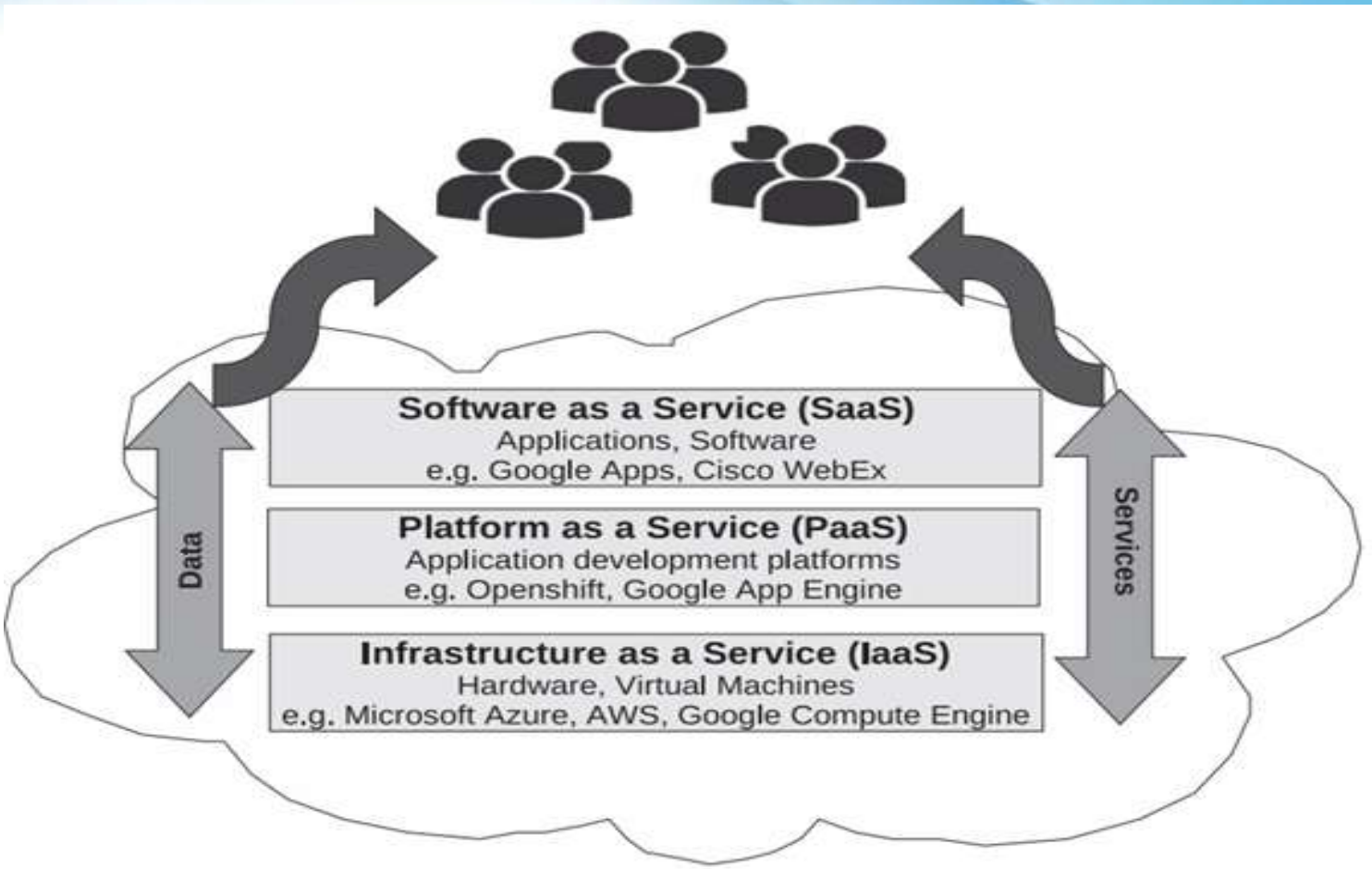


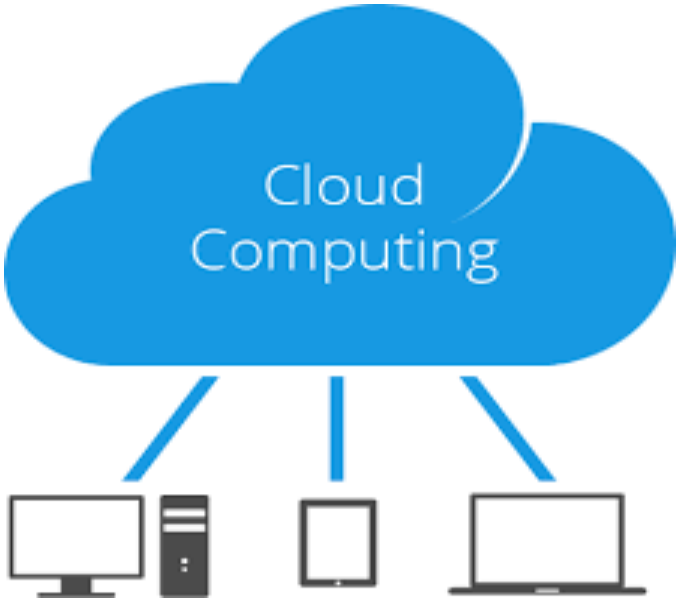
Fig. Cloud service delivery architecture.

Classification/Types based on Deployment models

Deployment models of cloud computing

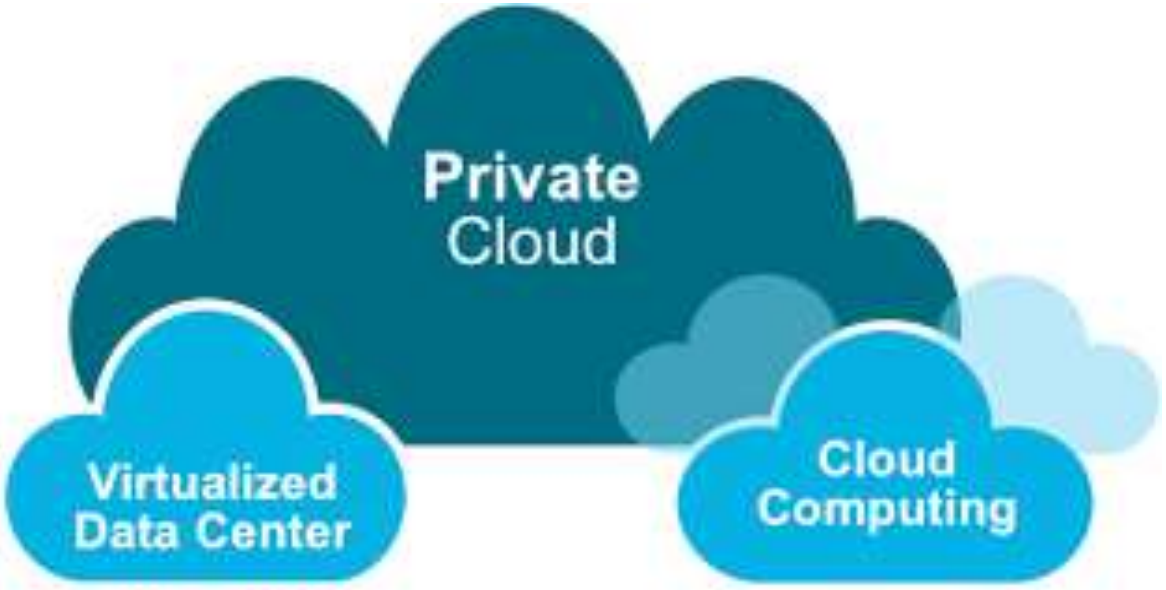
- A cloud organization model indicates how resources inside the cloud and shared.
- Deployment models are: **private cloud, public cloud, community cloud, and hybrid cloud**.

- Each model impacts the comparing scalability, reliability, security, and cost.



Private cloud

- A cloud that is used exclusively by one organization, company, or one of its customers.
- Cloud is operated and maintained internally by a single organization or through a Third Party Auditing .



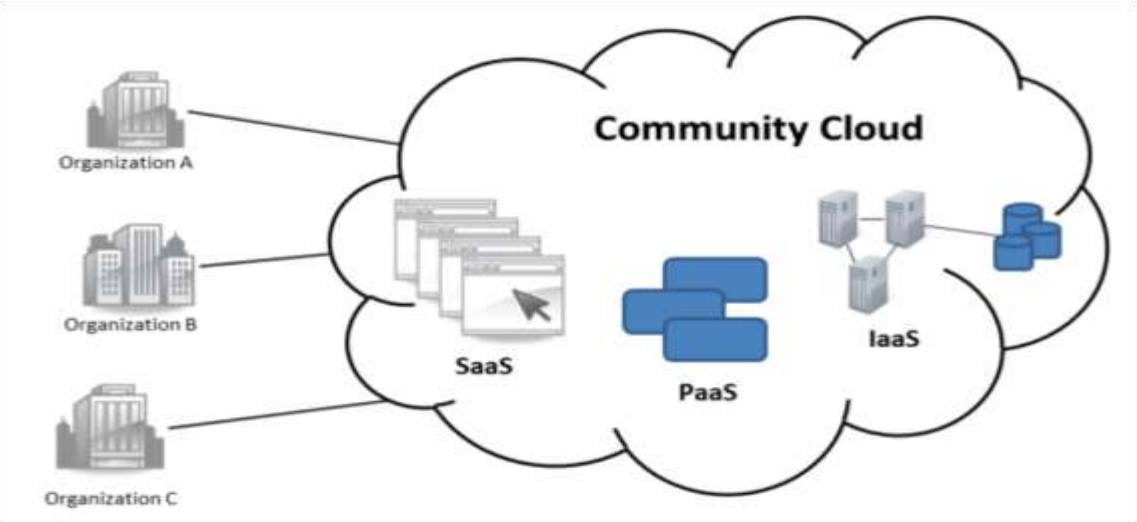
Public cloud

- A public cloud is run and managed by the CSP and the physical infrastructure may presented at off-site location of the user.
- The cloud resources are shared among the multiple people and people pay to the cloud provider according to the services they use.



Community Cloud

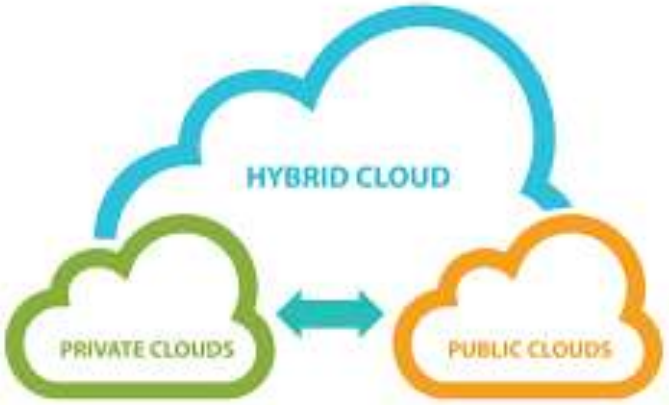
- Provides a cloud solution to a limited number of individuals or organizations that is governed, managed and secured commonly by all the participating organizations or a third party managed service provider.
- Often designed for businesses and organizations working on joint projects, applications, or research.



Hybrid Cloud

- Uses a mix of on-premises, private cloud and third-party, public cloud services with orchestration between the two platforms.

- Allows workloads to move between private and public clouds as computing needs and costs change. Hybrid cloud gives businesses greater flexibility and more data deployment options.



Cloud role and boundaries

The cloud provides different types of predefine role to the organization and human. These are:

- Cloud provider
- Cloud consumer
- Cloud service owner
- Cloud resource administrator
- Cloud broker
- Cloud carrier



Top leading Cloud Computing companies

1. **Amazon Web Services(AWS)**

- One of the most successful cloud-based businesses is Amazon Web Services(AWS), which is an Infrastructure as a Service(Iaas) offering that pays rent for virtual computers on Amazon's infrastructure.

2. **Microsoft Azure Cloud Platform**

- Microsoft is creating the Azure platform which enables the .NET Framework Application to run over the internet as an alternative platform for Microsoft developers. This is the classic Platform as a Service(PaaS).

3. **Google Cloud Platform (GCP)**

- Google has built a worldwide network of data centers to service its search engine. From this service, Google has captured the world's advertising revenue. By using that revenue, Google offers free software to users based on infrastructure. This is called Software as a Service (SaaS).

Technologies in Cloud Computing

Technologies in Cloud Computing

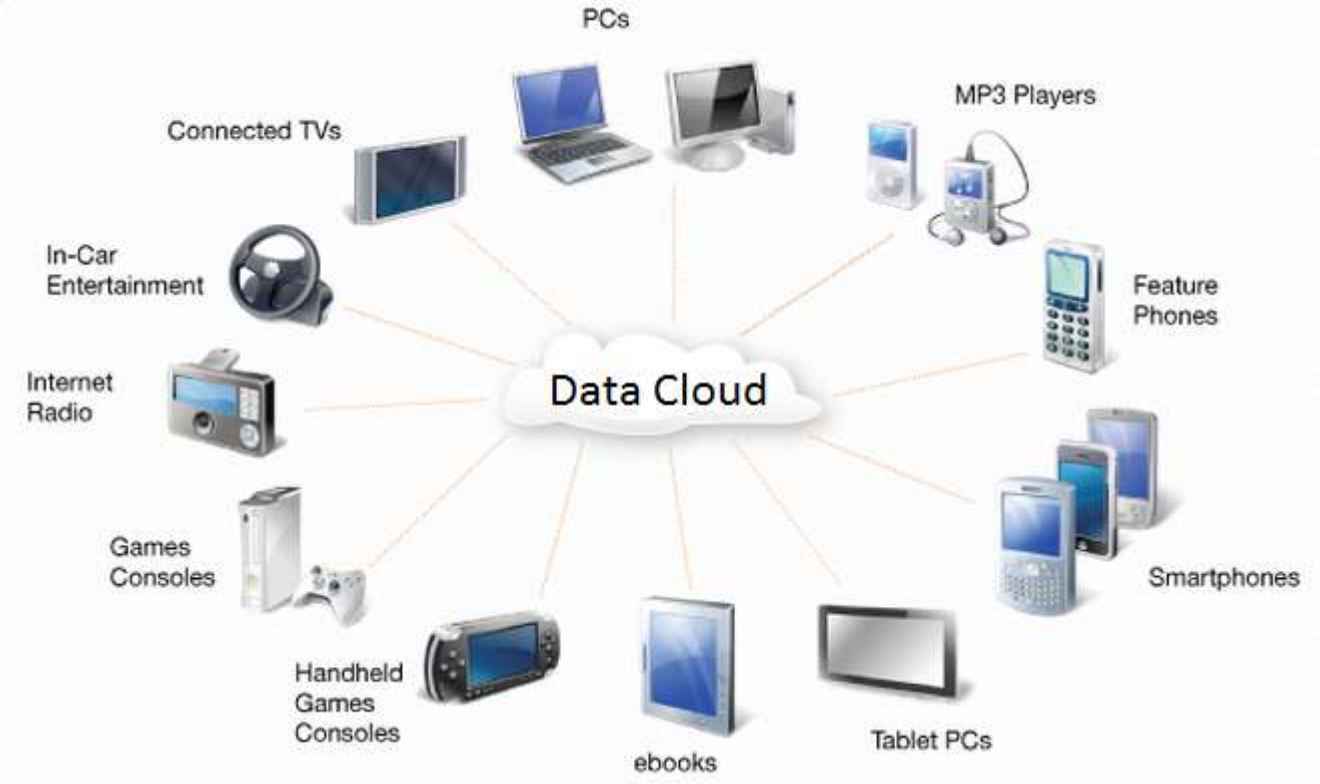
- Cloud computing isn't so much a technology as it is the combination of many pre-existing technologies.
- These technologies have matured at different rates and in different contexts, and were not designed as a coherent whole.
- These technologies have come together to create a technical ecosystem for cloud computing.

1. **Cloud access devices**
2. **Web technology**
3. **Broadband network and Internet technology**
4. **Data centers and server farms**
5. **Storage devices**
6. **Virtualization technologies**
7. **Service technology or API**
8. **Multi-tenant technology**



Cloud access devices

- The range of access devices for the cloud has expanded in recent years like home & enterprise PCs, network computers, mobile phone devices, and custom static devices are all online.



Web technology

-Users of multiple device types can now access applications and information from wherever they can load a browser.

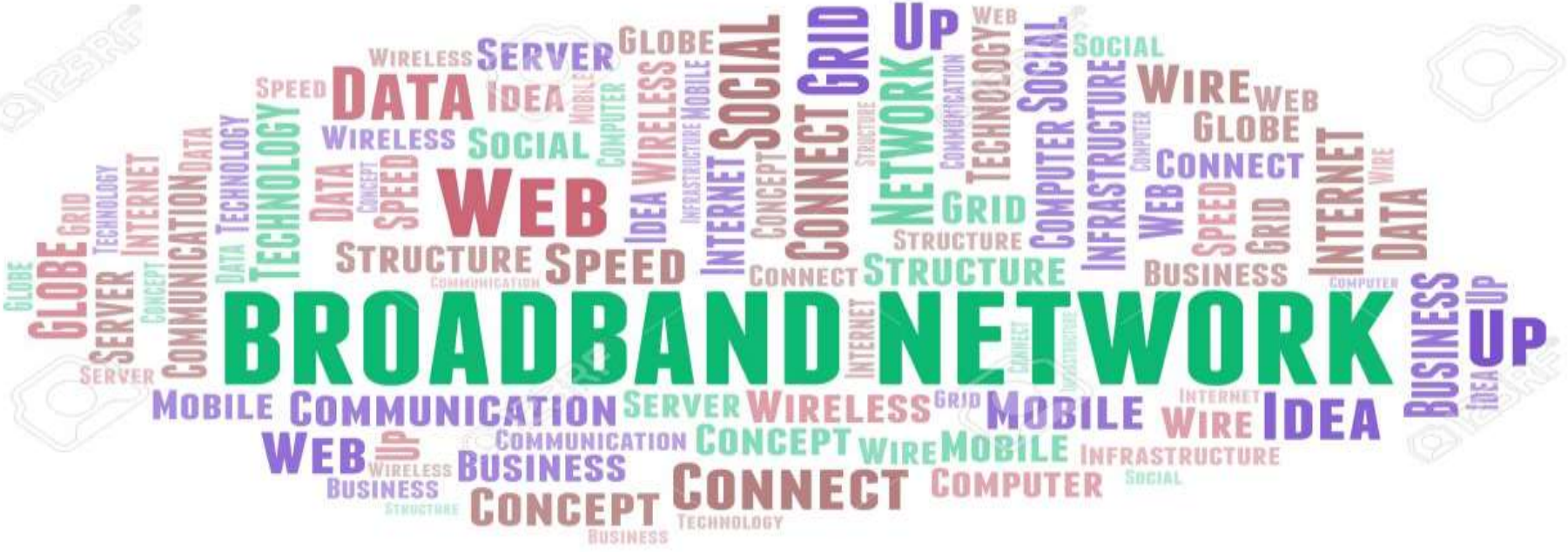
-The two fundamental constituent of the web technology is web client and web server. Proxies, routers, cache server, and gateways are known as the secondary components of the web



Broadband network and Internet technology

- A critical component of the cloud is the broadband network, which offers the means to connect components.

-Broadband access is now widely available, especially in global metropolitan areas.



Data centers and server farms

- Data center technology contains multiple technologies and components that are typically composed with one another.
- The data center has both physical and virtualized IT resources.



Storage devices

-The fixed direct access storage device (DASD) has been replaced with storage area networks (SANs), which have reduced costs and allowed a great deal more flexibility in enterprise storage.

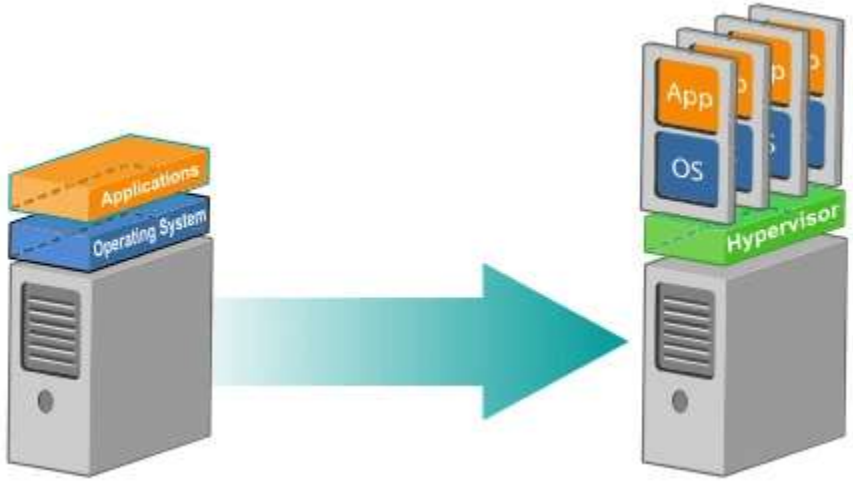
-SAN software manages integration of storage devices and can independently allocate storage space on demand across a number of devices.



Virtualization technologies

-Virtualization refers to the abstraction of compute resources (CPU, storage, network, memory, application stack, and database) from applications and end users consuming the service.

-Virtualization technologies enable multi-tenancy cloud business models by providing a scalable, shared resource platform for all tenants.



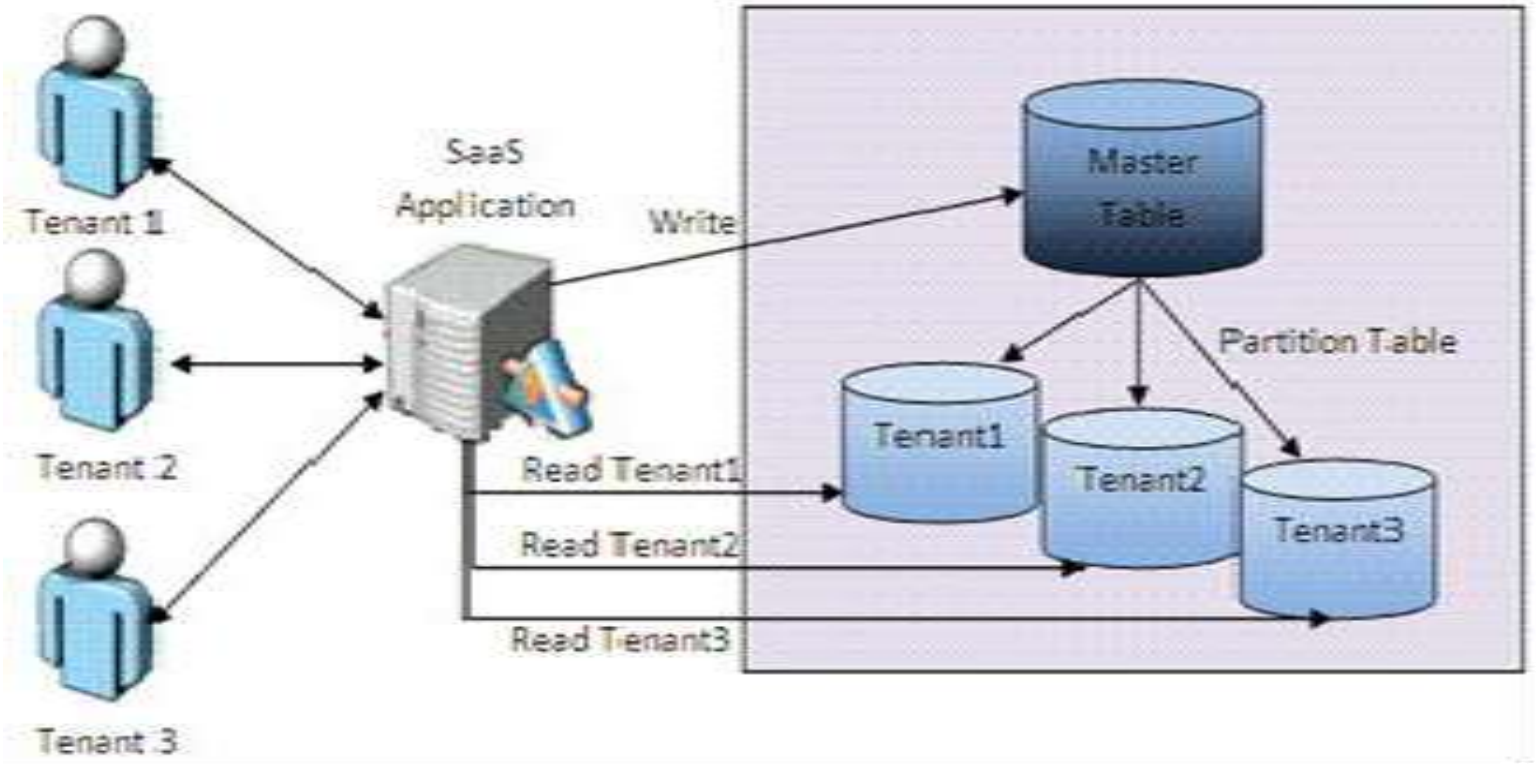
Service technology or API

- Depending on the type of cloud services delivery model, an API can manifest in different forms, ranging from simple URL manipulations to advanced SOA-like programming models.
- APIs help to exploit the full potential of cloud computing and mask the complexity involved in extending existing IT management processes of the cloud services.



Multi-tenant technology

- The same application logic is simultaneously accessed by multiple users using multi-tenant technology.
- The most common features of multi-tenants application is usage isolation, data recovery, data tier isolation, data security, application upgrades, system scalability, and metered usage



Traditional IT vs Cloud Computing

TABLE. *Cloud computing: A customer's perspective*

Dedicated/traditional IT	Cloud computing
High upfront IT investments for new builds	Low upfront IT investments; pay-for-use model
High cost of reliable infrastructure	Reliability built into the cloud architecture
High complexity of IT environment	Modular IT architecture environments
Complex infrastructure	No infrastructure

Key drivers of adopting cloud

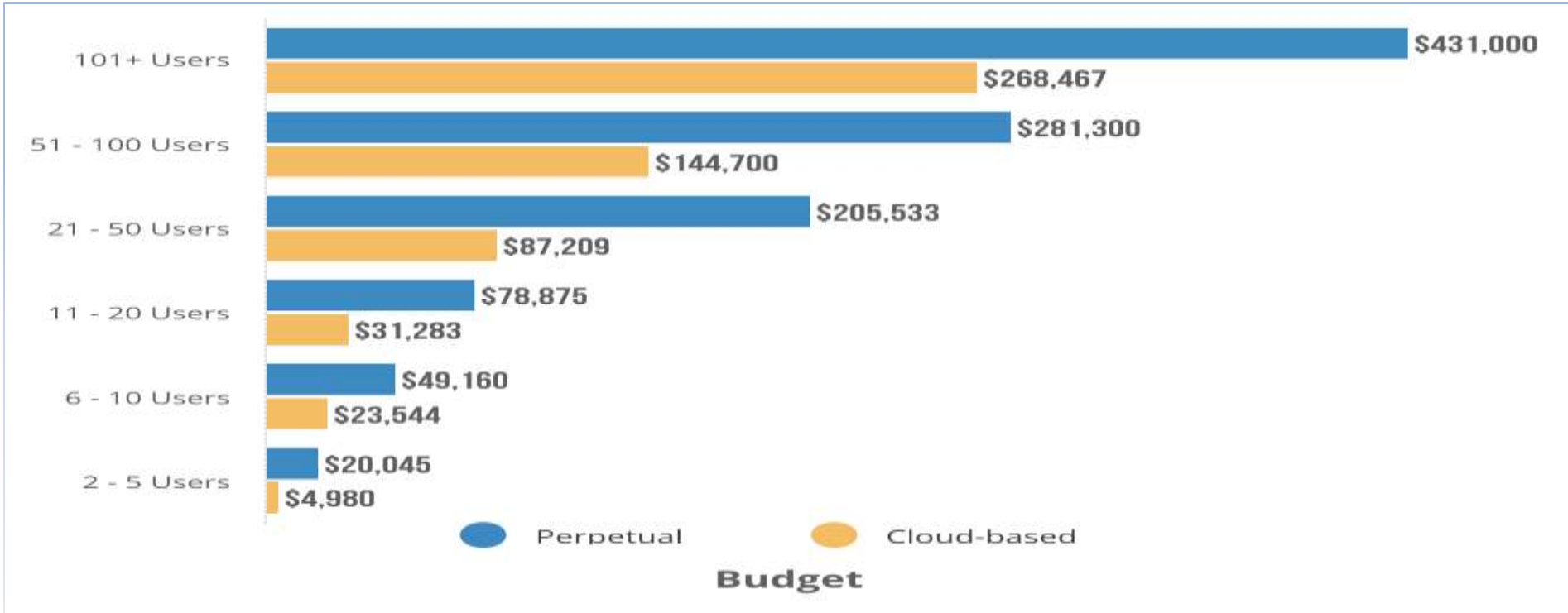
Key drivers of adopting cloud

There are a number of compelling reasons to move operations toward cloud computing.

- **Small Initial Investment and Low Ongoing Costs**
- **Economies of Scale**
- **Open Standards**
- **Sustainability**

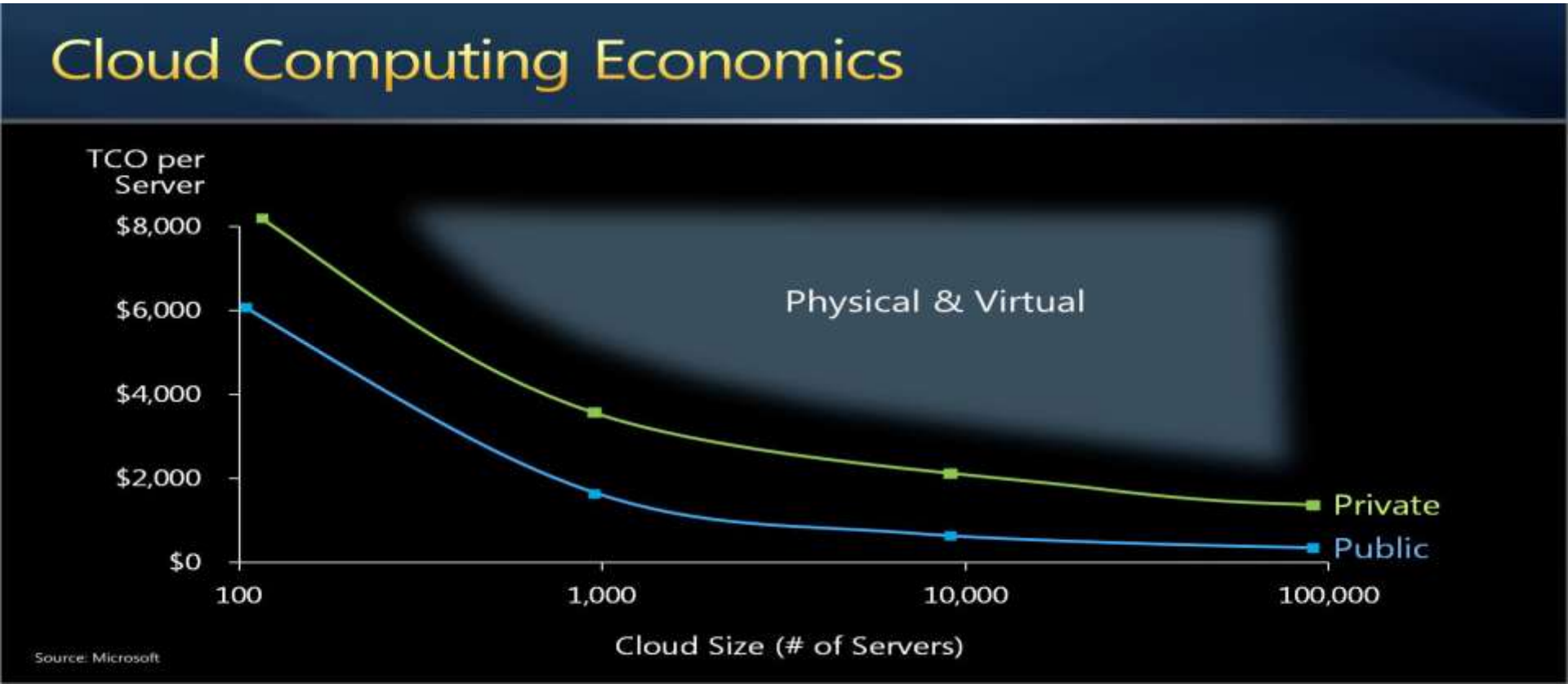
Key Drivers: Small Initial Investment and Low Ongoing Costs

- Public cloud computing can avoid capital expenditures because no hardware, software, or network devices need to be purchased.
- Cloud usage is billed on actual use only, and is therefore treated no more as an expense venture.



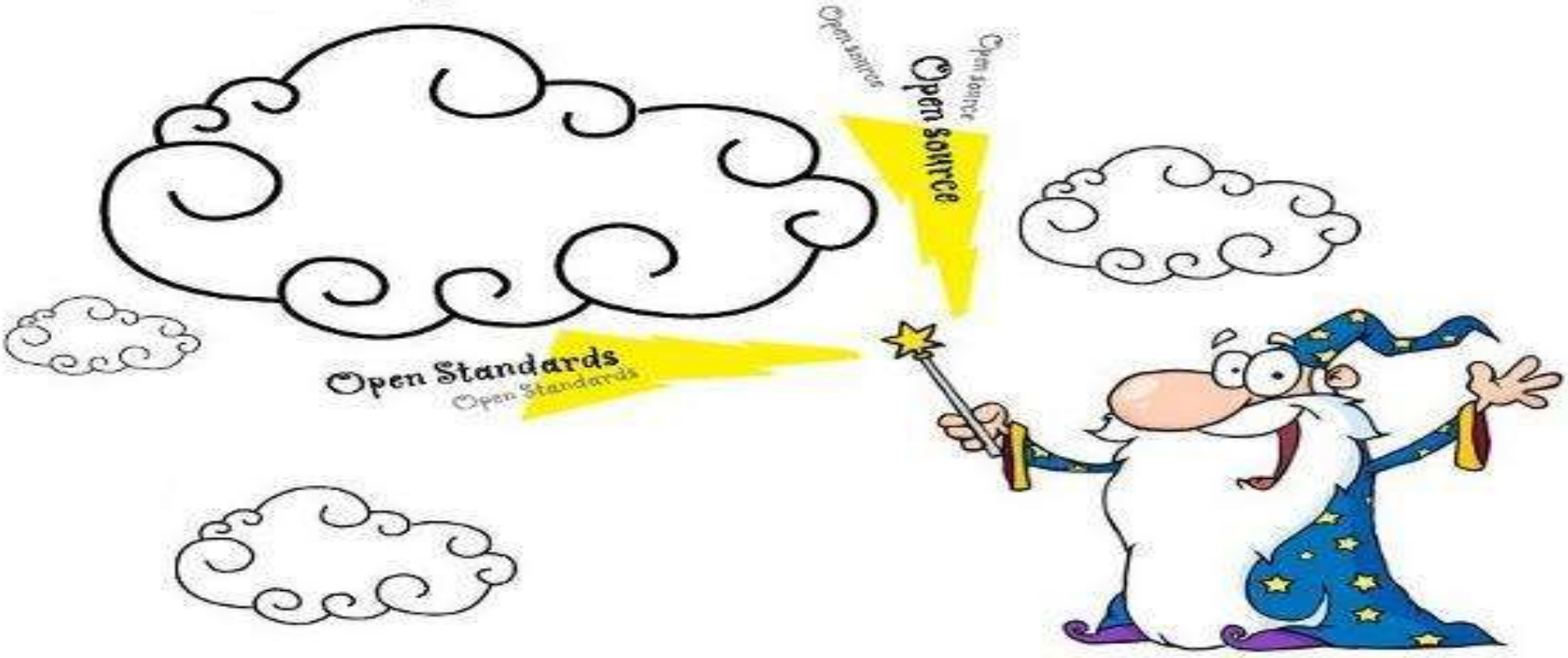
Key Drivers: Economies of Scale

- Most development projects have a sizing phase during which attempts to calculate the storage, processing power, and memory requirements during development, testing, and production.
- With the flexibility that cloud computing solutions offer, companies can acquire computing and development services as needed and on demand,



Key Drivers: Open Standards

- Some capabilities in cloud computing are based on open standards for building a modular architecture that can grow rapidly and can change when required.
- The flexibility to alter the source code is essential to allow for continued growth in the cloud solution.



Key Drivers: Sustainability

- CSPs have invested considerable expense and thought into creating a resilient architecture that can provide a highly stable environment
- Cloud computing allows companies to rely on the CSP to have limited points of failure, better resilience via clustering, and the ability to invest in state-of-the-art resilience solutions



Uses of cloud computing

From tiny start-ups and global corporations to government agencies and nonprofits — are embracing the technology for a variety of reasons and use cases.

- **Create new apps and services**: Quickly build, deploy, and scale applications like web, mobile, and API on any platform. Access the resources you need to help meet performance, security, and compliance requirements. Build, test and take down environments quickly, speeding time to market for new developments.

- **Store, backup, and recover data**: Avoid outages and protect your data cost-effectively — and at massive scale — by transferring your data over the internet to an offsite cloud storage system that's accessible from any location and any device. Improve disaster recovery efforts to ensure business continuity.

- **Stream audio and video**: Connect with your audience anywhere, anytime, on any device, with high-definition video and audio, with global distribution.

- **Deliver software on demand**: Also known as software as a service (SaaS), on-demand software lets you offer the latest software versions and updates to your customers — anytime they need them, anywhere they are.

- **Work with big data analytics and AI**: Use the powerful processing capabilities of the cloud to collect and analyze big data or to power artificial intelligence and machine learning applications.
- **Support your mobile workforce**: Give your mobile and remote workers virtual desktops they can easily access from any laptop, tablet, or mobile device. Keep workers connected with cloud-based email and messaging platforms.

Edge computing

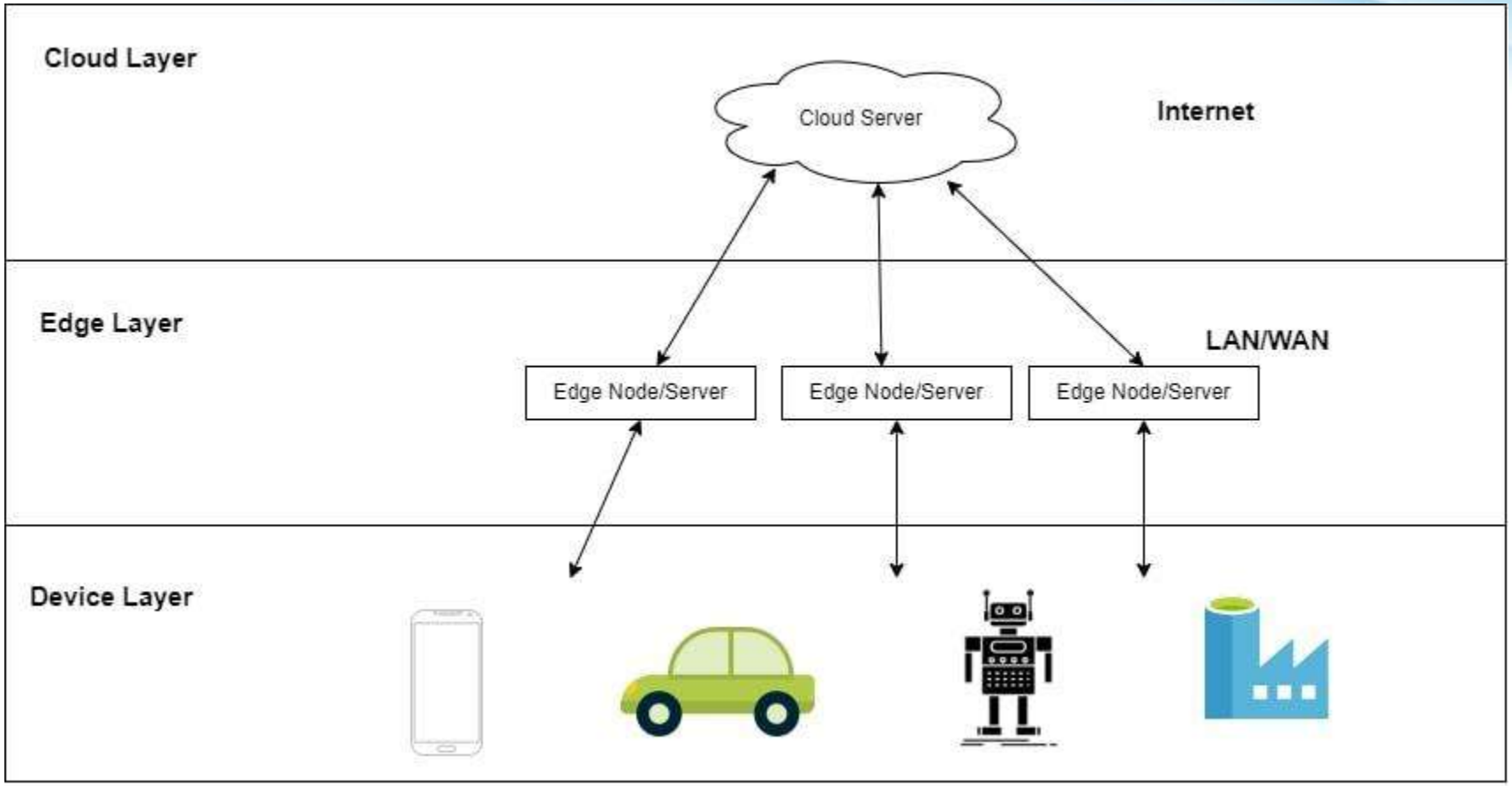
- Edge computing is a subsection of cloud computing.

- While cloud computing is about hosting applications in a core data centre, edge computing is about hosting applications closer to end users, either in smaller edge data centres or on the customer premises instead.

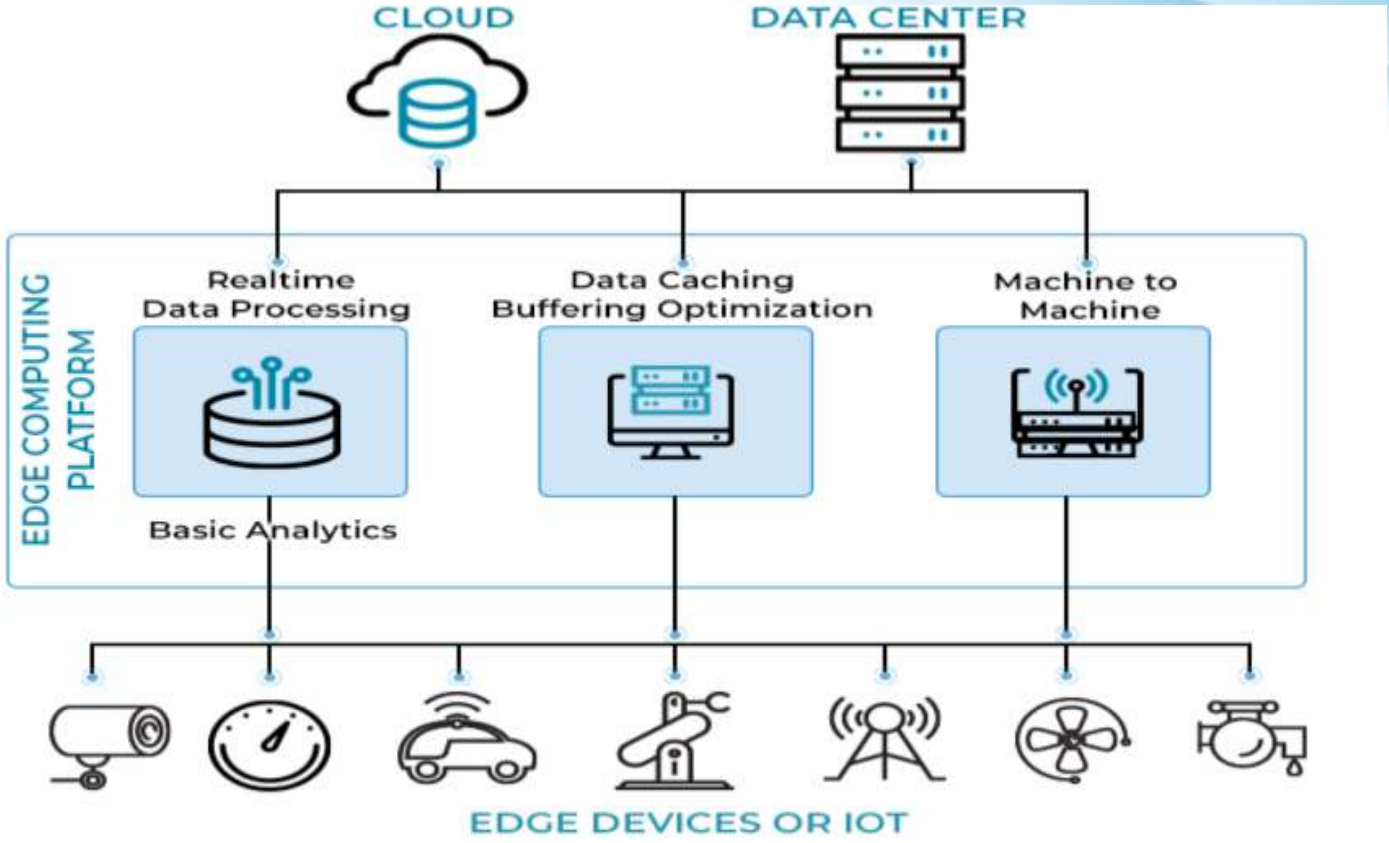
Edge computing

- Edge computing optimizes Internet devices and web applications by bringing computing closer to the source of the data.
- This minimizes the need for long distance communications between client and server, which reduces latency and bandwidth usage.
- Edge computing means running fewer processes in the cloud and moving those processes to local places, such as on a user's computer, an IoT device, or an edge server. Bringing computation to the network's edge minimizes the amount of long-distance communication that has to happen between a client and server.

Edge computing



Edge computing



Edge computing

Example of edge computing

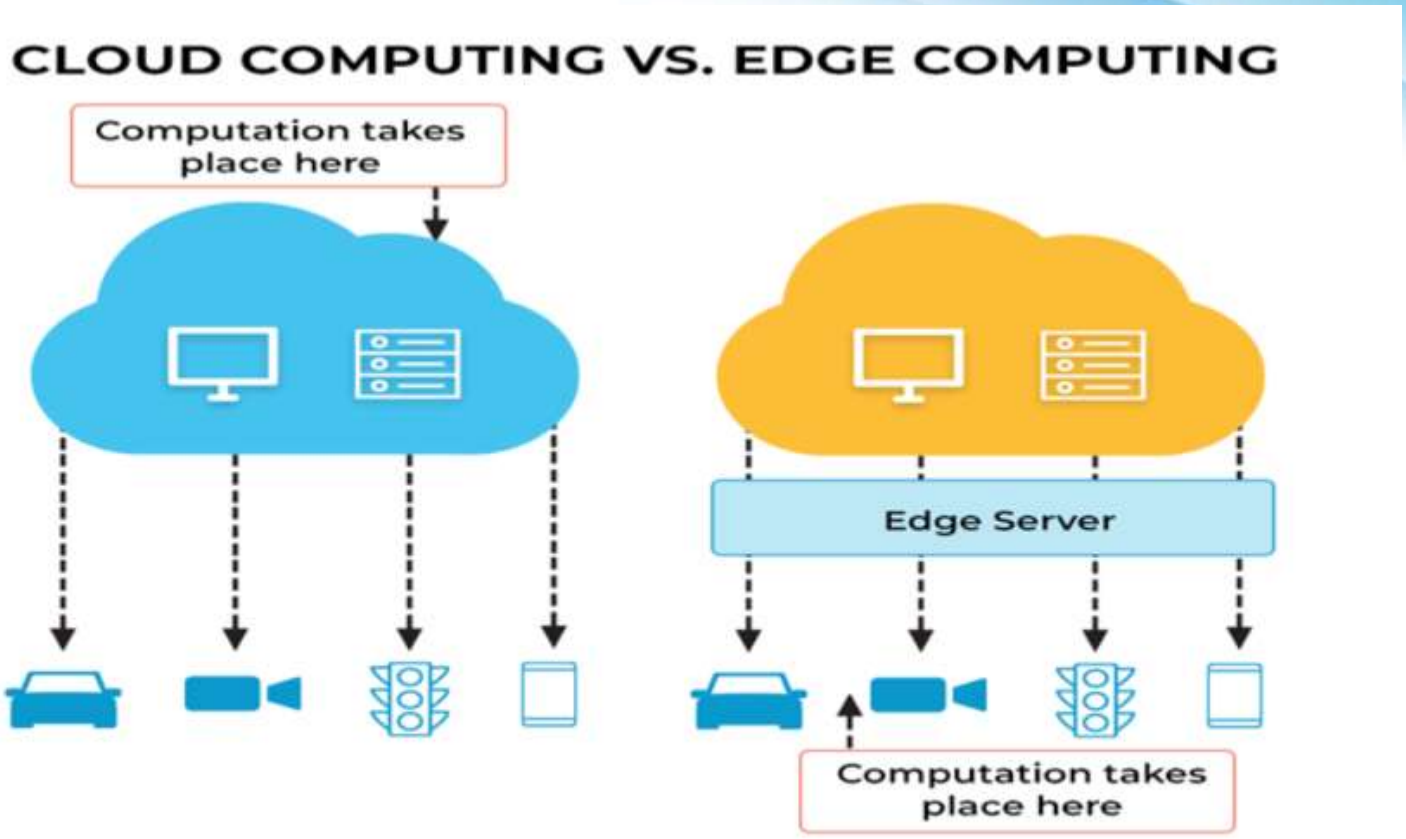
- Consider a building secured with dozens of high-definition IoT video cameras. These are "dumb" cameras that simply output a raw video signal and continuously stream that signal to a cloud server.
- On the cloud server, the video output from all the cameras is put through a motion-detection application to ensure that only clips featuring activity are saved to the server's database.
- This means there is a constant and significant strain on the building's Internet infrastructure, as significant bandwidth gets consumed by the high volume of video footage being transferred.
- Additionally, there is very heavy load on the cloud server that has to process the video footage from all the cameras simultaneously.

Example of edge computing

- Now imagine that the motion sensor computation is moved to the network edge. What if each camera used its own internal computer to run the motion-detecting application and then sent footage to the cloud server as needed? This would result in a significant reduction in bandwidth use, because much of the camera footage will never have to travel to the cloud server.

- Additionally, the cloud server would now only be responsible for storing the important footage, meaning that the server could communicate with a higher number of cameras without getting overloaded. This is what edge computing looks like.

Differences between cloud and edge computing



Difference Between Cloud Computing and Edge Computing

Differences between cloud and edge computing

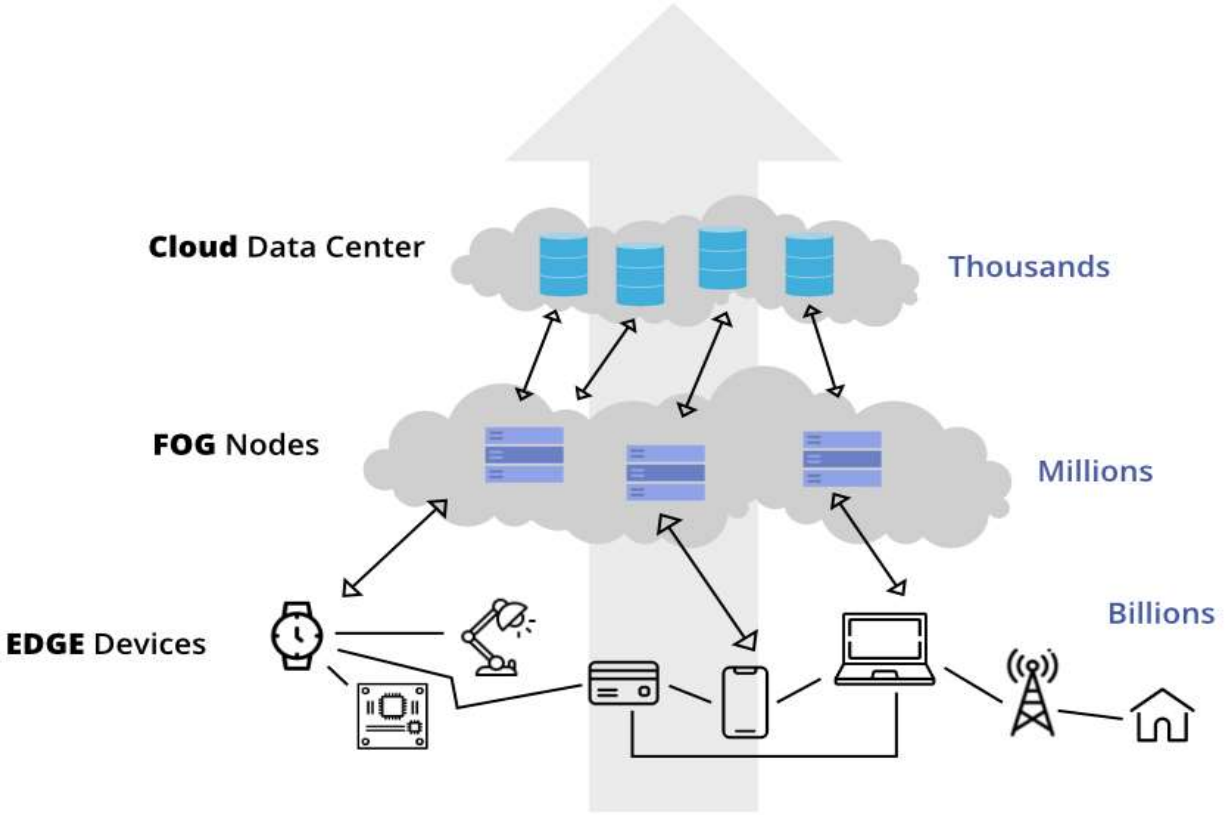
Computing	Edge Computing
Cloud computing is centralised servers stored in faraway, large-scale data centres.	On the other hand, it is a highly distributed and global computing infrastructure closer to the devices and users.
It processes data on a central cloud server far from the data sources.	Process data on site quickly and analyze data in real-time. It does not focus on storing data.
It is suited for applications that are not time-sensitive.	It is ideal for low latency, where every millisecond counts.
Cloud computing gives improved and innovative processing capabilities and storage capacity.	As it processes in the device, it has lower processing power and storage capacity.
It is suitable for in-depth and long-term analysis.	It is better for fast and real-time analysis.
It needs internet connectivity.	It can work without internet connectivity.
An expensive and intensive operational activity for the company.	Automated scalability with zero-touch provisioning
The connectivity, data movement, bandwidth, and latency cost are relatively high.	Fewer latency and bandwidth requirements increased performance and lower operational expenses.

Fog Computing

Fog computing, also known as fog networking, is a distributed computing architecture that brings cloud computing capabilities to the edge of a network. It allows devices to perform computation, storage, and communication locally, and then route the data over the internet



Fog Computing



Fog computing is a layer in between the edge and the cloud. When edge computers send huge amounts of data to the cloud, fog nodes receive the data and analyze what's important. Then the fog nodes transfer the important data to the cloud to be stored and delete the unimportant data or keep them with themselves for further analysis. In this way, fog computing saves a lot of space in the cloud and transfers important data quickly

Thank You





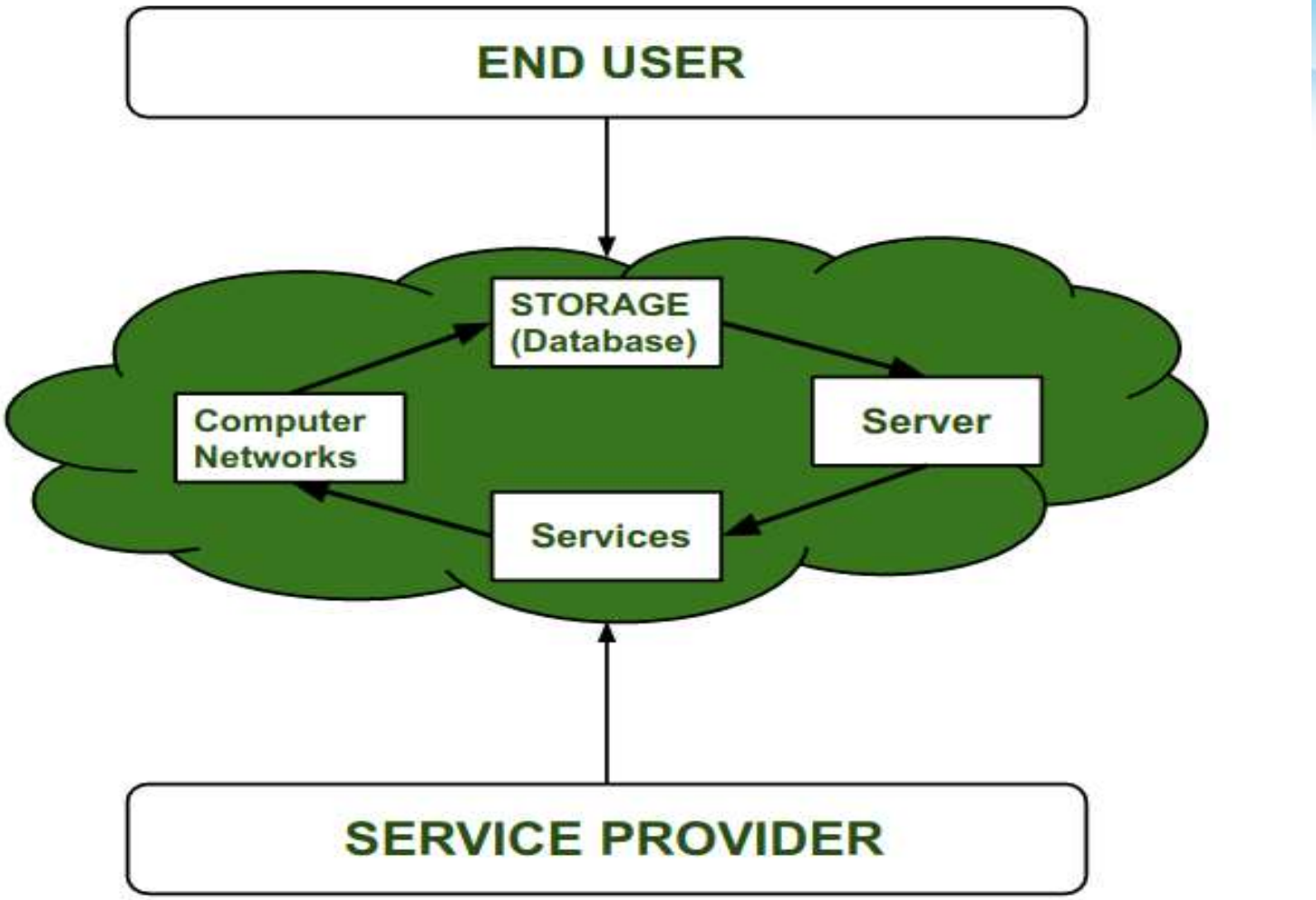
- **Challenges of cloud computing**
- **Security Issues in Cloud**
- **Attacks based on cloud components**
- **Major Public Cloud Cybersecurity Incidents Around the Globe**

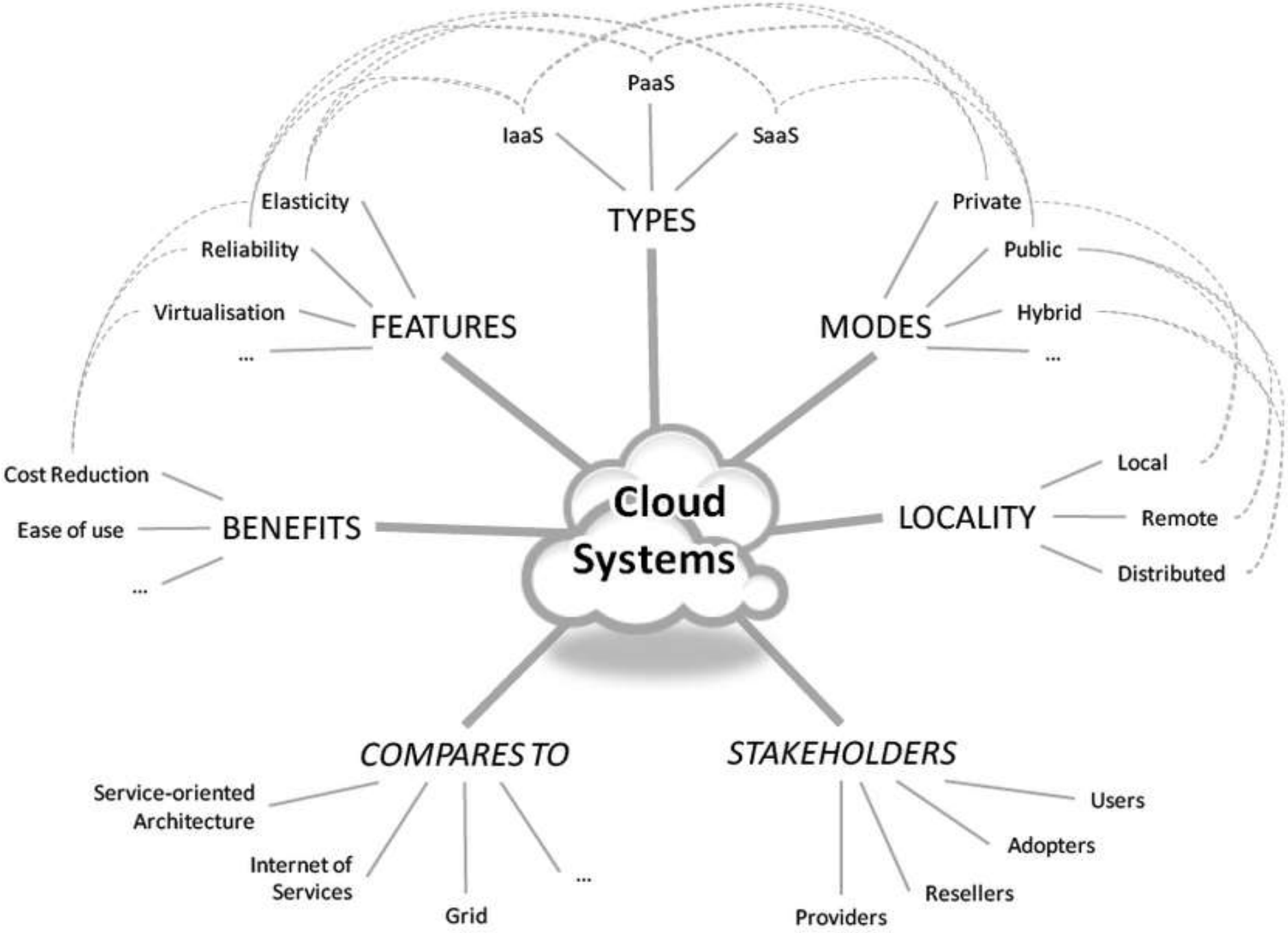
Outline

- **Challenges of cloud computing,**
- **Security issues in cloud,**
- **Categorization of attacks based on cloud components.**



Cloud Computing




Cloud Systems
TYPES
IaaS
PaaS
SaaS
FEATURES
Elasticity
Reliability
Virtualisation
...
MODES
Private
Public
Hybrid
...
BENEFITS
Cost Reduction
Ease of use
...
LOCALITY
Local
Remote
Distributed
COMPARES TO
Service-oriented Architecture
Internet of Services
Grid
...
STAKEHOLDERS
Users
Adopters
Resellers
Providers

Challenges of cloud computing

Cloud security challenges encompass the operational difficulties and complexities that organizations encounter while implementing and managing effective security measures in cloud environments.

Challenges of Cloud Computing

Like any new technology, the adoption of cloud computing is not free from issues.

Some of the most important challenges are as follows:

1. **Security and Privacy**
2. **Interoperability and portability**
3. **Reliability and availability**
4. **Performance and bandwidth cost**
5. **SLA & service quality**
6. **Lack of skill, knowledge and expertise**
7. **Recovery and loss of data**
8. **Insecure APIs**
9. **Vendor Lock-in**



Cloud Computing is **a security nightmare** and it can't be handled in traditional ways.

John Chambers
Former CISCO CEO

Security and Privacy

- How the businesses address the security and privacy concerns thinking of adopting it?
- The valuable enterprise data will reside outside the corporate firewall raises serious concerns.
  - Hacking and various attacks to cloud infrastructure would affect multiple clients even if only one site is attacked.



Interoperability and Portability

- The industry lacks standards for APIs and cloud interfaces, interoperability standards, and associated technical standards that allow interoperability of private to private clouds, public to private clouds, and so on.
- Portability refers to the ability of an application to move across environments, not just across platforms. Portability is a form of reusability.

- Due to lack of portability enables the migration of cloud services from one cloud provider to another or between a public cloud and a private cloud is difficult.



Reliability and availability

- Cloud outages experienced by its providers such as *Google and Amazon* are well documented and publicized.
- This has discouraged potential organizations who were thinking of moving into the cloud environment.
- Cloud computing is a trust-based technology where lack of trust inhibits its adoption.



Performance & bandwidth cost

- Businesses can save money on hardware but they have to spend more for the bandwidth.
- This can be a low cost for smaller applications but can be significant.
- Any enterprises adopting cloud computing services certainly expect the kind of improved performance that an elastic computing environment should provide.

- But cloud services are not perfect. Questions about performance are sure to arise in even the most efficient, well-designed cloud environment.



SLA and Service Quality

- Service quality is also one of the biggest factors considered by enterprises and for this reason, they don't shift their business application to the cloud.
- Though there is an SLA, clients fear that the cloud service providers do not provide any guarantee to ensure product applications security keeps the organizations away from having it.

- QoS approaches in cloud computing have become an important topic in the cloud computing area and there remain open challenges and gaps which require future research exploration.



Lack of skill, Knowledge and expertise

- Every organization does not have sufficient skill or knowledge about the implementation of the cloud solutions.
- organizations have not expertise/skilled staff and tools for the proper use of cloud technology.

- Despite growth in adoption, a cloud skills gap still exists.

- Firms hunt for candidates with more specialized skills related to public cloud and open source platforms.



Recovery of Lost data

- The potential financial impact from losing customer trust is so high on the threats list.
- Cloud services faces issue of data loss.
- A proper backup policy for the recovery of data must be placed to deal with the loss.

  - Vendors must set proper infrastructures to efficiently handle with server breakdown and outages.



Insecure APIs

- Application programming interfaces (APIs) play a significant role in communicating with the cloud services offered by cloud providers.

- APIs define the protocols and methods for requesting and exchanging data, allowing applications to access various cloud resources such as storage, computing power, and databases.

- Insecure APIs can be easily attacked by hackers, and sensitive data can be exposed, leading to data leaks, account takeovers, and service disruptions.

Vendor Lock-In

- The **vendor lock-in** is the situation where customers are dependent on a single **cloud provider** technology implementation and cannot easily move in the future to a different **vendor** without substantial costs, legal constraints, or technical incompatibilities.

- Vendor lock-in is a major barrier to the adoption of cloud computing, due to the lack of standardization.

  - For companies that come to rely heavily on public and hybrid cloud platforms, there is a danger that they become forced to continue with a specific third-party vendor simply to retain operational capacity.



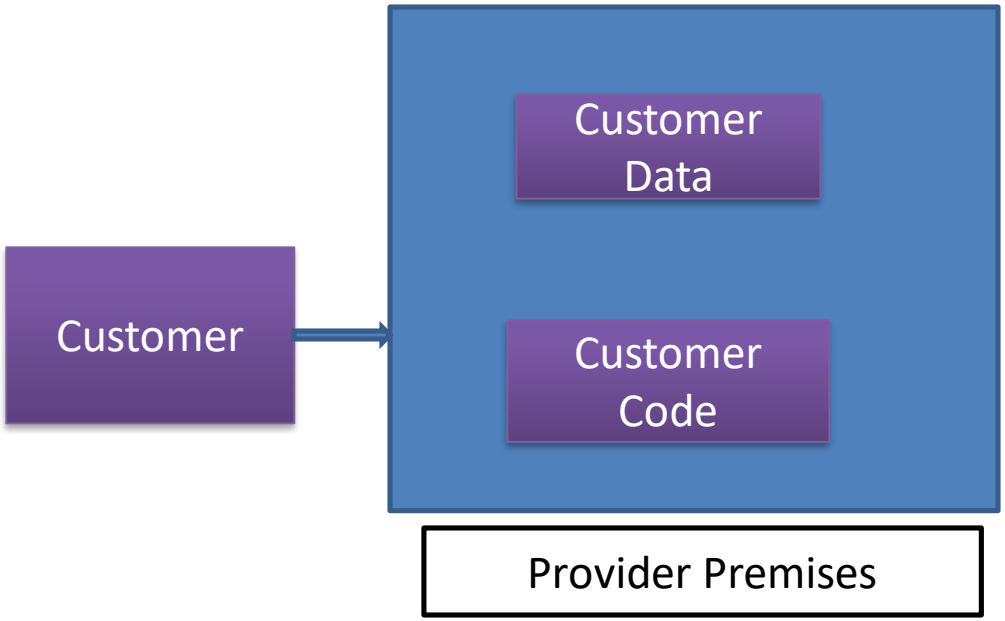
Other issues regarding cloud computing

i) Both customer data and program are residing at cloud provider's premises,
ii) Loss of control,
iii) Lack of trust (Service level agreement), and
iv) Multi-tenancy,
v) Lack of visibility

Cloud Security !! A major Concern

- Security concerns arising because both customer data and program are residing at Provider Premises.

- Security is always a major concern in Open System Architectures (OSA).





Cloud Computing brings new threats

- Traditional system security mostly means keeping bad guys out.
- The attacker needs to either compromise the auth/access control system, or impersonate existing users.

- Cloud Security problems are coming from :
  - **Loss of control**
  - **Lack of trust (mechanisms)**
  - **Multi-tenancy**



Cloud Computing brings new threats

Consumer's loss of control:

- Data, applications, resources are located with provider.
- User identity management is handled by the cloud.
- User access control rules, security policies and enforcement are managed by the cloud provider.
- Consumer relies on provider to ensure-
  - **Data security and privacy**
  - **Resource availability**
  - **Monitoring and repairing of services/resources**



Cloud Computing brings new threats: SLA

- The on-demand service or utility-based economic model necessitates the use of well-established service level agreements (SLAs).
- An SLA is a part of a service contract between the consumer and provider that formally defines the level of service. **It records a common understanding about services, priorities, responsibilities, guarantees and warranties.**

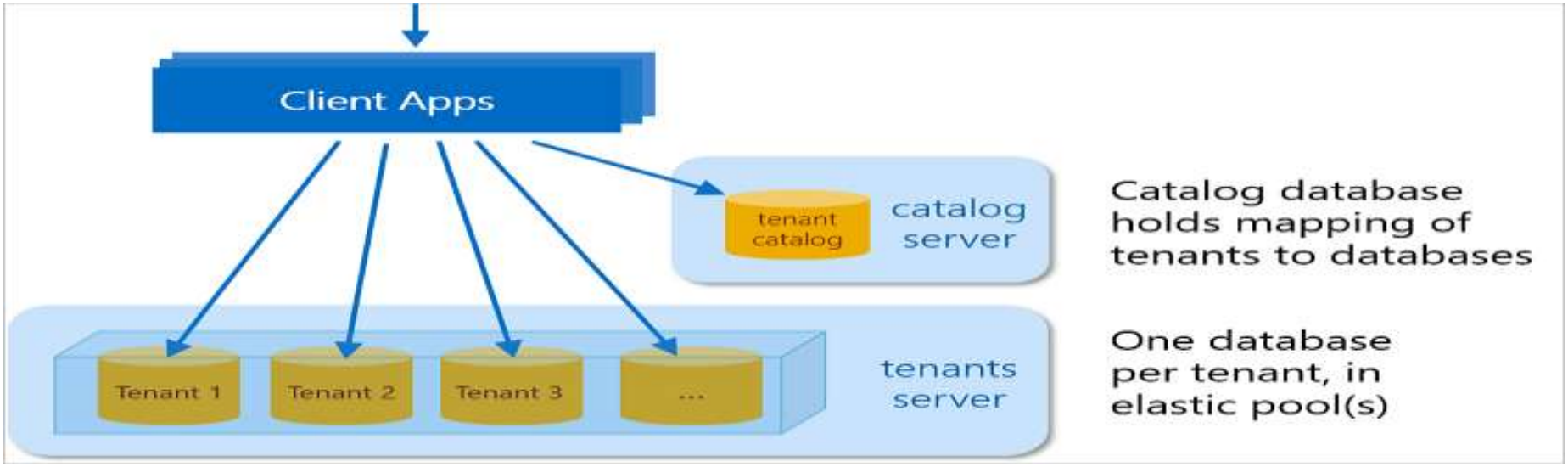
- Therefore, the main issue for cloud computing is to build a ***new layer to support a contract negotiation phase between service providers and consumers and to monitor contract enforcement*** for building trust to the clients.



Cloud Computing brings new threats

Multi-tenancy :

- Multiple independent users share the same physical infrastructure
- So, an attacker can legitimately be in the same physical machine as the target



Lack of visibility

- A typical cloud environment comprises IaaS, SaaS, and PaaS components, often combined with on-premises data centers in hybrid models.

- The rapid proliferation of third-party applications, digital identities, and sensitive data can lead to cloud sprawl, where an organization loses control over its cloud resources.

- The lack of comprehensive visibility slowed down Target's incident response, allowing the breach to persist and cause financial and reputational damage.

Security Issues in Cloud

Security Issues in Cloud

- A security issue is something happening in any assets attacks, misconfiguration, fault, damage, loopholes, and weakness in the system.
- The Cloud Security Alliance's 2026 report identifies 11 leading cloud security threats based on industry surveys.

i) Cloud misconfiguration,
ii) Identity and Access Management (IAM) attacks,
iii) Insecure APIs and interfaces,
iv) Data breaches and unauthorized data access,
v) Account hijacking and credential theft,
vi) Cloud ransomware attacks,
vii) Distributed Denial of Service (DDoS) &
viii) Insider threats.
ix) Insecure virtualization and hypervisor vulnerabilities
x) Supply chain attacks
xi) Advanced Persistent Threats (APTs)



Cloud misconfiguration

High risk

- Misconfiguration is one of the most common causes of cloud security incidents.

Examples:

- Publicly accessible cloud storage buckets.
- Databases exposed to the internet.
- Incorrect firewall and security group rules.
- Unprotected virtual machines.
- Incorrect access permissions.
- Exposed administrative interfaces.
- Insecure default configurations.

Example attack scenario:

- An organization stores confidential research data in cloud storage.
- The storage bucket is accidentally configured for public access.
- An attacker discovers the exposed storage location.
- The attacker downloads confidential files.
- Sensitive information is disclosed without compromising the cloud provider itself.
- Security mechanisms:

Identity and Access Management (IAM) attacks

Critical risk

- Identity and Access Management controls who can access cloud resources and what operations they can perform.

Major vulnerabilities:

- Weak passwords.
- Absence of Multi-Factor Authentication (MFA).
- Stolen credentials.
- Excessive user privileges.
- Poorly managed service accounts.
- Compromised API keys.
- Privilege escalation.
- Session hijacking and token theft.

Example:

- An attacker obtains the credentials of a cloud administrator through phishing. The attacker then logs into the cloud console and accesses virtual machines, databases, and storage systems.

Insecure APIs and interfaces

- Cloud environments depend heavily on APIs for communication between applications, databases, virtual machines, storage, and cloud management services.
- An insecure API can provide attackers with an entry point into the cloud infrastructure.

Common API vulnerabilities:

- Broken authentication.
- Broken authorization.
- API key exposure.
- Excessive data exposure.
- Injection attacks.
- Inadequate input validation.
- Unrestricted API access.
- Rate-limit bypass.

Example attack:

- An attacker discovers an API endpoint that retrieves student information from a university cloud database. Due to inadequate authorization checks, the attacker changes a student ID in the API request and accesses another student's personal information.

Data breaches and unauthorized data access

Critical risk

- A cloud data breach occurs when an unauthorized individual gains access to confidential or sensitive information.

Cloud databases may contain:

- Personal identification information.
- Financial records.
- Medical information.
- Government records.
- University research data.
- Intellectual property.

Authentication credentials.

- Attack mechanisms:
- Stolen credentials.
- SQL injection.
- Misconfigured cloud storage.
- Insider threats.
- Exploitation of vulnerable applications.
- Compromised third-party services.

Account hijacking and credential theft

- Account hijacking occurs when attackers obtain control over legitimate cloud accounts.

Common techniques:

- Phishing.
- Credential stuffing.
- Brute-force attacks.
- Password spraying.
- Session cookie theft.
- OAuth token theft.
- Malware-based credential harvesting.

Consequences:

- Unauthorized access to cloud applications.
- Theft of confidential data.
- Creation of unauthorized virtual machines.
- Modification of security configurations.
- Installation of ransomware.
- Financial losses through unauthorized resource consumption.

Cloud ransomware attacks

- Ransomware is malicious software that encrypts files or otherwise makes organizational data unavailable and demands payment for recovery.

Cloud environments can be affected through:

- Compromised cloud administrator accounts.
- Infected virtual machines.
- Compromised endpoints synchronized with cloud storage.
- Exploited application vulnerabilities.
- Compromised backup accounts.
- Abuse of cloud storage APIs.

Distributed Denial of Service (DDoS)

- DDoS attacks attempt to make cloud-hosted services unavailable by overwhelming them with malicious traffic or requests.
- Types of DDoS attacks:

Attack type	Mechanism
Volumetric	Flooding networks with massive traffic
Protocol-based	Exploiting network protocol weaknesses
Application-layer	Overloading HTTP, DNS or application services
DNS amplification	Using DNS infrastructure to amplify traffic
HTTP flood	Sending excessive HTTP requests

Insider threats

- Insider threats originate from individuals who already have legitimate access to cloud systems.

These may include:

- Employees.
- System administrators.
- Database administrators.
- Developers.
- Contractors.
- Third-party service personnel.

Types:

- Malicious insider: deliberately steals or destroys information.
- Negligent insider: accidentally exposes confidential data.
- Compromised insider: an employee's account is taken over by an attacker.

- Example: A cloud administrator downloads confidential research information and transfers it to an external storage account.

Insecure virtualization and hypervisor vulnerabilities

- Virtualization is fundamental to cloud computing. Multiple virtual machines may operate on the same physical server.
- The hypervisor manages the underlying physical resources and isolates virtual machines.
- A vulnerability in the hypervisor may threaten the isolation between virtual machines.

Major threats:

- Hypervisor exploitation.
- VM escape.
- VM-to-VM attacks.
- Insecure VM images.
- Virtual machine sprawl.
- Snapshot theft.
- Unauthorized VM cloning.
- Side-channel attacks.

Supply chain attacks

- Cloud services depend on many third-party components, including software libraries, APIs, plugins, development tools, managed services, and external vendors.
- An attacker may compromise a third-party component and use it as an entry point into an organization's cloud environment.

Examples:

- Malicious software packages.
- Compromised CI/CD pipelines.
- Vulnerable third-party libraries.
- Compromised software updates.
- Exposed vendor credentials.
- Insecure managed service integrations.

Advanced Persistent Threats (APTs)

- APTs are sophisticated attacks in which threat actors maintain unauthorized access to an organization's systems for an extended period.
- Cloud infrastructure is an attractive target for espionage, intellectual property theft, and strategic information collection.

Typical attack activities:

- Initial compromise through phishing.
- Credential theft.
- Privilege escalation.
- Lateral movement.
- Persistence through cloud identities.
- Data exfiltration.
- Concealment of malicious activities.

Summary of cloud cybersecurity threats

No.	Cybersecurity issue	Major security solution
1	Cloud misconfiguration	CSPM
2	IAM attacks	MFA, RBAC, ZTA
3	Insecure APIs	API Gateway, WAF
4	Data breaches	Encryption, DLP
5	Account hijacking	MFA, UEBA
6	Ransomware	EDR, immutable backup
7	DDoS	CDN, DDoS protection
8	Insider threats	PAM, UEBA
9	Hypervisor attacks	Hypervisor hardening
10	Supply chain attacks	SBOM, SCA
11	APTs	SIEM, XDR, threat intelligence

Attacks based on cloud components

(Network, Virtual Machines storage and applications)

Attacks based on cloud components

- For performing comparative analysis, attacks on a cloud platform based on its components:

1. **Network (A1),**
2. **Virtual machines (A2)**
3. **Storage (A3) and**
4. **Applications (A4)**



Network based attacks

- An intruder may attack a cloud system through its network which may in turn deteriorate
  the quality of cloud services and may even put data privacy/confidentiality at risk.

1. **Port scanning**
2. **Botnets**
3. **Spoofing attacks**

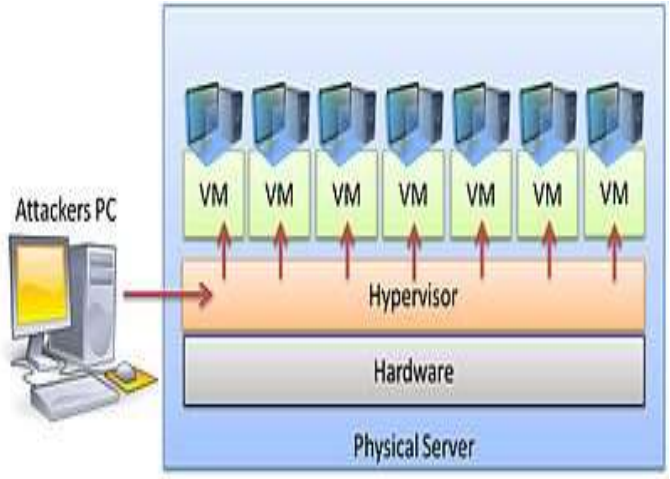




Virtual machine based attacks

- On a cloud system, the VM based attacks exploit vulnerabilities in the virtual machines to violate data protection and affect the cloud services.
- Multiple virtual machines being hosted on a system cause several security risks.

1. **Cross VM side channel attacks**
2. **VM creation attacks**
3. **VM migration and rollback attacks**
4. **VM scheduler based attacks**



Storage based Attacks

- An attacker from outside or even a malicious insider may steal private data stored on some storage device.
- With access to sensitive information, a large number of vulnerabilities may be exploited by manipulating data if a strict monitoring mechanism is not implemented.

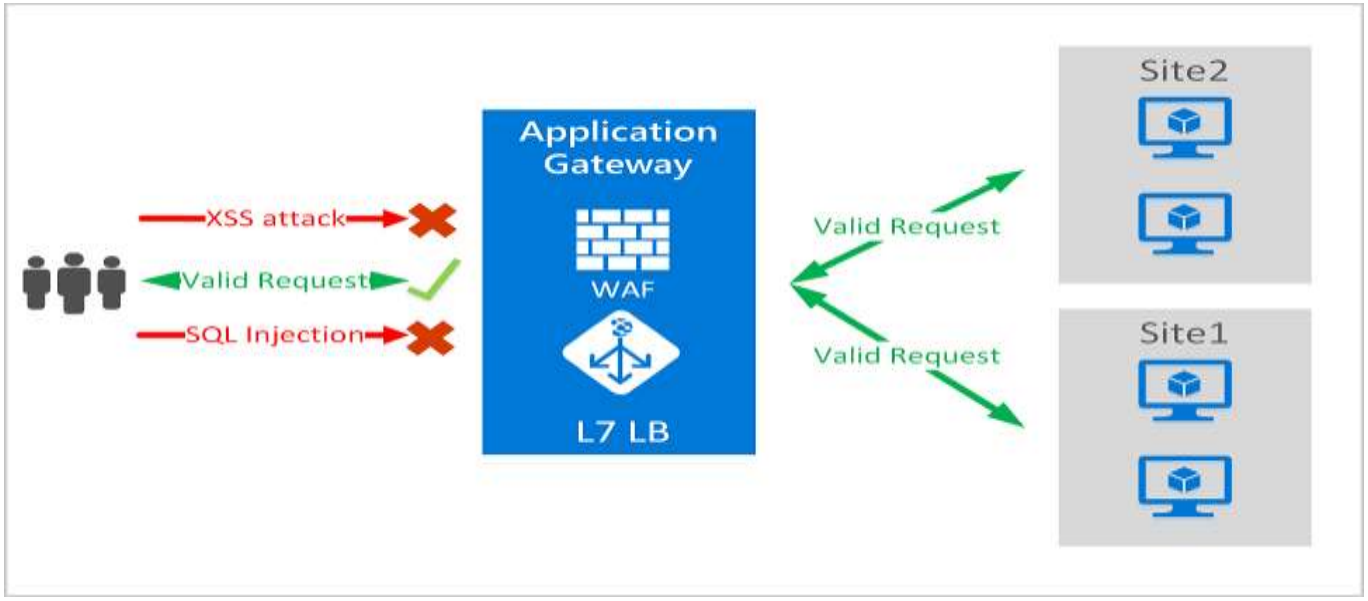
1. **Data scavenging (**the process of searching through a system's data residue to gain unauthorized access to sensitive or valuable information.)

2. **Data reduplication (**a technique that removes duplicate copies of data to improve storage efficiency and reduce the amount of storage media needed.)

Application based attacks

- The applications running on a cloud may be exposed to various attacks by injecting code which may trace execution paths and exploit this information for malicious purposes.

1. **Malware injection attacks**
2. **Shared architectures**
3. **Web services & protocol based attacks**



Major Public Cloud Cybersecurity Incidents Around the Globe

Capital One cloud data breach – USA (2019)

- **Major data breach**
  - Approximately 106 million individuals in the USA and Canada were affected.
  - Customer information was accessed without authorization.
  - The attacker exploited a server-side request forgery (SSRF) vulnerability associated with a web application firewall configuration.
- **Attack mechanism:**
  1. The attacker exploited an application-layer vulnerability.
  2. The vulnerability enabled access to AWS instance metadata.
  3. Temporary AWS credentials were obtained.
  4. Excessive permissions enabled access to cloud storage.
  5. Customer information was downloaded.

Microsoft Azure and Microsoft cloud identity compromise – Global (2023–2024)

Cloud platform: Microsoft cloud identity infrastructure and Exchange Online

- **Identity compromise**
  - The Storm-0558 campaign affected Microsoft customer email accounts.
  - Attackers used forged authentication tokens to access certain Exchange Online accounts.
  - The incident affected US government and other organizational email accounts.

- **Attack mechanism:**
  - Theft of a Microsoft signing key.
  - Forging authentication tokens.
  - Abuse of cloud identity authentication.
  - Unauthorized access to email data.

Snowflake customer data breaches – Global (2024)

- **Cloud platform: Snowflake cloud data platform**
- Large-scale account compromise
  - Multiple customer environments were accessed by attackers.
  - Stolen credentials were used to access customer accounts.
  - Some compromised accounts did not have MFA enabled.
- **Affected organizations included:**
  - Ticketmaster.
  - Santander Bank.
- **Attack mechanism:**
  1. Attackers obtained previously stolen credentials.
  2. They authenticated to customer Snowflake environments.
  3. They accessed and extracted stored information.
  4. Stolen information was used in extortion activities.

Microsoft Midnight Blizzard cloud email compromise – USA (2024)

- **Cloud platform: Microsoft corporate cloud environment**
- **Nation-state intrusion**
  - Microsoft disclosed that the Russian state-sponsored actor Midnight Blizzard had accessed certain corporate email accounts.
  - The attackers used password-spraying techniques against a legacy non-production test tenant.
  - They subsequently exploited an OAuth application to access additional corporate email.
- **Security lessons:**
  - Secure legacy and test environments.
  - Monitor password spraying.
  - Audit OAuth application permissions.
  - Enforce MFA and privileged access controls.
  - Investigate suspicious cloud identity activity.

European Commission AWS cloud breach – Europe (2026)

- **Cloud platform: Amazon Web Services (AWS)**
- Supply-chain compromise, March 2026
  - The European Commission disclosed a compromise affecting its public website hosting platform, europa.eu.
  - Attackers obtained an AWS secret through the Trivy software supply-chain compromise.
  - Approximately 91.7 GB of compressed data was exfiltrated.
  - Personal information and email-related data were among the exposed information.
  - Data associated with other EU entities may also have been affected.
- **Attack mechanism:**
  1. A compromised version of the Trivy security scanning tool entered the software supply chain.
  2. AWS credentials were harvested from the affected environment.
  3. Attackers used the credentials to access an AWS account.
  4. They performed reconnaissance and created additional access credentials.
  5. Data was exfiltrated.

CrowdStrike global IT outage – Worldwide (2024)

- **Technology involved: CrowdStrike Falcon and Microsoft Windows**

- Global operational disruption, 19 July 2024
  - A defective CrowdStrike software update caused Windows systems to crash.
  - Approximately 8.5 million Windows devices were affected.
  - Aviation, banking, healthcare, retail, and other sectors experienced disruptions.

Important distinction:

- **This was not a cloud data breach or a cyberattack. It was a defective security software update with a worldwide operational impact.**
- **It shows the systemic risks of relying on centralized software and cloud-connected security ecosystems.**

Conclusion

- A completely new realm for compute, storage, access, flexibility, productivity and economy of scale has been made possible by the cloud computing environment.

- Cloud Computing also has given rise to further security concerns for the users, IT personnel as well as enterprises or individuals.

- By being aware of cloud computing security challenges and issues, organization's IT team may develop a multi-cloud deployment security strategy to safeguard one's company/enterprise.

Thank You



Cloud Computing Cybersecurity Issues: Threats, Vulnerabilities, Attacks and Protection Mechanisms

Cloud computing has transformed how governments, universities, financial institutions, businesses, and research organizations store, process, and share information. However, the migration of IT infrastructure, applications, databases, and services to cloud environments introduces significant cybersecurity challenges.

Cloud cybersecurity is particularly important because organizations no longer maintain complete physical control over their computing infrastructure. Data, applications, virtual machines, networks, storage, and security controls may be distributed across multiple data centres, cloud providers, and geographical locations.

The major concern is that a security failure in one component of a cloud environment may compromise the confidentiality, integrity, and availability of the entire cloud-based service.

This discussion covers the major cloud computing cybersecurity issues, attack mechanisms, real-world incidents, AI/ML-based security mechanisms, and a proposed cloud security architecture.

2. Major cybersecurity issues in cloud computing

The following are some of the most significant cloud cybersecurity threats.

The Cloud Security Alliance's 2026 report identifies 11 leading cloud security threats based on industry surveys. Inadequate Identity and Access Management ranks first, while AI-enhanced attacks and AI system compromise have emerged as new major concerns.

2.1 Cloud misconfiguration

High risk

Misconfiguration is one of the most common causes of cloud security incidents.

Examples:

- Publicly accessible cloud storage buckets.
- Databases exposed to the internet.
- Incorrect firewall and security group rules.
- Unprotected virtual machines.
- Incorrect access permissions.
- Exposed administrative interfaces.
- Insecure default configurations.

Example attack scenario:

1. An organization stores confidential research data in cloud storage.
2. The storage bucket is accidentally configured for public access.
3. An attacker discovers the exposed storage location.
4. The attacker downloads confidential files.
5. Sensitive information is disclosed without compromising the cloud provider itself.

Security mechanisms:

- Cloud Security Posture Management (CSPM).
- Automated configuration auditing.
- Infrastructure as Code (IaC) security scanning.
- Continuous compliance monitoring.
- Automated remediation of dangerous configurations.

2.2 Identity and Access Management (IAM) attacks

Critical risk

Identity and Access Management controls who can access cloud resources and what operations they can perform.

Attackers frequently target user credentials, administrator accounts, API keys, access tokens, and service accounts.

Major vulnerabilities:

- Weak passwords.
- Absence of Multi-Factor Authentication (MFA).
- Stolen credentials.
- Excessive user privileges.
- Poorly managed service accounts.
- Compromised API keys.
- Privilege escalation.
- Session hijacking and token theft.

Example:

An attacker obtains the credentials of a cloud administrator through phishing. The attacker then logs into the cloud console and accesses virtual machines, databases, and storage systems.

Protection mechanisms:

1. Multi-Factor Authentication.
2. Role-Based Access Control (RBAC).
3. Attribute-Based Access Control (ABAC).
4. Privileged Access Management (PAM).
5. Identity federation.
6. Short-lived access tokens.
7. Continuous identity monitoring.

8. Zero Trust Architecture (ZTA).

A particularly important principle is Least Privilege Access: users should receive only the permissions necessary to perform their assigned responsibilities.

2.3 Insecure APIs and interfaces

Cloud environments depend heavily on APIs for communication between applications, databases, virtual machines, storage, and cloud management services.

An insecure API can provide attackers with an entry point into the cloud infrastructure.

Common API vulnerabilities:

- Broken authentication.
- Broken authorization.
- API key exposure.
- Excessive data exposure.
- Injection attacks.
- Inadequate input validation.
- Unrestricted API access.
- Rate-limit bypass.

Example attack:

An attacker discovers an API endpoint that retrieves student information from a university cloud database. Due to inadequate authorization checks, the attacker changes a student ID in the API request and accesses another student's personal information.

Protection mechanisms:

- API Gateway.
- Web Application Firewall (WAF).
- OAuth 2.0 and OpenID Connect.
- Mutual TLS (mTLS).
- API authentication and authorization.
- Rate limiting.
- Input validation.
- API security testing.

2.4 Data breaches and unauthorized data access

Critical risk

A cloud data breach occurs when an unauthorized individual gains access to confidential or sensitive information.

Cloud databases may contain:

- Personal identification information.

- Financial records.
- Medical information.
- Government records.
- University research data.
- Intellectual property.
- Authentication credentials.

Attack mechanisms:

- Stolen credentials.
- SQL injection.
- Misconfigured cloud storage.
- Insider threats.
- Exploitation of vulnerable applications.
- Compromised third-party services.

Protection mechanisms:

Security mechanism	Purpose
AES-256 encryption	Protect data at rest
TLS 1.3	Protect data in transit
Database encryption	Protect database contents
Tokenization	Replace sensitive values with tokens
Data Loss Prevention (DLP)	Detect and prevent unauthorized data transfers
Data Access Governance	Control access to sensitive data
Data classification	Identify different levels of sensitivity

2.5 Account hijacking and credential theft

Account hijacking occurs when attackers obtain control over legitimate cloud accounts.

Common techniques:

- Phishing.
- Credential stuffing.
- Brute-force attacks.
- Password spraying.
- Session cookie theft.
- OAuth token theft.
- Malware-based credential harvesting.

Consequences:

- Unauthorized access to cloud applications.
- Theft of confidential data.
- Creation of unauthorized virtual machines.
- Modification of security configurations.

- Installation of ransomware.
- Financial losses through unauthorized resource consumption.

Protection:

- Phishing-resistant MFA.
- Passwordless authentication.
- Conditional access policies.
- Continuous session validation.
- Detection of unusual login locations and devices.
- Automated account suspension following suspicious activity.

2.6 Cloud ransomware attacks

Ransomware is malicious software that encrypts files or otherwise makes organizational data unavailable and demands payment for recovery.

Cloud environments can be affected through:

- Compromised cloud administrator accounts.
- Infected virtual machines.
- Compromised endpoints synchronized with cloud storage.
- Exploited application vulnerabilities.
- Compromised backup accounts.
- Abuse of cloud storage APIs.

Typical attack lifecycle:

Initial compromise

Phishing / stolen credentials / vulnerable application

Privilege escalation

Obtaining higher cloud permissions

Lateral movement

Accessing additional cloud resources

Data exfiltration and encryption

Stealing or encrypting organizational data

Extortion and service disruption

Ransom demand, operational disruption and possible data disclosure

Protection mechanisms:

- Immutable backups.
- Offline backups.
- Endpoint Detection and Response (EDR).
- Network segmentation.
- Privileged account protection.
- Ransomware behaviour detection.
- Recovery testing.
- Separate backup administration accounts.

2.7 Distributed Denial of Service (DDoS)

DDoS attacks attempt to make cloud-hosted services unavailable by overwhelming them with malicious traffic or requests.

Types of DDoS attacks:

Attack type	Mechanism
Volumetric	Flooding networks with massive traffic
Protocol-based	Exploiting network protocol weaknesses
Application-layer	Overloading HTTP, DNS or application services
DNS amplification	Using DNS infrastructure to amplify traffic
HTTP flood	Sending excessive HTTP requests

Consequences:

- Website unavailability.
- Disruption of online education.
- Financial transaction failures.
- Service degradation.
- Increased cloud infrastructure costs.

Protection:

- Cloud DDoS protection services.
- Web Application Firewall.
- Rate limiting.
- Traffic filtering.
- Content Delivery Network (CDN).
- Auto-scaling with spending controls.
- Network anomaly detection.

2.8 Insider threats

Insider threats originate from individuals who already have legitimate access to cloud systems.

These may include:

- Employees.
- System administrators.
- Database administrators.
- Developers.
- Contractors.
- Third-party service personnel.

Types:

1. Malicious insider: deliberately steals or destroys information.
2. Negligent insider: accidentally exposes confidential data.
3. Compromised insider: an employee's account is taken over by an attacker.

Example: A cloud administrator downloads confidential research information and transfers it to an external storage account.

Protection mechanisms:

- User Behaviour Analytics (UBA).
- Privileged Access Management.
- Data Loss Prevention.
- Separation of duties.
- Audit trails.
- Continuous access monitoring.
- Regular access reviews.

2.9 Insecure virtualization and hypervisor vulnerabilities

Virtualization is fundamental to cloud computing. Multiple virtual machines may operate on the same physical server.

The hypervisor manages the underlying physical resources and isolates virtual machines.

A vulnerability in the hypervisor may threaten the isolation between virtual machines.

Major threats:

- Hypervisor exploitation.
- VM escape.
- VM-to-VM attacks.
- Insecure VM images.
- Virtual machine sprawl.
- Snapshot theft.
- Unauthorized VM cloning.
- Side-channel attacks.

VM escape: An attacker compromises a virtual machine and attempts to cross the isolation boundary to interact with the hypervisor or host system.

Protection:

- Hypervisor security patching.
- Strong VM isolation.
- Secure VM images.
- Hardware-assisted virtualization security.
- Virtual machine integrity monitoring.
- Network micro-segmentation.

2.10 Supply chain attacks

Cloud services depend on many third-party components, including software libraries, APIs, plugins, development tools, managed services, and external vendors.

An attacker may compromise a third-party component and use it as an entry point into an organization's cloud environment.

Examples:

- Malicious software packages.
- Compromised CI/CD pipelines.
- Vulnerable third-party libraries.
- Compromised software updates.
- Exposed vendor credentials.
- Insecure managed service integrations.

Protection mechanisms:

- Software Bill of Materials (SBOM).
- Software Composition Analysis (SCA).
- Dependency vulnerability scanning.
- Secure CI/CD pipelines.
- Vendor security assessments.
- Code signing.
- Third-party access restrictions.

2.11 Advanced Persistent Threats (APTs)

APTs are sophisticated attacks in which threat actors maintain unauthorized access to an organization's systems for an extended period.

Cloud infrastructure is an attractive target for espionage, intellectual property theft, and strategic information collection.

Typical attack activities:

- Initial compromise through phishing.
- Credential theft.
- Privilege escalation.
- Lateral movement.
- Persistence through cloud identities.
- Data exfiltration.

- Concealment of malicious activities.

Protection mechanisms:

- Threat intelligence.
- Security Information and Event Management (SIEM).
- Extended Detection and Response (XDR).
- Endpoint Detection and Response (EDR).
- Cloud Detection and Response (CDR).
- Behavioural analytics.
- Threat hunting.

2.12 Cloud visibility and logging deficiencies

Organizations may not have adequate visibility into their cloud environments, particularly when resources are distributed across multiple regions and providers.

Problems include:

- Incomplete audit logs.
- Unmonitored cloud resources.
- Lack of centralized security monitoring.
- Inconsistent log retention.
- Insufficient network visibility.
- Delayed detection of suspicious activity.

Protection:

- Centralized logging.
- SIEM integration.
- Cloud-native audit logging.
- Continuous monitoring.
- Security dashboards.
- Automated incident alerting.

2.13 Cryptojacking and unauthorized resource consumption

Cryptojacking occurs when attackers secretly use cloud computing resources to mine cryptocurrency.

Attackers may compromise cloud accounts, virtual machines, containers, or exposed computing services.

Consequences:

- Increased cloud bills.
- Reduced processing capacity.
- Performance degradation.
- Unauthorized resource consumption.
- Potential compromise of other cloud services.

Protection:

- CPU/GPU utilization monitoring.
- Unusual resource consumption detection.
- Cloud cost anomaly detection.
- Runtime malware detection.
- Resource quotas.
- Automated shutdown of suspicious instances.

2.14 Cloud-specific AI security threats

AI introduces two dimensions of cloud security risks: attackers can use AI to improve their attacks, and attackers can directly compromise AI systems hosted in the cloud.

Threat	Description
AI-enhanced phishing	Highly convincing targeted phishing
Automated vulnerability discovery	AI-assisted identification of weaknesses
Prompt injection	Manipulation of cloud-hosted LLM applications
Data poisoning	Manipulation of training data
Model theft	Unauthorized copying of proprietary models
Model extraction	Reconstructing model behaviour through queries
Model supply chain attacks	Compromising model dependencies or artifacts
AI agent compromise	Abusing agent permissions, tools and credentials
Training data leakage	Exposure of confidential training information

Protection mechanisms:

- AI model access control.
- Secure model registries.
- Training data validation.
- Prompt injection protection.
- Model integrity verification.
- AI activity monitoring.
- Runtime guardrails.
- Human approval for sensitive agent actions.

The 2026 CSA report specifically highlights AI-enhanced attacks and AI system compromise as two newly prominent cloud security threats.

2.15 **Summary of cloud cybersecurity threats**

The following table summarizes the major issues and corresponding protection technologies.

No.	Cybersecurity issue	Major security solution
1	Cloud misconfiguration	CSPM

2	IAM attacks	MFA, RBAC, ZTA
3	Insecure APIs	API Gateway, WAF
4	Data breaches	Encryption, DLP
5	Account hijacking	MFA, UEBA
6	Ransomware	EDR, immutable backup
7	DDoS	CDN, DDoS protection
8	Insider threats	PAM, UEBA
9	Hypervisor attacks	Hypervisor hardening
10	Container vulnerabilities	Image scanning, runtime security
11	Supply chain attacks	SBOM, SCA
12	APTs	SIEM, XDR, threat intelligence
13	Lack of visibility	Centralized logging, SIEM
14	Cryptojacking	Cost and resource anomaly detection
15	AI-related attacks	AI security monitoring and guardrails

Cloud Security Posture Management (CSPM)

CSPM continuously identifies and assesses cloud configuration weaknesses.

For example, CSPM can identify:

- Publicly exposed storage.
- Unencrypted databases.
- Unused administrator accounts.
- Unprotected virtual machines.
- Incorrect security group settings.
- Non-compliant cloud resources.

The system can generate alerts and, where safely authorized, automatically remediate misconfigurations.

Major Public Cloud Cybersecurity Incidents Around the Globe

Public cloud platforms such as Amazon Web Services (AWS), Microsoft Azure, and Google Cloud Platform (GCP) have become critical infrastructure for governments, banks,

universities, healthcare organizations, telecommunications companies, and multinational businesses.

However, public cloud environments have also been involved in major cybersecurity incidents, including data breaches, identity compromises, ransomware, misconfiguration, supply-chain attacks, and large-scale service disruptions.

A key distinction is that a cybersecurity incident in a cloud-hosted customer environment does not necessarily mean the cloud provider's underlying infrastructure was compromised. In many cases, attackers exploit customer-side misconfigurations, stolen credentials, vulnerable applications, or insecure access policies.

Below is a selection of significant incidents from different regions and cloud platforms, including their attack mechanisms, consequences, and security lessons.

1. Major global public cloud cybersecurity incidents

1.1 Capital One cloud data breach – USA (2019)

Cloud platform: Amazon Web Services (AWS)

Major data breach

- Approximately 106 million individuals in the USA and Canada were affected.
- Customer information was accessed without authorization.
- The attacker exploited a server-side request forgery (SSRF) vulnerability associated with a web application firewall configuration.

Attack mechanism:

1. The attacker exploited an application-layer vulnerability.
2. The vulnerability enabled access to AWS instance metadata.
3. Temporary AWS credentials were obtained.
4. Excessive permissions enabled access to cloud storage.
5. Customer information was downloaded.

Information exposed:

- Names and addresses.
- Credit scores.
- Credit card application information.
- Social Security numbers for some affected individuals.

Security lessons:

- Properly configure IAM permissions.
- Protect cloud instance metadata.
- Implement least-privilege access.
- Continuously monitor cloud storage access.

- Conduct application security assessments.

1.2 Microsoft Azure and Microsoft cloud identity compromise – Global (2023–2024)

Cloud platform: Microsoft cloud identity infrastructure and Exchange Online

Identity compromise

- The Storm-0558 campaign affected Microsoft customer email accounts.
- Attackers used forged authentication tokens to access certain Exchange Online accounts.
- The incident affected US government and other organizational email accounts.

Attack mechanism:

- Theft of a Microsoft signing key.
- Forging authentication tokens.
- Abuse of cloud identity authentication.
- Unauthorized access to email data.

Security lessons:

- Protect cryptographic signing keys.
- Strengthen cloud identity architecture.
- Monitor authentication tokens.
- Improve logging and detection.
- Apply strict controls to privileged cloud infrastructure.

1.3 Snowflake customer data breaches – Global (2024)

Cloud platform: Snowflake cloud data platform

Large-scale account compromise

- Multiple customer environments were accessed by attackers.
- Stolen credentials were used to access customer accounts.
- Some compromised accounts did not have MFA enabled.

Affected organizations included:

- Ticketmaster.
- Santander Bank.

Attack mechanism:

1. Attackers obtained previously stolen credentials.

2. They authenticated to customer Snowflake environments.
3. They accessed and extracted stored information.
4. Stolen information was used in extortion activities.

Security lessons:

- Enforce MFA.
- Monitor unusual login activities.
- Rotate exposed credentials.
- Implement network access policies.
- Monitor bulk database extraction.

1.4 Microsoft Midnight Blizzard cloud email compromise – USA (2024)

Cloud platform: Microsoft corporate cloud environment

Nation-state intrusion

- Microsoft disclosed that the Russian state-sponsored actor Midnight Blizzard had accessed certain corporate email accounts.
- The attackers used password-spraying techniques against a legacy non-production test tenant.
- They subsequently exploited an OAuth application to access additional corporate email.

Security lessons:

- Secure legacy and test environments.
- Monitor password spraying.
- Audit OAuth application permissions.
- Enforce MFA and privileged access controls.
- Investigate suspicious cloud identity activity.

1.5 Toyota cloud data exposure – Japan (2023)

Cloud environment: Toyota customer cloud environment

Cloud misconfiguration

- Toyota disclosed that vehicle-related customer information had been publicly accessible for an extended period.
- The incident involved cloud configuration errors.
- The company reported that some customer data could have been accessed by unauthorized parties.

Security lessons:

- Continuously audit cloud configurations.
- Restrict public storage access.
- Monitor changes to access permissions.

- Establish automated cloud security posture management.

1.6 European Commission AWS cloud breach – Europe (2026)

Cloud platform: Amazon Web Services (AWS)

Supply-chain compromise

March 2026

- The European Commission disclosed a compromise affecting its public website hosting platform, europa.eu.
- Attackers obtained an AWS secret through the Trivy software supply-chain compromise.
- Approximately 91.7 GB of compressed data was exfiltrated.
- Personal information and email-related data were among the exposed information.
- Data associated with other EU entities may also have been affected.

Attack mechanism:

1. A compromised version of the Trivy security scanning tool entered the software supply chain.
2. AWS credentials were harvested from the affected environment.
3. Attackers used the credentials to access an AWS account.
4. They performed reconnaissance and created additional access credentials.
5. Data was exfiltrated.

Security lessons:

- Secure software development pipelines.
- Protect secrets and API keys.
- Implement short-lived cloud credentials.
- Monitor AWS API activity.
- Apply software supply-chain security controls.
- Use SBOM and dependency verification.

This is particularly important because it demonstrates how a compromised security tool can become a pathway into a major public cloud environment.

1.7 Retool cloud application compromise – USA (2023)

Cloud environment: Google Cloud-hosted infrastructure

MFA and identity attack

- Attackers compromised employee accounts through sophisticated SMS phishing.
- They bypassed the organization's MFA protection by exploiting weaknesses in the authentication process.
- The attackers gained access to internal systems and certain cloud customer environments.

Security lessons:

- Use phishing-resistant MFA.
- Protect employee identity systems.
- Monitor suspicious authentication changes.
- Restrict access to production systems.
- Apply strong session and device security.

1.8 Football Australia AWS data exposure – Australia (2024)

Cloud platform: AWS

Cloud credential exposure

- A security incident involved exposed AWS credentials.
- The incident raised concerns about access to cloud storage and sensitive organizational information.
- It highlighted weaknesses in access-key management and cloud security monitoring.

Security lessons:

- Never expose AWS access keys in source code.
- Rotate compromised credentials.
- Use IAM roles rather than long-lived access keys.
- Monitor S3 and other cloud resource access.

1.9 Retool and other third-party cloud service compromise – USA (2023)

Another important aspect of cloud security is the compromise of services that have privileged access to customer environments.

Sumo Logic AWS credential incident (2023): Sumo Logic disclosed an incident involving unauthorized access to an AWS account and advised customers to rotate certain credentials and secrets.

Security lessons:

- Secure third-party integrations.
- Regularly rotate access keys.
- Restrict vendor permissions.
- Monitor access to secrets and cloud management interfaces.

1.10 Microsoft Azure service disruption – USA (2024)

Cloud platform: Microsoft Azure

Cloud availability incident

18 July 2024

- An Azure infrastructure incident affected virtual machine access in the Central US region.
- Some enterprise customers could not access their hosted services.
- The disruption lasted approximately half a day.

Security lesson: Cloud security must address availability and resilience in addition to confidentiality and integrity. This was an infrastructure/service disruption, not a confirmed malicious cyberattack.

1.11 CrowdStrike global IT outage – Worldwide (2024)

Technology involved: CrowdStrike Falcon and Microsoft Windows

Global operational disruption

19 July 2024

- A defective CrowdStrike software update caused Windows systems to crash.
- Approximately 8.5 million Windows devices were affected.
- Aviation, banking, healthcare, retail, and other sectors experienced disruptions.

Important distinction: **This was not a cloud data breach or a cyberattack. It was a defective security software update with a worldwide operational impact. It shows the systemic risks of relying on centralized software and cloud-connected security ecosystems.**

2. Other significant cloud-related security incidents

The following cases are also useful for understanding different cloud vulnerabilities.

Incident	Year	Cloud environment	Main issue
Accenture cloud storage exposure	2017	AWS S3	Publicly exposed storage
Uber data breach	2016	AWS-related infrastructure	Exposed credentials and unauthorized access
Code Spaces attack	2014	AWS	Compromised AWS control panel and data deletion
Microsoft Cosmos DB (ChaosDB)	2021	Azure	Vulnerability allowing unauthorized database access
DarkBeam data exposure	2023	Cloud-hosted Elasticsearch	Unsecured database
Toyota customer data exposure	2023	Cloud environment	Misconfiguration
Snowflake customer breaches	2024	Snowflake	Stolen credentials and inadequate MFA
European Commission breach	2026	AWS	Software supply-chain compromise

A few additional explanations are particularly important:

A. Microsoft Azure Cosmos DB – ChaosDB (2021)

A vulnerability in Azure Cosmos DB's Jupyter Notebook feature could have allowed unauthorized access to customer database credentials. Microsoft notified affected customers and remediated the vulnerability.

B. Code Spaces – AWS (2014)

An attacker gained control of the company's AWS management console and deleted resources, causing severe business disruption. Code Spaces ultimately ceased operations.

C. Accenture – AWS S3 exposure (2017)

Security researchers discovered unsecured AWS S3 storage containing sensitive corporate information, including credentials and internal data.

These incidents demonstrate that cloud security failures can result in data theft, infrastructure destruction, and even the collapse of a cloud-dependent business.

3. Comparative analysis of major incidents

The following table compares the most important incidents according to their security implications.

Incident	Year	Cloud provider/platform	Primary attack type
Code Spaces	2014	AWS	Account compromise and destructive attack
Accenture	2017	AWS	Public storage exposure
Capital One	2019	AWS	SSRF and IAM exploitation
ChaosDB	2021	Azure	Cloud database vulnerability
Toyota	2023	Cloud environment	Misconfiguration
Storm-0558	2023	Microsoft cloud	Authentication token forgery
Retool	2023	Google Cloud-related services	Spear phishing and MFA compromise
Midnight Blizzard	2024	Microsoft cloud	Password spraying and OAuth abuse
Snowflake	2024	Snowflake	Stolen credentials
CrowdStrike outage	2024	Cloud-connected security ecosystem	Defective software update
European Commission	2026	AWS	Software supply-chain compromise

4. Classification of incidents by cybersecurity vulnerability

An important observation is that different cloud incidents exploit different security weaknesses.

Five particularly important lessons

1. **Identity compromise:** Stolen credentials, weak MFA, and compromised authentication tokens are major attack pathways.
2. **Cloud misconfiguration:** Public storage and incorrectly configured access permissions can expose enormous volumes of data.
3. **Supply-chain vulnerabilities:** A compromised third-party development or security tool can provide access to cloud infrastructure.
4. **Insufficient monitoring:** Organizations must monitor cloud API calls, administrator activities, unusual data transfers, and access-key creation.
5. **Cloud dependency and resilience:** Even when no attacker is involved, a faulty update or infrastructure failure can disrupt critical services worldwide.